

📍 Avenue V. Maistriau 8a
B-7000 Mons
☎ +32 (0)65 33 81 54
📧 scitech-mons@heh.be

WWW.HEH.BE

UE : Networks : Connected and secure

- **AA : Cybersécurité 2**
Denis Mandoux

Bachelier en Informatique
Orientation réseaux et télécommunications

Table des matières

1. Security Fabric.....	(slide 2)	1
2. Authentication	(slide 45)	23
3. Journalisation	(slide 80)	40
4. Intrusion Prevention System	(slide 125)	63
5. Contrôle d'application.....	(slide 168)	84
6. TLS	(slide 200)	100
7. Haute disponibilité	(slide 252)	126
8. Fortinet Single Sign On	(slide 298)	149
9. SD-WAN	(slide 330)	165
10. ZTNA	(slide 381)	191
11. Bibliographie.....		215

UE : Networks : Connected and secure

- AA : Cybersécurité 2

Denis Mandoux

Bachelier en Informatique
Orientation réseaux et télécommunications

Chapitre 1

Fortinet Security Fabric

Objectifs

- A l'issue de ce chapitre, l'étudiant doit être capable de
 - Définir la notion de Fortinet Security Fabric.
 - Expliquer l'intérêt de la Fortinet Security Fabric.
 - Identifier les équipements qui participent à la Fortinet Security Fabric.
 - Déployer la solution Fortinet Security Fabric dans un réseau simple.

Security Fabric

- **Challenges**
 - La surface d'attaque augmente avec le réseau de l'entreprise
 - Cloud, Multicloud, IoT, télétravail, BYOD, ...
 - La quantité et la vitesse des menaces continue d'augmenter
 - Malware as a service, malware multi-vecteurs, ...
 - La complexité augmente avec le réseau
 - **Gestion des accès et des dispositifs**
 - Fusion, acquisition, télétravailleurs, fournisseurs, ...
 - **Nombre de solutions de sécurité**
 - Différentes solutions sont développées pour faire faces aux différentes attaques.
 - Une entreprise peut utiliser plus de 70 solutions de sécurité pour faire face aux différentes attaques possibles.
 - **Normes et réglementation à respecter**
 - RGPD, ISO 27000, CIS, NIST, ...

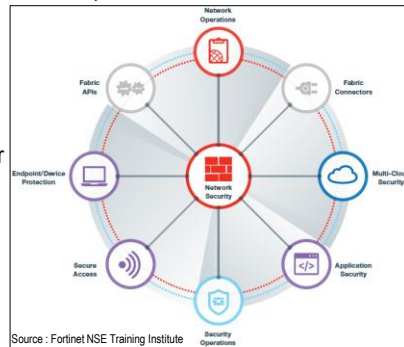
Security Fabric

- **Fortinet Security Fabric**

- **Solution de sécurité offrant une approche globale et centralisée**

- Tous les périphériques réseau sont intégrés dans un système de défense centralisé et automatisé.
 - L'environnement réseau est visible depuis une console unique Permet d'avoir une vue d'ensemble de tous les points d'infiltration potentiels et de coordonner les défenses.

Cette architecture est appelée CSMA (Cybersecurity Mesh Architecture) par Gartner



5

Security Fabric

- **Avantages**

- **Automatisation des opérations de sécurité**

- Diminue les risques notamment grâce à la détection proactive des menaces, à la corrélation des menaces et aux échanges d'alertes.

- **Gestion centralisée des périphériques**

- Partage en temps réel des renseignements sur les menaces entre périphériques.

- **Couvre l'ensemble de la surface d'attaque du réseau.**

- Tous les éléments de l'IoT jusqu'au cloud sont intégrés dans l'écosystème de sécurité.
 - Large visibilité sur l'ensemble du réseau.

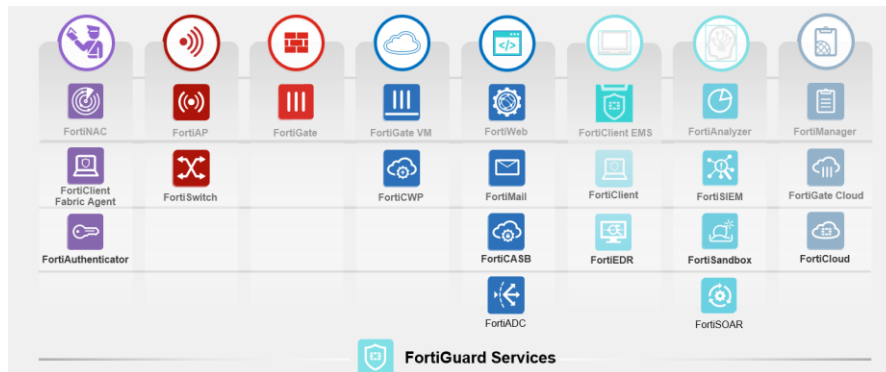
- **"Ouvert"**

- Des API permettent l'intégration d'équipements d'autres fabricants.
 - > 70 partenaires "Fabric-Ready".
 - Des API REST et les scripts DevOps permettent aux clients d'ajouter les équipements non compatibles Fabric.



6

- Composants de la solution Fortinet Security Fabric



Source : FortinetNSE Training Institute

- Composants de la solution Fortinet Security Fabric (suite)

- Cœur de la solution

- Au minimum, il faut
 - Deux FortiGate en mode NAT (un FortiGate racine et un FortiGate en aval pour la segmentation interne).
 - Un FortiAnalyzer ou une solution de journalisation dans le cloud (FortiAnalyzer Cloud ou FortiGate Cloud).

- Toutes les informations relatives à l'ensemble de l'écosystème de sécurité sont visibles sur les pages Topologie physique et Topologie logique du FortiGate racine.

- Équipements recommandés pour améliorer la visibilité et le contrôle

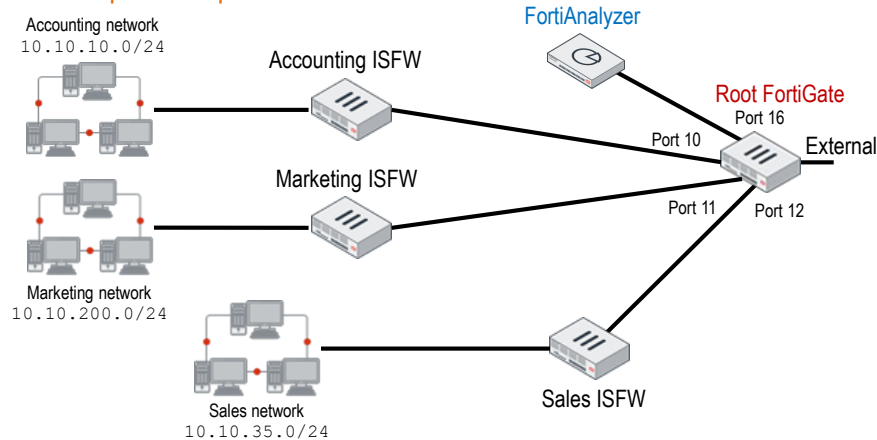
- FortiManager, FortiAP, FortiSwitch, FortiClient, FortiClient EMS, FortiSandbox, FortiMail, FortiWeb, FortiNDR, FortiDeceptor

- Solution étendue

- Autres solutions Fortinet ou équipements tiers en fonction des besoins.
 - Par exemple : FortiADC, FortiDDoS, FortiWLC, FortiAuthenticator, FortiSIEM, FortiCache, FortiToken.

Security Fabric

• Exemple de déploiement



Source : Fortinet NSE Training Institute

9

Security Fabric

• Etapes de configuration de la solution Fortinet Security Fabric

– Sur le FortiGate racine

- Activez *Security Fabric Connection* sur les interfaces requises.
- Activez le connecteur « Security Fabric » et sélectionnez « Serve as Fabric Root ».
- Configurez FortiAnalyzer ou la journalisation dans le cloud.
- (Facultatif) Préautoriser les dispositifs en aval.

– Sur les dispositifs en aval

- Activez *Security Fabric Connection* et *Device Detection* sur les interfaces requises.
- Activez la connexion « Security Fabric » et sélectionnez « Join Existing Fabric ».
- Spécifiez l'adresse IP du dispositif racine.

– FortiGate racine

- Autoriser tous les dispositifs en aval (s'ils n'ont pas été préautorisé à l'étape 1).

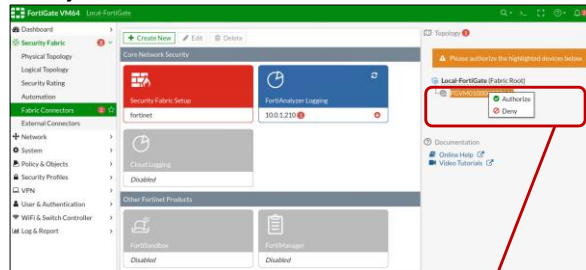
- [illegible]

- FortiAnalyzer Settings
- Settings will be retrieved from the root FortiGate in the Security Fabric.
- Status Enabled Refresh

- Autoriser des équipements en aval (suite)
 - Le FortiGate en aval doit avoir été autorisé à rejoindre le Fortinet Fabric sur le FortiGate racine

⚠ FortiGate not authorized. Log in to root FortiGate and confirm authorization of this device.

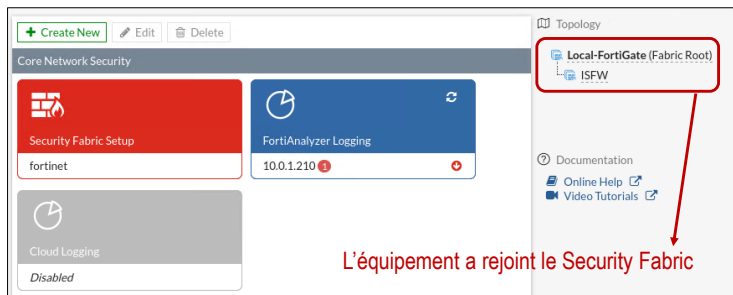
Security Fabric > Fabric Connectors



L'équipement attend l'autorisation de rejoindre le Security Fabric

13

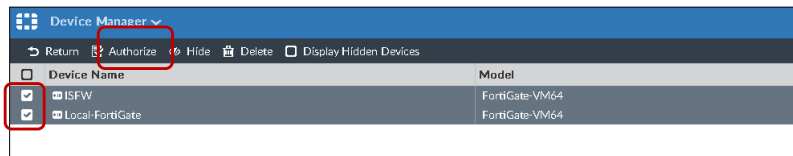
- Autoriser des équipements en aval (suite)



L'équipement a rejoint le Security Fabric

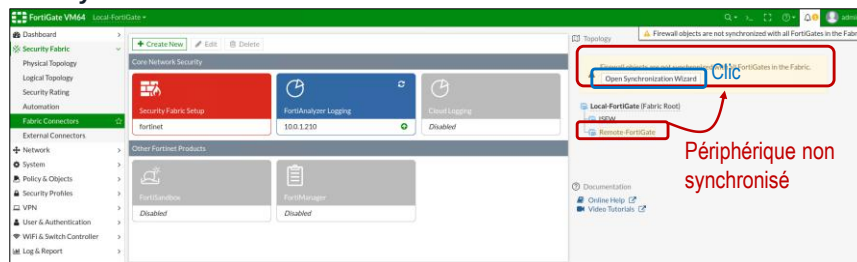
14

- Autoriser des équipements en aval (suite)
 - Onglet "Authorize" sur le FortiAnalyzer
 - Device Manager → authorize



- Synchronisation des objets
 - La synchronisation s'effectue toujours depuis le FortiGate racine
 - Certains objets (les adresses, les services, ...) sont synchronisés par défaut entre le FortiGate en amont et tous les dispositifs en aval.

Security Fabric > Fabric Connectors



- Synchronisation des objets (suite)
 - Il peut y avoir des conflits lors de la synchronisation d'objets

The screenshot shows the FortiGate configuration interface. A yellow warning box at the top right indicates a conflict: "Firewall objects are in conflict with other FortiGates in the fabric." with a "Review firewall object conflicts" link. A modal window titled "Firewall Object Synchronization" is open, displaying a table of objects. The table has columns for "Fabric Object", "Status", and "Conflicting FortiGate". One object, "sync_add_1", is listed with a status of "Resolved" and a conflicting FortiGate of "Remote-FortiGate". The modal also shows tabs for "Automatic" and "Manual" strategies, and a "Rename All Objects" button.

- Options de synchronisation
 - L'option « configuration-sync »
 - **Default** : le FortiGate participe à la synchronisation des objets.
 - **Local** : le FortiGate ne synchronise pas ses objets avec ceux du FortiGate racine.
 - Ce FortiGate en aval propage néanmoins l'envoi d'objets synchronisé en aval.

```
# config system csf
  set status enable
  set configuration-sync {default | local}
  set fabric-object-unification {default | local}
end
```

- L'option « fabric-object-unification »
 - Commande uniquement disponible sur le FortiGate racine
 - **Default** : les objets sont synchronisés.
 - **Local** : les objets du FortiGate racine ne seront pas synchronisés avec cet équipement mais celui-ci envoie les objets synchronisés en aval.

Configuration

- Options de synchronisation (suite)

- Synchronisation par objet

- Désactivée par défaut.
- Permet de définir, objet par objet, lesquels doivent être synchronisés.
- Cette option n'est pas disponible pour les objets créés sur un FortiGate en aval.

```
config firewall <object>
  edit <name>
    set fabric-object {enable | disable}
  end
```

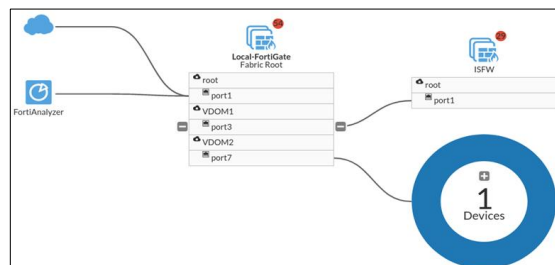
Security Fabric

- Multi-VDOM mode

- Ajout d'un FortiGate en mode multi-VDOM à la Security Fabric

- Chaque VDOM avec ses ports affectés s'affiche lorsqu'un ou plusieurs dispositifs sont détectés.
- Seuls les ports derrière lesquels des périphériques connectés ont été découverts apparaissent dans la vue Security Fabric (→ Activer « Device Detection » dans Network>Interfaces sinon ils n'apparaissent pas).

Global > Physical Topology
 Root > Physical Topology
 FG-traffic > Physical Topology



Device identification

- Surveillance et récolte d'informations
 - Le FortiGate peut "surveiller" le trafic réseau et recueillir des informations sur certains périphériques s'y trouvant.

The screenshot shows the FortiGate web interface for Device Identification. On the left, the 'User & Device' menu is open, with 'Device Inventory' selected. A red arrow labeled 'Ajout manuel' points to the 'New Device' form, which includes fields for Alias, MAC Address, Device Type (set to 'Windows PC'), and options to Upload Image or Capture Image. A purple arrow labeled 'Détection des périphériques' points to the 'Discovered Device Status' table, which lists discovered devices with columns for OS, IP Address, and Last Seen. A note at the bottom right states: 'La détection des périphériques doit être activée au niveau de l'interface.'

Device identification

- Activer la détection des périphériques
 - L'activation se fait interface par interface
 - Network > Interfaces

Ajouter un périphérique manuellement

The screenshot shows the steps to enable device detection on a FortiGate interface.
 1. 'Network > Interfaces' is selected in the left menu.
 2. The 'Networked Devices' section shows 'Device Detection' and 'Active Scanning' both enabled (checked).
 3. The 'Interfaces' table shows 'port1 (HA_Link1)' selected.
 4. The 'New Policy' dialog is open, with 'Device' selected in the 'Source' dropdown.
 5. The 'Edit Device' dialog is open, showing the 'Device Type' as 'Other Network Device'.
 6. A 'Confirm' dialog states: 'Creating a device policy will automatically enable the device identification option for the following interface(s): port3'.
 A red box highlights the 'Device' button in the 'New Policy' dialog. A note at the bottom right states: 'Utiliser "Source Device Type" dans une règle active automatiquement "Device Detection" et "Active Scanning".'

- **Techniques d'identification**
 - **Mode avec Agent**
 - **Nécessite l'utilisation du logiciel Forticlient**
 - Chaque périphérique sera identifié par un *FortiClient UID*.
 - FortiClient collecte et transmet les informations à l'UTM.
 - **L'identification est indépendante de la localisation du périphérique**
 - **Exemple d'informations collectées**
 - L'adresse MAC
 - L'adresse IP
 - Le système d'exploitation
 - Le hostname
 - Le username

- **Techniques d'identification (suite)**
 - **Mode sans agent**
 - Utilise le trafic du périphérique pour l'identifier
 - Les périphériques sont indexés par leur adresse MAC.
 - L'identification peut se baser sur :

- HTTP "User-Agent" header
- TCP Fingerprint
- MAC address OUI
- Options DHCP
- Microsoft Windows Browser Service (MWBS)
- SIP User Agent
- Link Layer Discovery Protocol (LLDP)
- Simple Service Discovery Protocol (SSDP)
- ...

first come, first served



Le mode sans agent nécessite une connectivité directe au FortiGate, c'est-à-dire sans périphérique intermédiaire de couche 3.

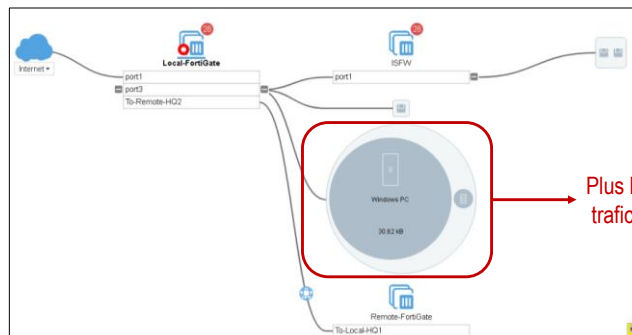
Device identification

- Techniques d'identification (suite)
 - Exemple HTTP "User-Agent" header
 - Capture Wireshark ou TCPdump

```
Hypertext Transfer Protocol
  GET /dumprequest HTTP/1.1\r\n
  Host: rve.org.uk\r\n
  User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.13; rv:60.0) Gecko/20100101 Firefox/60.0\r\n
  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8\r\n
  Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3\r\n
  Accept-Encoding: gzip, deflate\r\n
  Referer: https://www.google.com/\r\n
  Connection: keep-alive\r\n
  Upgrade-Insecure-Requests: 1\r\n
  \r\n
  [Full request URI: http://rve.org.uk/dumprequest]
  [HTTP request 1/3]
  [Response in frame: 116]
  [Next request in frame: 118]
```

Device identification

- Topology view
 - Les équipements détectés sont ajoutés automatiquement dans la vue topologique de Security Fabric.



Plus le périphérique génère de trafic, plus la bulle sera grande

Device identification

• Device Inventory

– Afficher la liste des périphériques

- Périphériques détectés
- Périphériques encodés manuellement

Y Name	Y Details	Y Asset Tags	Y Comment
Custom Device Groups (3)			
Mobile Devices 8 Members	Android Phone Android Tablet BlackBerry Phone BlackBerry PlayBook iPad iPhone Windows Phone Windows Tablet		Phones, tablets, etc.
Network Devices 3 Members	Fortinet Device Other Network Device Router/NAT Device		Routers, firewalls, gateways, e..
Others 2 Members	Gaming Console Media Streaming		Other devices.

User & Device	✓
Device Inventory	
Custom Devices & Groups	

Nombre de périphériques détectés

Clic droit : Afficher, éditer, supprimer

Edit	Delete	Refresh	Search	Total Devices Tracked: 4
Y Status	Y MAC	Y User	Y IP Address	Y Interface
Online	00:0c:29:0b0b:b3	Linux / CentOS 5 (x64)	10.200.2.254	port2
Online	00:0c:29:0b0b:b3	Windows / Server	10.0.1.10	port3
Registered - Off-Net	WIN-OSJMMO6QN6G	Saurabh	10.200.3.1	port1
Online	00:0c:29:0b0b:b3	Windows / Server	10.200.3.1	port1
Offline	00:0c:29:0b0b:b3	Windows / Server	10.200.3.1	port1
Online	00:0c:29:4b:9c:07	Windows / Server	10.200.2.22	port2

27

Device identification

• Device Inventory

– Affichage détaillé en CLI

- # diagnose user device list
- # diagnose endpoint registration list

– Sauvegarde en flash

- La liste des périphériques détectés sont conservés après un reboot.

```
Student # diag user device list
hosts
vd root/0 00:0c:29:0b:db:a9 gen 195/34/140 req 3c redir 0
created 1524s seen 1s port1
ip 10.200.3.1
type 8 'Windows PC' src tcp c 1 gen 140
vd root/0 00:0c:29:0b:db:b3 gen 189/39/100 req 30 redir 0
created 1118s seen 200s port2
ip 10.200.2.254
type 6 'Linux PC' src http c 1 gen 108
os 'Linux' version 'CentOS 5 (x64)' src http id 1020 c 1
vd root/0 00:0c:29:65:6d:99 gen 194/38/139 req 0 redir 0
created 1509s seen 3s port3
ip 10.0.1.10(b) ip6 fe80::dc57:a6d1:4012:7b14
type 8 'Windows PC' src forticlient c 1 gen 139
os 'Windows' version 'server' src forticlient id 0 c 1
host 'WIN-OSJMMO6QN6G' src forticlient
```

```
Student # diagnose endpoint registration list
Forticlient #1 (0):
UID = 4E2602B29AF47B7876E560668CF839
vdom = root
status = registered
source IP = 10.0.1.10
source MAC = 00:0c:29:65:6d:99
```

Méthode de détection
du périphérique

Device identification

- Utilisation des périphériques identifiés
 - Une fois identifiés, les périphériques peuvent être utilisés dans les règles du pare-feu.

The screenshot shows the FortiGate configuration interface. On the left, a firewall rule is being configured under 'Policy & Objects'. The rule is named 'FIT - Intel NUC outbound'. The 'Incoming Interface' is 'FITNUC' and the 'Outgoing Interface' is 'WAN (port17)'. The 'Source' is set to 'all' (highlighted in yellow). The 'Destination' is 'all', 'Schedule' is 'always', and 'Service' is 'ALL'. The 'Action' is 'ACCEPT'. On the right, a 'Select Entries' window is open, showing a list of device categories. The 'Device' tab is selected, and the list includes 'All', 'Android Phone', 'Android Tablet', 'BlackBerry Phone', 'BlackBerry PlayBook', 'FortiCam', 'FortiFone', 'Fortinet Device', 'Gaming Console', and 'IP Phone'. A red arrow points from the 'Source' field of the firewall rule to the 'All' entry in the device selection list.

Security Fabric

- Automatisation
 - Automation Stitches*
 - Des flux de travail automatisés (appelés "stitches") peuvent être définis par l'administrateur
 - Remarque : Aussi disponible sans Security Fabric.
 - Permettent une réponse automatique en fonction d'un événement
 - Configuration d'actions automatisées selon des instructions (if/then).
 - Une ou plusieurs actions peuvent être déclenchées suite à un événement.
 - La détection peut se faire depuis n'importe quel périphérique du Security Fabric.
 - L'action peut être appliquées sur n'importe quel périphérique du Security Fabric.
 - Notification des événements
 - Le paramètre "Minimum Interval" peut être configuré pour ne pas recevoir de notifications répétées au sujet du même événement.

• Automatisation : exemple

On sélectionne un déclencheur

On associe une ou plusieurs actions (en série ou en parallèle)

31

• Automatisation : exemple de notification

- Les hôtes compromis peuvent être affichés dans le FortiGate.
- FortiGate peut envoyer une notification aux administrateurs via Microsoft Teams

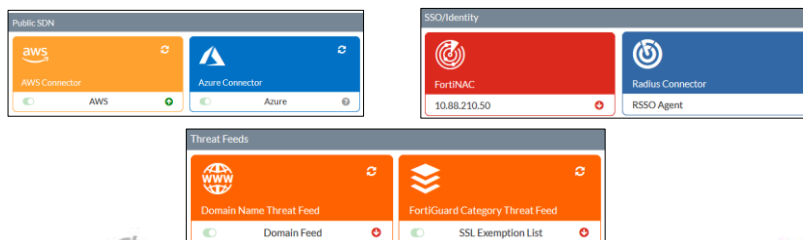
Security Fabric > Physical Topology

Name	FortiGate	Action	Status	Last Trigger Time
Compromised Host				
AutoQ	Demo-ISFW-ENG	Access Layer Quarantine Quarantine FortiClient via EMS IP Ban	Disabled	

32

- **Connecteurs « Security Fabric » (Fabric Connectors)**
 - **Constat**
 - **Les entreprises utilisent parfois de nombreux outils et applications provenant de différents constructeurs**
 - Nombreuses alertes possibles, consoles différentes, ...
 - Difficulté à recruter des professionnels pour gérer tous ces outils.
 - **Manque d'intégration technologique au sein d'environnements complexes (IoT → multicloud)**
 - Complexe à gérer, à opérer des changements.
 - Complexe à automatiser.
 - Les outils informatiques ne sont pas intégrés avec les processus de sécurité.

- **Connecteurs "Security Fabric" (suite)**
 - **Facilitent la connectivité**
 - Ils facilitent la connectivité des solutions de l'architecture "Security Fabric" avec les outils de sécurité existant chez les clients.
 - **Différents connecteurs disponibles**
 - Permettent de répondre aux besoins d'intégration dans différents domaines (Cloud, SDN, flux de veille sur les menaces, SSO/Identification, ...)

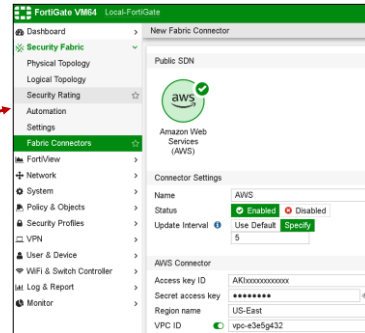
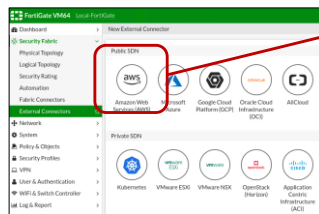


Security Fabric

• Connecteurs Security Fabric (suite)

– Exemple avec la prise en charge multi-cloud

- Le connecteur sert de passerelle pour récupérer des objets et les enregistrer sur le FortiGate.
- Permet une orchestration centralisée des utilisateurs, applications et données sur l'ensemble des environnements.

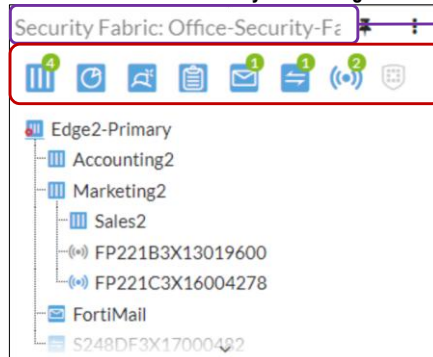


Security Fabric

• Security Fabric Status Widget

– Affiche un résumé visuel de la plupart des périphériques du Security Fabric.

Dashboard > Status > Security Fabric widget



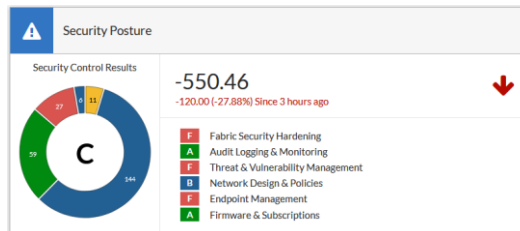
Nom du Security Fabric

Liste des équipements du Security Fabric :

- En bleu : Les périphériques connectés.
- En gris : Les périphériques non configurés ou non détectés.
- En rouge : Les périphériques plus connectés ou non autorisés.

Security Fabric Rating

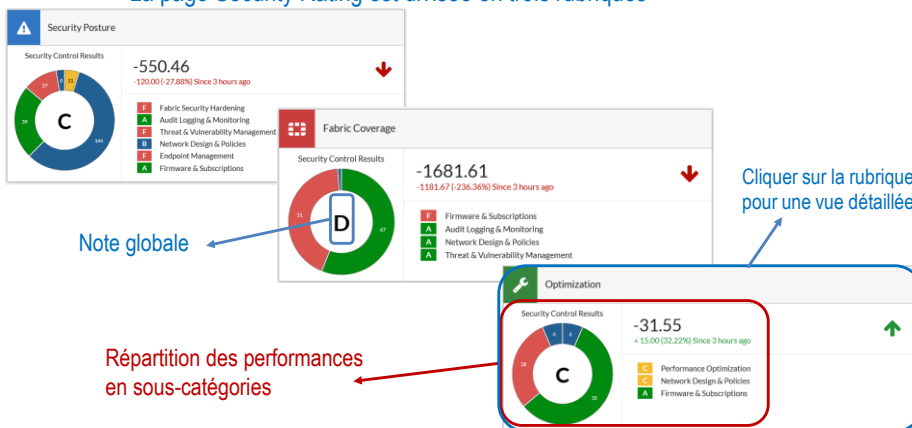
- FortiGuard Security Rating Service
 - Service réalisant des tests de sécurité du Security Fabric
 - Nécessite une licence "Fortiguard security rating".
 - Fonctionne en arrière plan et à la demande.
 - Effectue différents contrôles de sécurité (password check, ...)
 - Évaluation du déploiement du Fortinet Security Fabric en %.
 - Facilite l'identification des vulnérabilités potentielles
 - Aide à prioriser vos tâches.



37

Security Fabric Rating

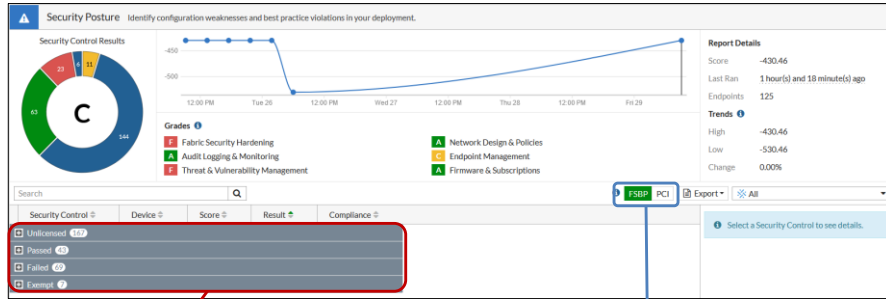
- FortiGuard Security Rating Service (suite)
 - La page Security Rating est divisée en trois rubriques



38

Security Fabric Rating

- FortiGuard Security Rating Service (suite)
 - Vue détaillée des résultats et des recommandations de conformité

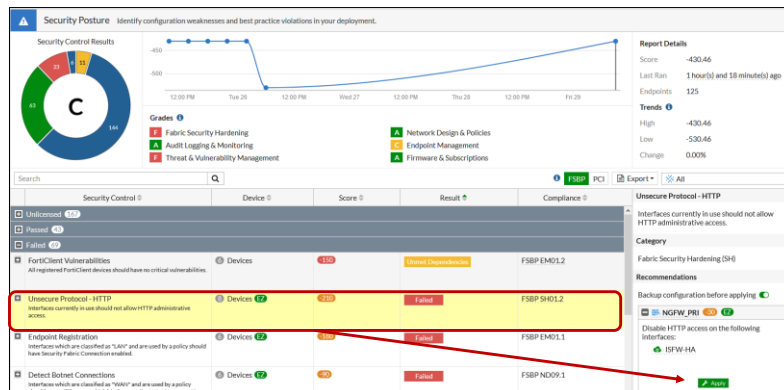


Détail et recommandations

FSBP : Fortinet Security Best Practices
PCI : PCI-DSS : Payment Card Industry Data Security Standard

Security Fabric Rating

- FortiGuard Security Rating Service (suite)
 - Vue détaillée des résultats et des recommandations de conformité



Certains problèmes de sécurité étiquetés
"Apply" peuvent être résolus immédiatement

Security Fabric Rating

- FortiGuard Security Rating Service (suite)

- Notifications

- Des recommandations sont affichées directement sur la page des paramètres concernés.

System > Settings

Security Fabric

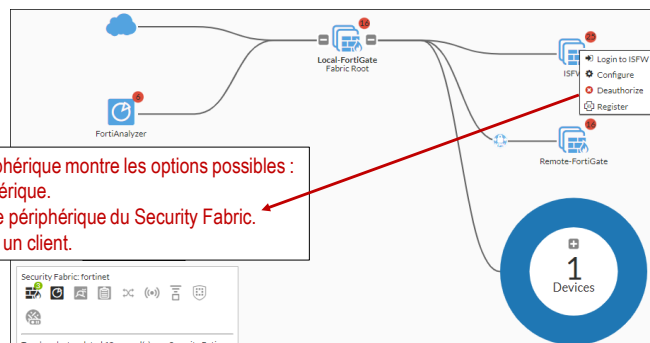
- Vue topologique

- Il est possible de voir la topologie du Security Fabric

- Topologie physique ou logique.
- La topologie complète est vue depuis le FortiGate racine.

Un clic droit sur un périphérique montre les options possibles :

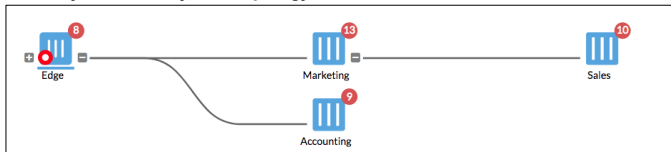
- Configurer le périphérique.
- Ajouter ou enlever le périphérique du Security Fabric.
- Bannir ou réintégrer un client.



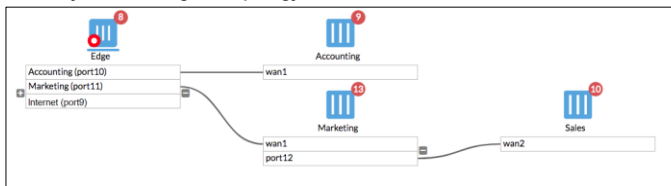
Security Fabric

- Vue topologique

Security Fabric > Physical Topology



Security Fabric > Logical Topology



Journalisation

- Journalisation dans un environnement Security Fabric

- FortiGate racine

- Les administrateurs peuvent consulter les journaux et les périphériques connectés au réseau en se connectant au FortiGate racine.
 - Ces informations sont partagées de manière sécurisée à l'aide du protocole FortiTelemetry

- Conseil

- Veillez à ne pas analyser et enregistrer le même flux de trafic plus d'une fois lorsqu'il passe par plusieurs firewalls.

Chapitre 2

Authentification

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Décrire l'authentification au niveau des règles de pare-feu.
 - Identifier les différentes méthodes d'authentification de pare-feu disponibles sur un périphérique FortiGate.
 - Configurer des règles de FW pour authentifier les utilisateurs.
 - Par mot de passe local.
 - Par mot de passe sur serveur distant.
 - Par authentification à deux facteurs.
 - Configurer un portail captif.

Firewall authentication

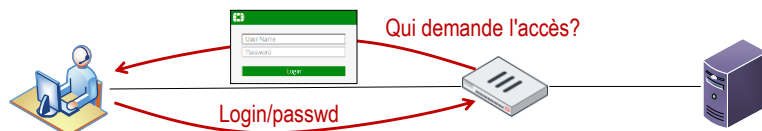
- **Authentification par le pare-feu**

- **Contrôle de l'IP source et du périphérique**

- Pour décider si un accès est autorisé, un pare-feu peut se baser sur l'IP source et le périphérique (Device Identification).
- Ce contrôle peut être insuffisant car le pare-feu ne peut pas déterminer quel utilisateur se trouve derrière l'appareil auquel il donne accès.

- **Authentification des utilisateurs**

- Pour certains accès, il est nécessaire de pouvoir authentifier les utilisateurs.
- Seulement après avoir authentifié l'utilisateur, l'UTM appliquera les règles de pare-feu et les profils de sécurité.



Méthode d'authentification

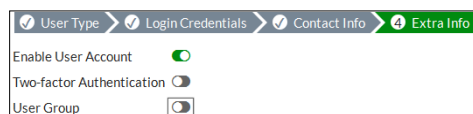
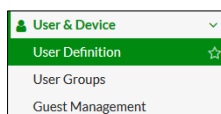
- **Local password authentication**

- **Authentification par mot de passe local**

- Le nom d'utilisateur et le mot de passe sont stockés localement sur le FortiGate.
- A utiliser s'il n'y a qu'un ou deux FortiGates.
- L'authentification à deux facteurs est possible.

- **Création d'un utilisateur local**

- **User & Device > User Definition** (voir cours précédent).
- Une fois créé, l'utilisateur peut être utilisé dans une règle de pare-feu.



Méthode d'authentification

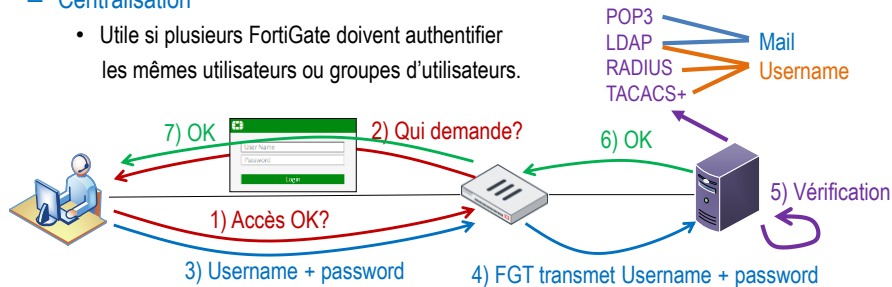
- **Server-based Password Authentication**

- Principe

- Le FortiGate stocke peu voire pas du tout d'informations utilisateur en local.
 - Les identifiants sont transmis à un serveur pour vérification.

- Centralisation

- Utile si plusieurs FortiGate doivent authentifier les mêmes utilisateurs ou groupes d'utilisateurs.



Méthode d'authentification

- **Server-based Password Authentication : method 1**

- Créer un compte utilisateur de type « Remote » et spécifier le serveur qui contiendra/vérifiera les identifiants

User & Device > RADIUS Servers

New RADIUS Server

Name: FortiAuth-RADIUS

Primary Server IP/Name: []

Primary Server Secret: [] Test Connectivity

Secondary Server IP/Name: []

Secondary Server Secret: [] Test Connectivity

Authentication Method: Default Specify

NAS IP: []

Include in every User Group: ☐

Définir le ou les serveurs d'authentification

User & Device > User Definition

1 User Type 2 RADIUS Server 3 Contact Info 4 Extra Info

Local User

Remote RADIUS User

Remote TACACS+ User

Remote LDAP User

Créer le compte utilisateur
L'authentification
POP3 est uniquement
disponible via la CLI

User & Device > User Definition

User Name: []

RADIUS Server: FortiAuth-RADIUS

Choix du serveur à contacter pour l'authentification
Doit avoir été préconfiguré sur le FortiGate

Méthode d'authentification

- **Server-based Password Authentication : method 2**

- Ajouter un serveur d'authentification à un groupe d'utilisateurs

- Tous les utilisateurs qui ont un compte sur le serveur pourront s'authentifier.

User & Device > User Group

Choix du serveur à contacter
 Doit avoir été préconfiguré sur le FortiGate (diapo. précédente)

- Ajouter le groupe d'utilisateur à une règle de pare-feu

Méthode d'authentification

- **Two-Factor Authentication and One-Time Passwords (OTP)**

- Mots de passe à usage unique

- **Plus sûrs que les mots de passe statiques**
 - Ils ne sont valides que pour une courte période de temps.
 - Une fois utilisé l'OTP ne peut plus être utilisé, donc même s'il est intercepté, il est inutile.
 - **Un OTP peut être utilisé comme deuxième facteur d'authentification**

- Time-based OTP

- **FortiGate peut délivrer des OTP via des jetons (token)**
 - FortiToken (jeton matériel), FortiToken Mobile (jeton logiciel via smartphone) .
 - Par défaut, un FortiToken génèrent un nouveau mot de passe toutes les 60 secondes.
 - FortiToken mobile push : juste accepter le jeton suffit sans devoir entrer le code envoyé (uniquement sur le même téléphone portable que celui enregistré).
 - **FortiGate peut aussi délivrer des OTP via SMS ou par e-mail**
 - En cas d'envoi par courriel ou SMS, le compte utilisateur doit contenir les informations de contact de l'utilisateur.
 - **Serveur NTP recommandé !**



Méthode d'authentification

- Assigner un FortiToken à un utilisateur
 - Configurer le token (User & Authentication > FortiTokens)

+ Create New
Edit
Delete
Activate
Provision
Refresh
Search

Type	Serial Number	Status	User	Drift
☐ Mobile Token	FTKMOB49AF7C8B6D	Available		
☐ Mobile Token	FTKMOB4975658F0A	Available		

Un code d'activation est requis pour les jetons logiciels (à acheter).

Activation Code

Il est possible d'importer les n° de série des FortiToken depuis un fichier .txt

Import

Un FortiToken peut être enregistré sur un seul FortiGate. Pour l'utiliser sur plusieurs FortiGate, vous devez utiliser un serveur de validation centralisé (FortiAuthenticator).




● ● ● ● ●
53



Méthode d'authentification

- Assigner un FortiToken à un utilisateur (suite)
 - Activer l'authentification à deux facteurs
 - Sélectionner le FortiToken qui sera associé à l'utilisateur.


User & Device

User Definition

Edit User
Return

User Name

User Account Status

User Type

Password

Email Address

SMS

guest

Enabled Disabled

Local User

.....

☐

Two-factor Authentication

☒

Token

Search

FTKMOB5C94FE73B4
 FTKMOB5CC0DB3E44




● ● ● ● ●
54

- Authentification active et authentification passive
 - Authentification active
 - Invite de connexion
 - Les utilisateurs doivent saisir manuellement leurs identifiants de connexion avant d'obtenir un accès.
 - L'authentification active peut être utilisée avec :
 - L'authentification par mot de passe local.
 - L'authentification basée sur un serveur d'authentification (POP3, LDAP, RADIUS, TACACS+).
 - L'authentification à deux facteurs.

- Authentification active et authentification passive (suite)
 - Authentification passive
 - Le processus d'authentification est transparent pour l'utilisateur
 - L'utilisateur ne devra pas entrer ses identifiants de connexion, ils sont déterminés automatiquement par le pare-feu.
 - Le FortiGate peut obtenir les identifiants selon plusieurs méthodes
 - FSSO, RSO et NTLM → Voir chapitre FSSO.
 - Authentification active et passive à la fois
 - Si les deux sont utilisées, l'authentification active est utilisée comme backup en cas d'échec de l'authentification passive.

Remote Authentication Servers

Configuration de l'authentification avec serveur LDAP

Le Common name est cn pour la plupart des serveurs LDAP.

Le DN doit pointer vers le bon niveau dans Active Directory.

Compte utilisateur que FortiGate utilise pour interroger le serveur LDAP

Sécurisation de la connexion avec SSL il faut préciser le certificat de la CA qui vérifiera le certificat du serveur.

User & Authentication > LDAP Servers

Name	ADserver	
Server IP/Name	10.0.1.10	
Server Port	636	
Common Name Identifier	cn	
Distinguished Name	ningAD,dc=training,dc=lab	Fetch DN
Bind Type	Simple Anonymous Regular	
User DN	cn=ADadmin,cn=users,dc=	
Password	*****	
Secure Connection	☒	
Protocol	LDAPS STARTTLS	
Certificate	No Certificate	
Test		

Teste la connexion au serveur LDAP.
Ne teste pas l'auth. des utilisateurs.

Remote Authentication Servers

Configuration de l'authentification avec serveur LDAP (suite)

Simple : à utiliser si tous les enregistrements de l'utilisateur sont sous le même nom de domaine.

Anonymous : à utiliser lorsque les recherches anonymes sont acceptées par le LDAP.

Regular : à utiliser si serveur LDAP nécessite une authentification pour effectuer des recherches.

Name	ADserver	
Server IP/Name	10.0.1.10	
Server Port	636	
Common Name Identifier	cn	
Distinguished Name	ningAD,dc=training,dc=lab	Fetch DN
Bind Type	Simple Anonymous Regular	
User DN	cn=ADadmin,cn=users,dc=	
Password	*****	
Secure Connection	☒	
Protocol	LDAPS STARTTLS	
Certificate	No Certificate	
Test		

Remote Authentication Servers

- Tester l'authentification d'un utilisateur

- La commande `test authserver`

- Permet de vérifier si les informations d'identification d'un utilisateur permettent de l'authentifier correctement.

- Syntaxe

```
# diagnose test authserver ldap <server_name> <username> <password>
```

- Exemple

```
# diagnose test authserver ldap ADserver aduser1 mypassword

authenticate 'aduser1' against 'ADserver' succeeded!
Group membership(s) - CN=AD-
users,OU=Training,DC=trainingAD,DC=training,DC=lab
```

Remote Authentication Servers

- Configuration de l'authentification avec serveur RADIUS

- Remote Authentication and Dial-in User Service

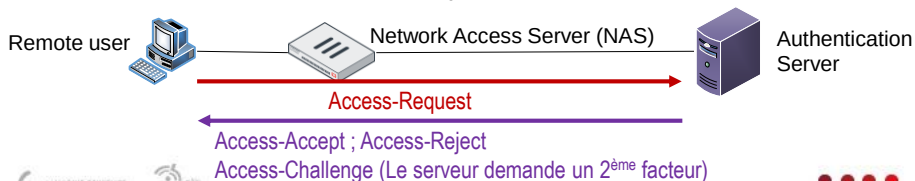
- Protocole client-serveur qui fournit des fonctions centralisées d'authentification, d'autorisation et de comptabilisation.

- RFC 2865 (RADIUS) et RFC 2866 (Accounting)

- Utilise le protocole UDP pour les échanges entre client et serveur.
 - Ports UDP : 1812 ou 1645 (authentification) et 1813 ou 1646 (traçabilité).

- Configuration du serveur

- Le serveur RADIUS doit être configuré pour accepter le FortiGate comme client.



Remote Authentication Servers

- Configuration de l'authentification avec serveur RADIUS
 - Configuration du FortiGate pour utiliser un serveur RADIUS

IP du FortiGate à utiliser dans le cas où plusieurs interfaces sont utilisées.

User & Device > RADIUS Servers

New RADIUS Server

Name: FortiAuth-RADIUS

Authentication method: **Default** Specify

NAS IP: []

Include in every user group: ☐

Primary Server

IP/Name: 10.0.1.150

Secret: []

Test Connectivity

Test User Credentials

Ajoute le serveur Radius, à chaque groupe d'utilisateurs créé sur le FortiGate. Utile si tous les utilisateurs s'authentifient avec ce serveur.

Protocole d'authentification pris en charge par le serveur RADIUS

PAP
MS-CHAP-v2
MS-CHAP
CHAP
PAP

61

Remote Authentication Servers

- Tester l'authentification d'un utilisateur
 - La commande `test authserver`
 - Permet de vérifier si les informations d'identification d'un utilisateur permettent de l'authentifier correctement.
 - Syntaxe

```
# diagnose test authserver radius <server_name> <scheme> <user> <password>
```

– Exemple

```
# diagnose test authserver radius FortiAuth-RADIUS pap student
fortinet

authenticate 'aduser1' against 'pap' succeeded, server=primary
assigned_rad_session_id=810153440 session_timeout=0 secs!
Group membership(s) - remote-AD-admins
```

User Groups

- Types de groupes d'utilisateurs

- Firewall user group

- Ils sont utilisés localement au niveau d'une règle de pare-feu afin d'autoriser des accès uniquement à certains groupes d'utilisateurs.
- Configuration : User & Device > User Groups > Create New

Ajouts d'utilisateurs dans le groupe

User Groups

- Types de groupes d'utilisateurs (suite)

- Guest user group

- Ces groupes sont généralement utilisés pour les accès invités dans les réseaux sans fil.

Plusieurs comptes d'invités peuvent être créés en une fois à l'aide d'identifiants et de mots de passe générés de façon aléatoire.

2. Guest user group (suite)

- Ce type de compte contient le compte entier, pas seulement le mot de passe.
- Les comptes invités expirent après une période de temps prédéterminée.

Guest Details

Require Name ☐

Require Email ☒

Require SMS ☐

Password ☒ Auto Generated Specify

Sponsor ☒ Optional Required

Company ☒ Optional Required

Expiration

Start Countdown ☒ On Account Creation After First Login

Time Days Hours Minutes Seconds

- Types de groupes d'utilisateurs

3. Fortinet Single Sign-On (FSSO) user group

- Utilisé pour l'authentification unique et passive (voir chapitre FSSO).

4. RADIUS Single Sign-On (RSSO) user group

- Utilisé pour l'authentification unique et passive (voir chapitre FSSO).

User Groups

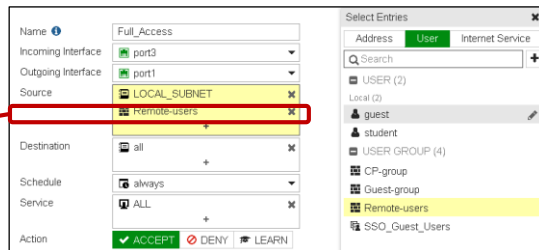
• Règle de pare-feu et authentification

– Principe

• Authentifier avant d'accepter le trafic utilisateur

- Ajouter des utilisateurs ou groupes d'utilisateurs dans le champ source d'une règle de pare-feu permet d'authentifier l'utilisateur avant d'accepter le trafic.
- Normalement, aucun service n'est autorisé par la règle de pare-feu avant l'authentification réussie des utilisateurs.

- Comptes locaux
- Comptes externes (remote server)
- Utilisateurs PKI (certificate)
- Utilisateurs SSO



User Groups

• Règle de pare-feu et authentification (suite)

– Exceptions

• La règle de pare-feu doit parfois autoriser certains protocoles avant l'authentification active (HTTP/HTTPS/FTP/Telnet)

- Le protocole permettant d'afficher la boîte de dialogue d'authentification utilisée dans l'authentification active.
 - » Ce n'est pas le cas avec l'authentification passive.
- Le protocole DNS peut être autorisé même si l'utilisateur ne s'est pas encore authentifié.
 - » En effet, la résolution du nom d'hôte est souvent requise par le protocole de couche application qui est utilisé pour l'authentification.

• Pour cela, la règle de pare-feu doit spécifier les protocoles autorisés.

ID	Name	Source	Destination	Schedule	Service	Action	NAT
1	Full_Access	LOCAL_SUBNET	all	always	DNS HTTP	ACCEPT	Enabled

- Règle de pare-feu et authentification (suite)
 - Combinaison de règles avec et sans authentification



- Activer l'authentification dans une règle de pare-feu ne garanti pas que l'utilisateur devra s'authentifier

ID	Name	Source	Destination	Schedule	Service	Action	NAT
port3 → port1							
1	Full_Access	LOCAL_SUBNET	all	always	ALL	ACCEPT	Enabled
2		LOCAL_SUBNET	all	always	ALL	ACCEPT	Enabled

- Dans l'exemple ci-dessus, le trafic d'un utilisateur de HR-group ne « matche » pas avec la règle 1 car l'utilisateur n'est pas encore authentifié.
- Par contre son trafic « matche » avec la règle 2 car son IP est bien comprise dans l'objet LOCAL_SUBNET.

- Règle de pare-feu et authentification (suite)
 - 3 possibilités pour garantir l'authentification des utilisateurs
 1. Activer l'authentification dans chaque règle de pare-feu qui pourrait correspondre au trafic.
 2. Appliquer l'option d'authentification à la demande (CLI uniquement).

```
# config user setting
(setting) # set auth-on-demand <always|implicit>
```

- **Implicit** : option par défaut, elle ne déclenchera pas l'authentification de l'utilisateur s'il existe une autre règle sans authentification qui autorise le trafic.
- **Always** : garanti que l'utilisateur devra s'authentifier pour les règles dont l'authentification active est activée.
- 3. Activer un portail captif sur l'interface d'entrée du trafic.
 - Dans ce cas, tous les utilisateurs qui envoient du trafic par cette interface devront s'authentifier.

Authentification via un portail captif

• Portail captif

– Permet une authentification des utilisateurs via une page Web

- Le portail captif est utilisé pour que tous les utilisateurs qui se connectent au réseau doivent s'authentifier via une authentification active.
- Le portail captif peut être hébergé sur le FortiGate ou un serveur d'authentification externe.

– Le portail captif est activé au niveau d'une interface

- WiFi (SSID) → OK
- Interfaces VLAN → OK
- Interfaces en mode DHCP → pas OK

Network > Interfaces

Admission Control	
Security Mode	Captive Portal
Authentication Portal	Local External
User Access	Restricted to Groups Allow all
Customize Portal Messages	
Exempt Sources	+
Exempt Destinations/Services	+

Authentification via un portail captif

• Configuration d'un portail captif

- Il est possible d'exempter certains utilisateurs ou certains périphériques de l'authentification car certains appareils ne sont pas capables de s'authentifier (imprimante).

Tous les groupes listés dans les règles de pare-feu pourront s'authentifier et accéder aux ressources

Seuls les groupes listés dans « User Groups » pourront s'authentifier et accéder aux ressources

Liste des appareils qui ne devront pas fournir d'authentification

Network > Interfaces

Admission Control	
Security Mode	Captive Portal
Authentication Portal	Local External
User Access	Restricted to Groups Allow all
User Groups	+
Customize Portal Messages	
Exempt Sources	+
Exempt Destinations/Services	+

Authentification via un portail captif

- Configuration d'un portail captif (suite)
 - Il est possible de configurer l'exemption en CLI

1. Par le biais d'une liste d'exemption de sécurité

```
#config user security-exempt-list
edit <list_name>
config rule
edit <name>
set srcaddr|dstaddr|service
next
end
```

2. Par le biais de la politique de pare-feu

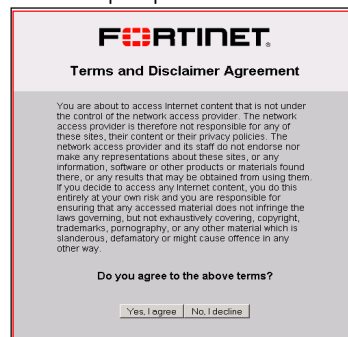
Tout le trafic correspondant à la règle
 <policy ID> est exempté de l'obligation de
 s'authentifier par le biais d'un portail captif.

```
#config firewall policy
edit <policy_id>
set captive-portal-exempt enable
end
```

Authentification via un portail captif

- Configuration d'un portail captif (suite)
 - Disclaimer
 - Il est possible d'afficher une page reprenant les conditions d'utilisation.
 - Tous les utilisateurs devront accepter ces conditions pour poursuivre.
 - Pas d'exemption possible.

```
#config firewall policy
edit <policy_id>
set disclaimer enable
end
```



FORTINET

Terms and Disclaimer Agreement

You are about to access Internet content that is not under the control of the network access provider. The network access provider is therefore not responsible for any of these sites, their content or their privacy policies. The network access provider and its staff do not endorse nor make any representations about these sites, or any information, software or other products or materials found there, or any results that may be obtained from using them. If you decide to access any Internet content, you do this entirely at your own risk and you are responsible for ensuring that any accessed material does not infringe the laws governing, but not exhaustively covering, copyright, trademarks, pornography, or any other material which is slanderous, defamatory or might cause offence in any other way.

Do you agree to the above terms?

- Configuration d'un portail captif (suite)
 - Personnaliser les messages

Seule l'option « Extended View » affiche
l'ensemble des messages configurable

System > Replacement Messages

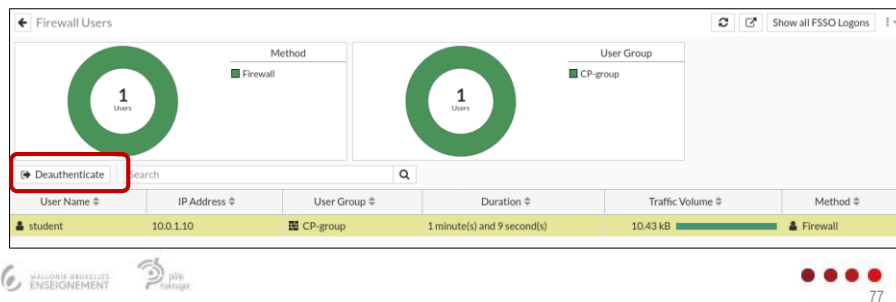
Manage Images	Search	Q	Simple View	Extended View
Name	Description			
Administrator (2)				
Post-login Disclaimer Message	Replacement message for post-login disclaimer			
Pre-login Disclaimer Message	Replacement message for pre-login disclaimer			
Alert Email (5)				
alertmail-block				
alertmail-crit-event				
alertmail-disk-full				
alertmail-nids-event				
alertmail-virus				
Authentication (24)				

- Authentication Timeout
 - Minuteur d'expiration de l'authentification
 - Il spécifie combien de temps un utilisateur peut rester inactif avant de devoir s'authentifier à nouveau (5 min. par défaut).
 - Réduit les risques qu'une personne réutilise l'IP d'un utilisateur authentifié.
 - Limite l'utilisation des ressources.
 - Le FortiGate ne doit pas garder indéfiniment en mémoire les informations de connexions.
 - Options
 - Idle
 - Si le FortiGate ne reçoit pas de paquets du périphérique hôte dans le délai configuré, l'utilisateur est déconnecté.
 - Hard
 - L'authentification expire à la fin du minuteur, quel que soit le comportement de l'utilisateur.
 - New session
 - L'authentification expire si aucune nouvelle session n'est créée pendant la durée du minuteur, même si du trafic est généré.

```
#config user setting
set auth-timeout-type [idle-timeout|hard-timeout|new-session]
```

Monitorer les utilisateurs authentifiés

- Surveiller les utilisateurs authentifiés
 - [Monitor > Firewall User Monitor](#)
 - Affiche l'utilisateur, le groupe d'utilisateurs, la durée, l'adresse IP, le volume de trafic et la méthode d'authentification.
 - Permet de désauthentifier un (ou plusieurs) utilisateurs.



Dépannage

- Commandes de dépannage
 - Afficher les utilisateurs authentifiés, les groupes associés et leur adresse IP.

```
diagnose firewall auth list
```

- Effacer tous les utilisateurs autorisés de la liste actuelle.

```
diagnose firewall auth clear
```

- Tester la clé pré-partagée entre FortiGate et le serveur RADIUS.

```
diagnose test authserver radius-direct <ip> <port> <secret>
```

- Débogage de l'authentification active.

```
diagnose debug enable
diagnose debug app fnbamd -1
```

- Surveiller les utilisateurs authentifiés
 - Règle de pare-feu
 - La colonne « bytes » permet de vérifier si une règle voit passer du trafic.

ID	Name	Source	Destination	Schedule	Service	Action	NAT	Security Profiles	Log	Bytes
1	Full_Access	LOCAL_SUBNET	all	always	ALL	ACCEPT	Enabled	log_deep-inspection	UTM	3.47 MB

Chapitre 3

Journalisation

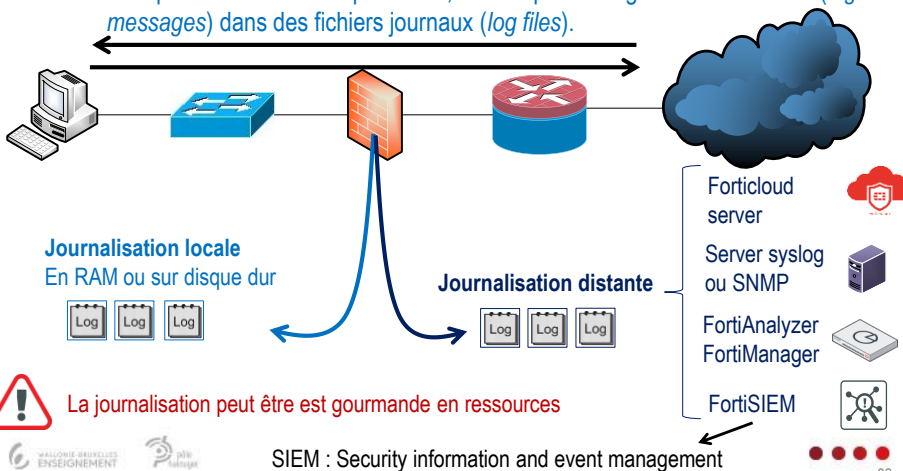
Logging and Monitoring

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Décrire les types et sous-types de journaux (logs).
 - Décrire les niveaux de sévérité des journaux.
 - Identifier les emplacements de stockage des journaux.
 - Configurer les paramètres de journalisation.
 - Afficher, filtrer, télécharger et exporter les journaux.

Journalisation

- **Journalisation**
 - Lorsque du trafic transite par l'UTM, celui-ci peut enregistrer cette activité (*log messages*) dans des fichiers journaux (*log files*).



- **Avantages de la journalisation**
 - **Apporte de la visibilité sur les activités du réseau**
 - Fournir des données pour localiser certains problèmes (pertes de performance, erreurs lors de l'utilisation d'un tunnel VPN IPsec, ...).
 - Lister les menaces les plus rencontrées.
 - **Facilite l'établissement d'une ligne de base du réseau.**
 - Car elle permet de disposer de statistiques sur le trafic.
 - **Important du point de vue de la sécurité**
 - **Enregistrement de différents événements critiques (traçabilité)**
 - Tels que des accès au système, des modifications de fichiers ou encore le blocage de trafic malicieux.
 - **Parfois la journalisation est obligatoire de par la loi**
 - Par exemple, un fournisseur d'accès à Internet doit conserver un historique des connexions de ses clients pendant un certains laps de temps.

- **Inconvénients de la journalisation**
 - **La journalisation consomme des ressources**
 - Plus il y a d'événements à journaliser, plus il y a consommation de ressources CPU, mémoire, espace disque.
 - Une journalisation trop intensive peut réduire les performances
 - Variable selon les capacités du FortiGate.
- **Conseils**
 - **Créer un plan de gestion des logs**
 - Quelles activités voulez-vous/devez-vous consigner?
 - Quel dispositif de journalisation est le mieux adapté à votre situation?
 - Les journaux doivent-ils être archivés? Combien de temps?
 - Etc.
 - **Réviser régulièrement votre plan**

```
config system global
  set sys-perf-log-interval <number from 0-15>
end
```


Trois types de journaux

1. Traffic Logs (Les journaux de trafic)

- Ils enregistrent des informations sur le trafic qui traverse le FortiGate
 - Appelé aussi "firewall policy logging" car le trafic traversant l'UTM est nécessairement autorisé via une règle de pare-feu.
- Ils contiennent trois sous-types : forward, local et sniffer.
 - **Journaux de trafic Forward**
 - Ils contiennent des informations sur le trafic qui a été autorisé ou bloqué par le FW.
 - **Les journaux de trafic Local**
 - Ils contiennent des informations sur le trafic de et vers l'IP de gestion de l'UTM.
 - Par exemple, les connexions en GUI et les requêtes vers les services FortiGuard.
 - **Les journaux de trafic Sniffer**
 - Ils enregistrent tout le trafic passant par l'interface configurée en One-Arm Sniffer
 - Ce trafic peut ainsi être examiné séparément des autres journaux.

Trois types de journaux

2. Event Logs (Les journaux d'événements)

- Ils enregistrent les événements système et d'administration
 - Par exemple, des ajouts ou modifications de la configuration, la connexion d'un administrateur, ou l'activation d'un tunnel VPN IPsec.
- Ils contiennent les sous-types suivants
 - **Les journaux d'événements System**
 - Ils contiennent des informations relatives aux opérations système telles que les mises à jour FortiGuard ou la connexion d'un administrateur.
 - **Les journaux d'événements User**
 - Ils contiennent des informations relatives aux connexions et déconnexions des utilisateurs lorsque des règles de pare-feu utilisent l'authentification utilisateur.
 - **Les autres journaux d'événements (Router, VPN, Endpoint Control, ...)**
 - Endpoint Control, High Availability, Router, WAD, VPN, Wireless, ...
 - Ils contiennent des fichiers journaux relatifs à ces fonctionnalités.

Trois types de journaux

3. Security logs (Les journaux de sécurité)

- Ils enregistrent des journaux concernant les événements de sécurité
 - Contiennent les logs relatifs aux actions prises par les profils de sécurité
 - Application Control
 - Antivirus
 - DLP
 - Anti-Spam (Email Filter)
 - Web Filter
 - Intrusion Protection
 - Anomaly (DoS-policy)
 - WAF
 - Le type de log = utm

Trois types de journaux

• Types et sous-types de journaux

Traffic	Event	Security
Forward	Endpoint Control	Application Control
Local	High Availability	Antivirus
Sniffer	System	Data Leak Prevention (DLP)
	User	Anti-Spam
	Router	Web Filter
	VPN	Intrusion Prevention System (IPS)
	Wan Optimization Daemon (WAD)	Anomaly (DoS-policy)
	Wireless	WAF

Trois types de journaux

- Niveau de sévérité des journaux
 - Les journaux sont classés par niveau de sévérité.
 - Le niveau de sévérité est utilisé par les administrateurs pour définir quelles informations doivent être enregistrées (log level, priority level).

Sévérité	Niv.	Descriptif
Emergency (Urgence)	0	Système instable
Alert (Alerte)	1	Action immédiate requise
Critical (Critique)	2	Condition critique, fonctionnalité affectée
Error (Erreur)	3	Erreur existante pouvant affecter une fonctionnalité (service qui ne charge pas)
Warning (Avertissement)	4	Avertissement, une fonctionnalité pourrait être affectée (espace disque faible)
Notification (Notification)	5	Événement normal mais pouvant être important
Informational (Informatif)	6	Information générale sur le système
Debugging (Débogage)	7	Message de débogage

Exemples de journaux

- Forward log example
 - Il est possible de trier les journaux

Log & Report

Forward Traffic

Local Traffic

#	Date/Time	Source	Destination	Application Name	Security Events	Result	Log Details
1	00:06:59	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	General Date 02/12/2018 Time 23:51:29 Duration 0s Session ID 69656 Virtual Domain root Source IP 10.0.0.2 Source Port 138 Country Reserved Source Interface port1 Security Level Threat Level high Threat Score 30 Notice
2	00:06:29	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
3	02-12-23:54	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
4	02-12-23:51	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
5	02-12-23:42	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
6	02-12-23:36	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
7	02-12-23:30	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
8	02-12-23:21	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
9	02-12-23:18	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
10	02-12-23:06	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
11	02-12-23:06	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	

Exemples de journaux

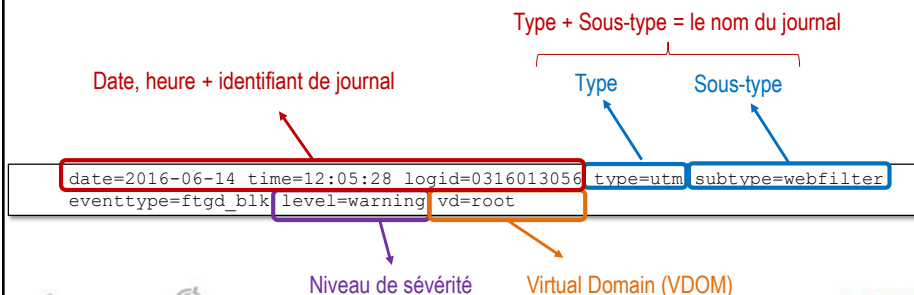
- Security log example
 - Par défaut, ils sont visibles dans le menu Forward Traffic

Date/Time	Source	Destination	Security Events	Log Details
06-28 07:17	100.1.1.10	52.32.150.180 (ec2-52-32-150-180.us-west-2.compute.amazonaws.com)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)	1	
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:17	100.1.1.10	188.40.238.250 (https.itcon.info)		
06-28 07:16	52.85.63.60 (server-52-85-63-60.lhr50.r.cloudfront.net)			
06-28 07:16	100.1.1.10	72.21.91.29 (ocsp.digicert.com)		

Log Details	Details
Antivirus	Agent: Firefox/47.0
FortiSandbox Checksum	275a021bb6b6489e54d
Submitted to FortiSandbox	false
Details	host: 188.40.238.250
Threat Level	critical
Direction	incoming
Detection Type	Virus
Event Type	Infected
File Name	eicar.com.txt
Message	File is infected.
Profile Name	anotherAV
Quarantine Skip	File was not quarantined.
Reference	http://www.fortinet.com
URL	http://www.eicar.org/idx
Virus/Botnet	EICAR_TEST_FILE
Virus ID	2172

Exemples de journaux

- En-tête d'un log
 - Chaque journal a une disposition standard composée d'une section *en-tête* et d'une section *corps*.
 - L'en-tête est similaire pour tous les types de log.
 - La combinaison "type + sous-type" détermine le contenu du corps d'un log.



Exemples de journaux

- Corps d'un log

- Il varie en fonction du type de log.
- Il indique la raison pour laquelle le journal a été créé.

N° de la règle de pare-feu
 IP source et destination
 Nom ou adresse IP
 Service concerné
 Raison de l'action

```

policyid=1 sessionid=10879 user="" srcip=10.0.1.10 srcport=60952
srcintf="port3" dstip=52.84.14.233 dstport=80 dstintf="port1" proto=6
service="HTTP" hostname="miniclip.com" profile="default" action=blocked
reqtype=direct url="/favicon.ico" sentbyte=297 rcvdbyte=0
direction=outgoing msg="URL belongs to a denied category in policy"
method=domain cat=20 catdesc="Games" crscore=30 crlevel=high
  
```

Exemples de journaux

- Affichage des logs en CLI

```

FGT60D # execute log display
93 logs found.
10 logs returned.
  
```

```

1: date=2020-01-16 time=13:34:12 logid="0000000011" type="traffic" subtype="forward" level="warning" vd="root"
eventtime=1579178052 srcip=192.168.0.1 srcname="COOLERMMASTER" srcport=49468 srcintf="internal7"
srcintfrole="undefined" dstip=1010.10.1 dstport=53 dstintf="internal" dstintfrole="lan" poluid="f64d1c98-33d8-
51ea-b2c1-e4a490c8e06a" sessionid=365767 proto=17 action="dns" policyid=2 policytype="policy" service="DNS"
appcat="unscanned" crscore=5 craction=262144 crlevel="low" devtype="Windows PC" osname="Windows 8.1 /
2012" mastersrcmac="c8:60:00:c5:9b:48" srcmac="c8:60:00:c5:9b:48" srcserver=1 dstdevtype="Unknown"
masterdstmac="28:c6:8e:39:63:6b" dstmac="28:c6:8e:39:63:6b" dstserver=1
  
```

- Affichage des logs en CLI (suite)

```
FGT60D4Q16067135 # execute log filter ?
category          Category.
device            Device to get log from.
dump              Dump current filter settings.
field             Filter by field.
ha-member         HA member.
max-checklines    Maximum number of lines to check.
reset             Reset filter.
start-line        Start line to display.
view-lines        Lines per view
```

- “Performance statistic logging”
 - Fonction qui crée une entrée de journal périodique contenant des informations générales sur les performances du FortiGate.
 - Fournit des informations sur l'utilisation du CPU et de la mémoire, ainsi que le nombre de sessions simultanées.
 - Peut être utile lors du dépannage des changements de comportement en termes d'utilisation des ressources.

```
# config system global
  set sys-perf-log-interval <number from 0-15>
end
```

→ 0 = Désactivé

```
itime=2020-09-01 11:13:06 vd=root bandwidth=13/16 totalsession=53 disk=1
dstepid=3 devid=FGVM04TM20001209 disklograte=0 logdesc=System performance
statistics msg=Performance statistics: average CPU: 0, memory: 48,
concurrent sessions: 53, setup-rate: 0 idseq=267453240667275345 type=event
eventtime=1598951586 mem=48 dtime=2020-09-01 11:13:06 devname=FGT-VM-HEL
setuprate=0 dsteuid=0 itime_t=1598951586 euid=3 fazlograte=20 date=2020-
09-01 level=notice epid=3 logid=0100040704 subtype=system time=11:13:06
action=perf-stats cpu=0
```

Configuration de la journalisation

Local Logging

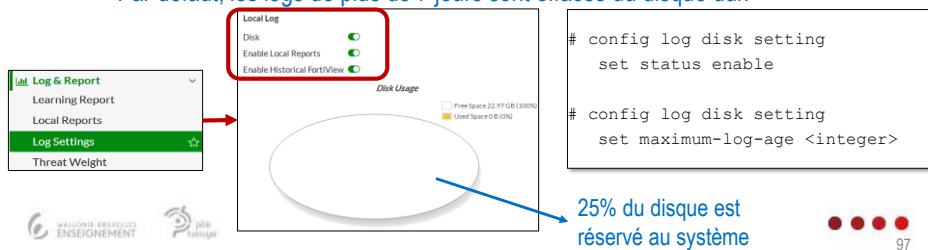
Enregistrement sur disque

- Vous pouvez activer l'enregistrement local sur le disque (disk logging).
- Si le disque dur local est utilisé pour le « WAN Optimization », vous ne pouvez pas utiliser le disque pour les logs.

Sans disque dur

- Les informations dans FortiView s'affichent en temps réel uniquement.

Par défaut, les logs de plus de 7 jours sont effacés du disque dur.



```
# config log disk setting
set status enable

# config log disk setting
set maximum-log-age <integer>
```

25% du disque est réservé au système

Configuration de la journalisation

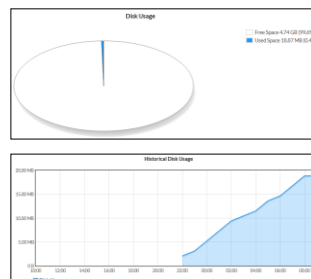
Local Logging (suite)

Surveiller l'espace disque

- Une partie du disque est réservée (~25%).

```
# diagnose sys logdisk usage
Total HD usage: 208MB/118145MB
Total HD logging space: 88608MB
HD logging space usage for vdom "root": 5MB/9863MB
HD logging space usage for vdom "vdom1": 0MB/103747MB
```

Log & Report > Log Settings



Formule

- Disque – log = réservé ($118145\text{MB} - 88608\text{MB} = 29537\text{MB}$)
- Réserve/disque*100 = réservé % ($29537/118145*100 = 25\%$)

Configuration de la journalisation

• Local Logging (suite)

– Avertissement

- Des messages d'avertissement sont affichés avant que le disque ne soit plein.
- Les seuils sont configurables :

```
# configure log disk setting
```

```
set diskfull [overwrite | nolog]
```

```
set full-first-warning-threshold <1-98>
```

```
set full-second-warning-threshold <2-99>
```

```
set full-final-warning-threshold <3-100>
```

75% par défaut

90% par défaut

95% par défaut

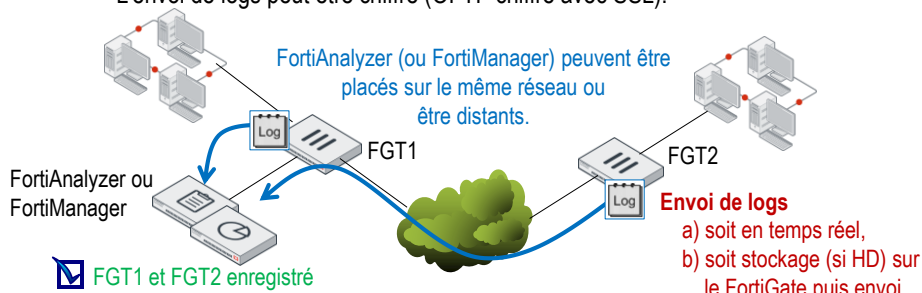
– Si le disque est rempli?

- FIFO : les logs les plus anciens sont remplacés par les nouveaux.
- Possible de configurer le FortiGate pour stopper la journalisation.

Remote logging

• Sauvegarde sur FortiAnalyzer ou FortiManager

- Les FortiGates doivent être enregistrés auprès du FortiAnalyzer/FortiManager pour pouvoir lui envoyer des logs.
- Utilise le port 514, les logs sont compressés (format LZ4) et transmis en clair.
- L'envoi de logs peut être chiffré (OFTP chiffré avec SSL).



- FortiAnalyzer vs FortiManager



- FortiAnalyzer (FAZ)

- Équipement dédié au stockage et à l'analyse des fichiers journaux.
 - Prévu pour stocker et traiter de grandes quantités de logs.



- FortiManager (FMG)

- Destiné à la gestion centralisée de plusieurs périphériques Fortinet.
 - Peut aussi stocker des logs et générer des rapports.
 - Les volumes de logs sont limités à un montant fixe (par jour) qui est inférieur à celui d'un FortiAnalyzer.

- Jusqu'à 3 FAZ/FMG par FortiGate (Redondance)

- FortiCloud

- Service hébergé dans le cloud (hosted service)



- Service de gestion des logs et de la sécurité.
 - Stockage à long terme des logs et génération de rapports.
 - Nécessite un abonnement.
 - Utile dans les petits réseaux afin d'éviter l'achat d'un appareil de journalisation dédié (dedicated logging appliance).

Remote logging

- Configuration
 - Définir de l'équipement vers qui envoyer les logs

Log & Report > Log Settings

Remote Logging and Archiving

Send logs to FortiAnalyzer/FortiManager ☒

IP address: 10.0.1.210

Logging to ADOM: root

Storage usage: 67.13 MiB / 1000.00 MiB

Analytics usage: 67.12 MiB / 700.00 MiB (Number of days stored: 34/60)

Archive usage: 4.00 KiB / 300.00 MiB (Number of days stored: 365/365)

Upload option: Real Time | Every Minute | **Every 5 Minutes**

SSL encrypt log transmission: ☒

Allow access to FortiGate REST API: ☒

Verify FortiAnalyzer certificate: ☒ FAZ-VM0000065040

- En temps réel
- Toutes les minutes
- Toutes les 5 minutes

- La configuration d'un 2^{ème} et/ou 3^{ème} équipement distant doit se faire en CLI.

```
# config log [fortianalyzer | fortianalyzer-cloud | fortianalyzer2 |
fortianalyzer3] setting
set status enable
set server x.x.x.x
set upload-option [store-and-upload | realtime/1-minute/5-minute]
```

Même mot clé pour un FortiManager

103

Remote logging

- Configuration (suite)
 - Envoi des logs vers FortiCloud
 - Nécessite d'activer le compte FortiCloud via le Dashboard en premier.

FortiCloud Account

Remote Logging and Archiving

Send Logs to FortiAnalyzer/FortiManager ☒

Upload Option: **Store & Upload Logs** | Realtime

Store & Upload Logs: Daily

Time: at 00:59

Activate

Une fois activée, l'option FortiCloud apparaît

Si l'on souhaite enregistrer les logs avant de les envoyer, il faut le planifier.

```
# config log fortiguard setting
set status enable
set source-ip <src IP used to connect FortiCloud>
set upload-option <realtime | 1-minute | 5-minute>
set enc-algorithm <high-medium | high | low>
```

Chiffrement à configurer en CLI

104

Remote logging

- Configuration (suite)

- Envoi des logs vers un serveur Syslog ou un FortiSIEM

Remote Logging and Archiving
 Send Logs to FortiAnalyzer/FortiManager ☐
 Send Logs to FortiCloud ☐
 Send Logs to Syslog ☒
 IP Address/FQDN:

- Il est possible de configurer jusqu'à quatre serveurs Syslog ou FortiSIEM distants.

```
# config log <syslogd | syslogd2 | syslogd3 | syslogd4> setting
  set status enable
  set server <syslog_IP>
  set format [default | csv | cef]
```

Remote logging

- Configuration (suite)

- VDOM

- Par défaut, la configuration est globale.
- Par défaut, le VDOM root est responsable de l'envoi des logs.

- override-setting

- S'il faut définir un FortiAnalyzer ou un serveur syslog différent pour un VDOM, la configuration se fait en CLI.
- Dans ce cas, le VDOM concerné enverra les logs (et pas le VDOM root)

```
# config vdom
  edit <VDOM_Name>
    config log setting
      set faz-override enable
      set syslog-override enable
    end
  # config log fortianalyzer/fortianalyzer2/fortianalyzer3 override-setting
```

Remote logging

- **Journalisation fiable**

- **Reliable logging**

- Utilise TCP au lieu de UDP (port 514).
 - Logs vers FortiCloud : utilise TCP
 - Logs vers FortiAnalyzer ou FortiManager
 - Si configuré en GUI, TCP est automatiquement utilisé.
 - Si configuré en CLI, UDP est utilisé par défaut.

```
# config log fortianalyzer setting
set reliable [enable/disable]

# config log syslogd setting
set mode udp | reliable | legacy-reliable
```

- **TCP doit être utilisé pour pouvoir chiffrer l'envoi des logs**

```
# config log fortianalyzer setting
set enc-algorithm [high-medium | high | low]
```

Remote logging

- **Configuration (suite)**

- **Si l'équipement distant est indisponible**

- FortiGate met les journaux en cache (processus miglogd).
 - Suffisant pour stocker les logs le temps d'un redémarrage de l'équipement distant.

- **Afficher des statistiques sur les processus**

```
Local-FortiGate # diagnose test application miglogd 6

mem=0, disk=0, alert=0, alarm=0, sys=0, faz=19, faz-cloud=0, webt=0, fds=0
interface-missed=0
Queues in all miglogds: cur:0 total-so-far:153
global log dev statistics:
faz 0: sent=15, failed=0, cached=0, dropped=0, relayed=0
```

```
Local-FortiGate # diagnose log kernel-stats

fgtlog: 1
fgtlog 0: total-log=32, failed-log=0 log-in-queue=0
```

Configuration de la journalisation

- Configuration (suite)

- Il est possible de choisir les logs qui seront envoyés à un serveur syslog ou un FortiAnalyzer

```
# config log [fortianalyzer | fortianalyzer2 | fortianalyzer3] filter ?

Severity <level>
Forward traffic [enable/disable]
Local traffic [enable/disable]
Multicast traffic [enable/disable]
Sniffer traffic [enable/disable]
Anomaly [enable/disable]
VOIP [enable/disable]
ZTNA-traffic [enable/disable]
GTP [enable/disable]
Filter [string]
Filter type [include | exclude]
```

Configuration de la journalisation

- Activation de la journalisation

- Se fait au niveau de la règle de pare-feu

- Active la journalisation du trafic traversant le pare-feu

Seq.#	Name	From	To	Source	Destination	Service	Action	NAT	Security Profiles	Log
2	Mobile	lan	wan1	all Mobile Devices	all	DNS HTTP HTTPS	Accept	Enabled	WEB SSL	PROX All

Policy & Objects > Firewall Policy

Security Profiles
 AntiVirus ☒ AV AV-Monitor
 Web Filter ☒ WEB monitor-all
 DNS Filter ☐
 Application Control ☒ APP MonitorALL
 IPS ☒ IPS all_default_pass
 File Filter ☐
 SSL Inspection ☐ SSL SSL1
 Logging Options
 Log Allowed Traffic ☒ Security Events All Sessions



Doit être activé, sinon aucun log ne sera généré

Configuration de la journalisation

• Configuration

- Il est possible de spécifier quel sous-type de trafic devra être journalisé concernant les types de journaux « Event » et « Local Traffic »

Log & Report > Log Settings

Log Settings

Event Logging: All **Customize**

☒ System activity event	☒ VPN activity event
☒ User activity event	☒ Router activity event
☒ WiFi activity event	☒ Explicit web proxy event
☒ Endpoint event	☒ HA event
☒ Compliance Check Event	☒ Security audit event

Local Traffic Log: All **Customize**

☒ Log Allowed Traffic	☒ Log Denied Unicast Traffic
☒ Log Local Out Traffic	☒ Log Denied Broadcast Traffic

Trafic « de » et « vers » le FortiGate

111

Configuration de la journalisation

• Configuration (suite)

Affiche les logs depuis la mémoire, le disque dur ou un FortiAnalyzer

GUI Preferences

Display Logs From: Disk

Resolve Hostnames: ☒

Resolve Unknown Applications: ☒

Peut charger le CPU et avoir un impact sur la l'affichage des logs, particulièrement si le DNS est lent à répondre.

Le FortiGate recherche dans la base de données "Internet services" pour résoudre les applications inconnues.

112

Configuration de la journalisation

- **Journalisation et accélération matérielle**
 - **L'accélération matérielle affecte la journalisation**
 - Le trafic déchargé sur des SPU n'est pas journalisé.
 - Si vous devez journaliser, il faut désactiver l'accélération matérielle.
 - **Exception**
 - Il est possible de journaliser les paquets utilisant les processeurs NP7 mais avec une dégradation des performances de l'accélération matérielle.
- **Tester la journalisation**

diagnose log test

```

Generation a system event message with level - warning
Generation an infected virus message with level - warning
Generation a block virus message with level - warning
Generation a URL block message with level - warning
...

```

Configuration de la journalisation

- **Anonymiser les logs**
 - **Parfois requis de par la loi**

```

config log setting
  set user-anonymize enable
end

```

execute log display

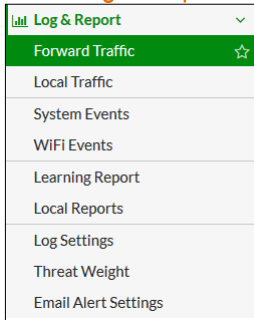
```

Date=2021-02-04 time=10:06:10 logid=0215013713 type=utm
subtype=webfilter eventtype=ftgd_allow level=notice vd="root"
policyid=2 identidx=1 sessionid=42342848 user="anonymous"
group="ldap_users" srcip=192.168.0.2 srcport=62423
srcintf="port3" dstip=193.190.65.24 dstport=80 dstintf="port1"
service="http" hostname="www.heh.be"
profiletype="Webfilter_Profile" profile="default"
status="passthrough" reqtype="direct" url="/" sentbyte=304
rcvbyte=60135 msg="URL belongs to an allowed category in
policy" method=domain class=0 cat=140 catdesc="custom1"

```

Affichage et gestion des journaux

• Log & Report



Les éléments du menu Log & Report dépendent de la configuration.

Les journaux de sécurité existent uniquement s'il y a des événements de sécurité qui ont été journalisés.

Si les logs sont enregistrés à plusieurs endroits, il est possible de sélectionner depuis quelle source les récupérer.

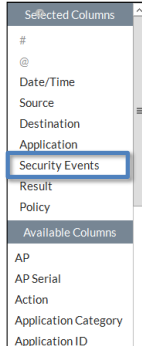
Date/Time	Source	Device	Destination	Application Name	Result	
2021/02/04 01:26:37	10.88.12.99	00:09:0f:09:78:02	192.168.254.254	tcp/5671	✓ 120 B / 0 B	ISFW-WAN (22)
2021/02/04 01:26:36	10.88.110.113	00:09:0f:09:78:02	96.45.36.228 (fortianalyzer.fortidemo.c...)	OFTP	✓ 208 B / 0 B	ISFW-WAN (22)
2021/02/04 01:26:36	10.88.110.11	00:09:0f:09:78:02	96.45.36.106 (fctems.fortidemo.com)	HTTPS.BROWSER	✓ 1.36 kB / 1.00 kB	ISFW-WAN (22)

Affichage et gestion des journaux

• Filtrage de l'affichage des logs

Par défaut, seules les colonnes les plus courantes sont affichées.

Ajout colonne :
Clic droit sur
la barre de titre



Pour filtrer les données en fonction d'une colonne, assurez-vous qu'elle soit affichée ...

Des filtres sont configurables pour chaque colonne de l'affichage.

#	Date/Time	Source	Destination	Action
1	00:19:19	10.0.0.2	10.0.0.255	AP Serial
2	00:17:04	10.0.0.2	10.0.0.255	Application Category
3	00:07:18	10.0.0.2	10.0.0.255	Application ID
4	00:02:04	10.0.0.2	10.0.0.255	Application Name

Exemple

HEH.be Sciences et technologies

Affichage et gestion des journaux

- Filtres rapides

Clc droit

Clc droit

Permet de mettre rapidement une adresse source en quarantaine.

117

HEH.be Sciences et technologies

Affichage et gestion des journaux

- Afficher les logs relatifs à une règle de pare-feu

118

Configuration de la journalisation

- Alertes

- Notifications par email

- Nécessite de définir le serveur SMTP à contacter.

System > Advanced

Email Service ⓘ

Use custom settings ☒

SMTP Server notification.fortinet.net

Port 465

Authentication Disable

Security Mode SMTPS

Default Reply To

Email Service ⓘ

Use Custom Email Server ☒

SMTP Server 10.1.1.1

Port 25

Default Reply To admin@labo.be

Authentication ☒

Security Mode ☒ None ☐ SMTPS ☐ STARTTLS

Déclenchement basé sur
le type d'évènement
ou le niveau de sévérité

Log & report > Email Alert Settings

Email Alert Settings

Enabled ☒

From

To

Alert parameter **Events** Severity

Interval ⓘ 5

Security

Intrusion detected ☐

Virus detected ☐

Web Filter blocked traffic ☐

Policy denied traffic ☐

Administrative

Disk usage exceeds ☐

FortiGuard renewal due within ☐

Administrator login/logout ☐

Configuration change ☐

Firewall authentication failure ☐

HA status change ☐

119

Configuration de la journalisation

- Configuration des notifications par email via la CLI

- Parfois requis de par la législation

```
# config alertemail setting
  set username "fortigate@training.lab"
  set mailto1 "admin@training.lab"
  set filter-mode category | threshold
  set email-interval 1
  set IPS-logs enable
  set HA-logs enable
  set antivirus-logs enable
  set webfilter-logs enable
  set log-disk-usage-warning enable
end
```

Jusqu'à trois destinataires

120

Configuration de la journalisation

• Threat Weight in FortiOS

– Permet de configurer ses propres niveaux de menace

- Permet de classer les logs en fonction de ses propres niveaux de menace.
- Permet de prioriser plus facilement les actions en fonction des niveaux de menaces rencontrées.

Permet de définir ses propres pondération des menaces.

Threat Weight Definition

Log Threat Weight ☒ Reset

Web Activity

Activity	Off	Low	Medium	High	Critical
Blocked URLs	Off	Low	Medium	High	Critical
Malicious Websites	Low	Medium	High	Critical	✗
Phishing	Low	Medium	High	Critical	✗
Spam URLs	Low	Medium	High	Critical	✗
Drug Abuse	Low	Medium	High	Critical	✗
Malware	Low	Medium	High	Critical	✗

Risk Level Values

Risk Level	Value
Low	5
Medium	10
High	30
Critical	50

Affichage et gestion des journaux

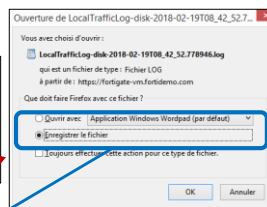
• Télécharger des logs en GUI

#	Date/Time	Source	Device
1	08:40:03	196.223.152.30	
2	08:40:03	196.223.152.30	

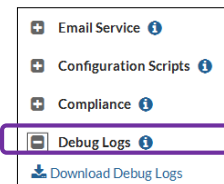
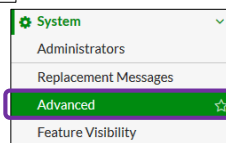
Les logs ne sont pas formatés (raw format)

```
date=2018-02-19 time=07:10:54 logid="0100032001" type="event"
subtype="system" level="information" vd="root" logtime=
1519053054 logdesc="Admin login successful" src="1519053054"
user="demo" ui="https(95.182.239.72)" method="https" srcip=
95.182.239.72 dstip=172.30.72.73 action="login"
status="success" reason="none" profile="demo-read-only"
msg="Administrator demo logged in successfully from
https(95.182.239.72)"
```

Il peut être utile de pouvoir
fournir les journaux debug
au support client pour aider
au dépannage.



Les journaux de débogage peuvent être téléchargés
depuis la page System > Advanced



Affichage et gestion des journaux

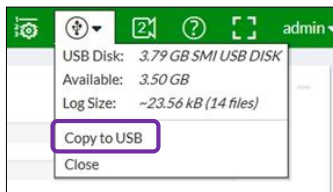
- Sauvegarde des logs

- Vers l'USB ou un serveur FTP/TFTP

- Les logs sont enregistrés en format compressé LZ4.
 - Il est recommandé de stopper « *miglogd* » et « *reportd* ».

```
# execute backup disk alllogs [ ftp | tftp |usb]
# execute backup disk log [ ftp | tftp |usb] <log_type>
```

En USB, le menu apparaît quand on branche un périphérique USB.



Les sauvegarde de logs réalisées en CLI ne peuvent pas être restaurées sur un autre FortiGate.
→ FortiAnalyzer

Affichage et gestion des journaux de bord

- Sauvegarde des logs (suite)

- Log rolling

- Similaire à une compression, permet de réduire l'espace disque occupé par les journaux.
 - Automatique lorsque les journaux atteignent une taille de 20 Mo (configurable).

- Log uploading

- Les logs (compressés) peuvent être automatiquement envoyé sur un serveur FTP et effacés localement juste après l'envoi.
 - Possible de spécifier le type de log et le moment de l'envoi.

```
# config log disk setting
set max-log-file-size <1-100>
set roll-schedule [daily | weekly]
set roll-day <day of week>
set roll-time [hh:mm]
set upload [enable | disable]
set upload-destination [FTP]
set upload-delete-files [enable* | disable]
...
```

Chapitre 4

Intrusion Prevention System

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Protéger un réseau contre les attaques connues en utilisant les signatures IPS.
 - Protéger un réseau contre des "anomalies" telles que du trafic inhabituel ou des paquets mal formés.
 - Protéger un réseau contre des attaques DoS.
 - Protéger les services Web à l'aide de profils WAF (Web Application Firewall).
 - Configurer un FortiGate pour inspecter le trafic réseau hors ligne (IDS).

- **IDS : Intrusion Detection System**

- Analyse l'activité d'un réseau (NIDS) ou d'un hôte (HIPS)

- **Pour y détecter des exploits**
 - Attaques connues (Il existe des signatures).
- **Pour y détecter des anomalies**
 - Erreurs de protocoles, trafic anormal (DoS, ...), attaque zero-day.
- **De manière passive**
 - Aucune action directe sur le trafic, l'IDS est offline.



- Collecte des informations

- Par exemple via l'enregistrement de tout le trafic ou uniquement du trafic concernant une attaque.
- Le HIDS est donc indispensable dans une optique de traçabilité d'attaque



- Alerte les administrateurs

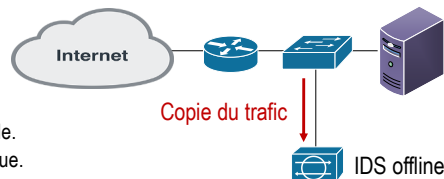
- **L'IDS n'agit pas sur le trafic**
 - Le trafic malicieux peut pénétrer dans le réseau.
 - L'administrateur doit réagir à postériori.
- **L'IDS peut cependant faire appel à un FW pour que celui-ci bloque le trafic**



- **IDS : Intrusion Detection System**

- Avantages des IDS (si offline)

- **Pas d'impact sur le réseau**
 - Ni en cas de panne d'une sonde.
 - Ni en cas de surcharge d'une sonde.
 - N'introduit pas de latence ni de gigue.



- Inconvénients des IDS

- **Ne peut pas être totalement automatisé**
 - La configuration et l'administration des IDS nécessitent beaucoup de temps et de connaissances (analyse des logs).
- **Nécessite du personnel compétent**
 - L'exploitation des remontées d'alertes nécessite des connaissances pointues.
 - Quelle mesure prendre ? Comment distinguer un faux-positif d'un véritable incident de sécurité ? Etc.
- **Vulnérable à certaines techniques d'évasion**

- **IPS : Intrusion Prevention System**

- Si un IDS peut détecter une intrusion, alors pourquoi ne pas la bloquer?

- **Techniquement, un IPS est un IDS qui ajoute des fonctionnalités de blocage**

- Aucun paquet ne peut pénétrer dans le réseau sans avoir été analysé par l'IPS.

- *Inline mode :*

- » L'IPS doit être sur le chemin du trafic.

- **L'IPS est actif, il peut agir sur le trafic**

- Empêcher les paquets de passer.

- Interrompre une connexion.

- Ralentir une connexion.

- Bloquer les sources.

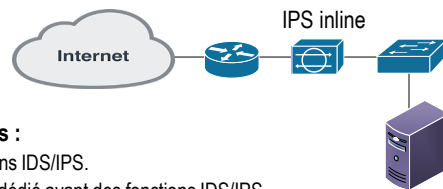
- ...

- **IPS et IDS peuvent être déployés :**

- Sur un routeur ayant des fonctions IDS/IPS.

- Sur un périphérique de sécurité dédié ayant des fonctions IDS/IPS.

- Via un module installable sur un Sw, un R ou un appliance de sécurité.



- **IPS : Intrusion Prevention System**

- **Avantages des IPS**

- Contrairement à un IDS, les attaques sont bloquées immédiatement.

- Permet de bloquer d'autres types d'attaques que l'antivirus.

- Permet de créer des règles pour protéger les systèmes vulnérables, le temps que des correctifs de sécurité soient distribués.

- **Inconvénients des IPS**

- **Possibilité de nombreux faux-positifs**

- Un faux-positif est un paquet ou message injustement considéré comme nuisible.

- De nombreux paquets sains peuvent ainsi être bloqués.

- **Possibilité d'impacts négatifs sur le réseau**

- Paralyser le réseau si l'IPS ne fonctionne plus ou est surchargé..

- Introduire de la latence et de la gigue sur le réseau (si l'IPS est mal dimensionné).

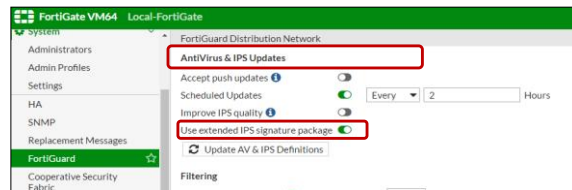
- Bloquer du trafic légitime à cause des faux-positifs.

- IPS FortiGate
 - Peut détecter des attaques connues
 - Un trafic ou un fichier correspond à une signature
 - Les signatures sont régulièrement mises à jour par le service Fortiguard.
 - Peut détecter des anomalies
 - Détecté par l'analyse comportementale
 - Signatures IPS basées sur des taux.
 - Règles spécifique contre du DoS.
 - Inspection du protocole.
 - Exemples :
 - Quantité de trafic anormalement élevé (DoS/flood) par rapport à la ligne de base.
 - Utilisation anormale du protocole (drapeau SYN et RST en même temps).

- Bases de données de signatures
 - Regular signatures database
 - Base de données réduite reprenant des signatures d'attaques classiques
 - Inclue par défaut dans chaque version du firmware FortiGate.
 - Provoquent rarement de faux positifs.
 - L'action par défaut est le blocage (Default action = Block)
 - Extended signature database
 - La base de données de signatures étendue contient des signatures supplémentaires
 - Disponible uniquement pour les FortiGate ayant suffisamment d'espace disque ou de RAM.
 - Ces signatures peuvent plus facilement générer des faux positifs.
 - Plutôt utilisée pour les réseaux nécessitant une plus haute sécurité

— Mises à jour

- Les mises à jour permettent d'inclure automatiquement de nouvelles signatures
 - Nécessite un abonnement au service Fortiguard IPS.
- Les décodeurs sont également mis à jour
 - Assez rare, par exemple en cas de modification des RFC ou des spécifications d'un protocole.
- Le moteur IPS est lui-aussi mis à jour
- Choisir la base de données de signatures
 - System > FortiGuard

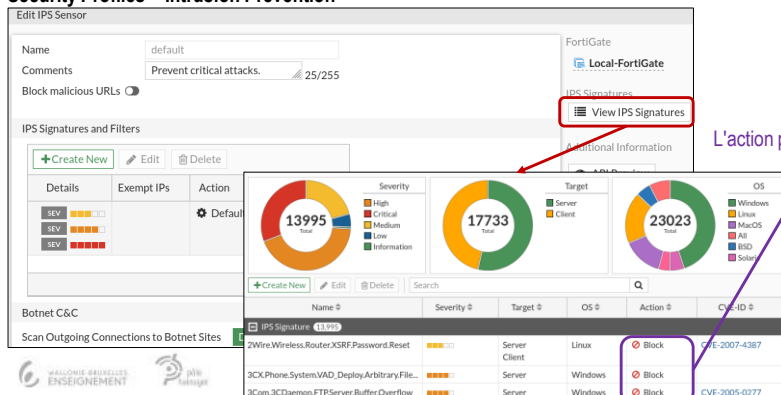


• Listes des signatures IPS

L'action par défaut est généralement correcte mais peut être modifiée (ou la signature supprimée) :

- Si une application "maison" déclenche une signature IPS.
- Si un correctif de sécurité bloque un exploit, il n'est plus utile de continuer à rechercher cet exploit.

Security Profiles > Intrusion Prevention



Custom IPS Signatures

- Signatures personnalisées

- Il est possible de créer ses propres signatures

- Utile pour bloquer du trafic lié à une vulnérabilité pour lequel il n'y a aucun patch

Syntaxe :

Mots-clés spécifiques au protocole.
 Défini dans quelle partie du paquet rechercher

Chaque paire mot-clé/valeur se termine par un point-virgule et un espace

une correspondance

Valeur pour laquelle il y aura une correspondance.

En-tête

Toutes les signatures personnalisées commencent par F-SBIB

Opérateurs utilisables
 =, !=, >=, <=, &, |, ^, in

```

F-SBIB ( --KEYWORD VALUE; --KEYWORD VALUE; )
  
```

IPS sensors

- Les sondes IPS (IPS sensors)

- Les signatures IPS

- Elles contiennent des paramètres (valeurs, mots clés)
 - Ces paramètres peuvent être comparés au contenu des paquets reçus à la recherche d'une correspondance.

- Les filtres IPS

- Ils regroupent un ensemble de signatures
 - Permettent de fournir différents niveaux de protection selon les signatures incluses.
 - Ils peuvent être personnalisés
 - Plus un filtre sera précis, moins il consommera de ressources pour analyser le trafic.

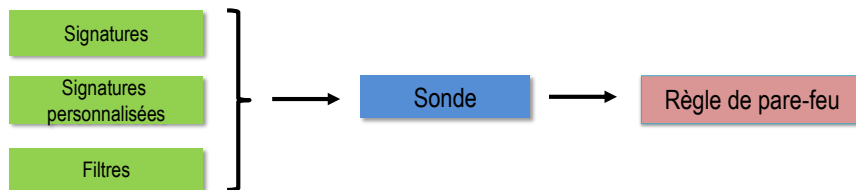
- Les sondes IPS

- Elles regroupent des filtres et/ou des signatures individuelles.
 - Elles sont chargées d'analyser le trafic réseau :
 - Par rapport aux signatures et filtres paramétrés.
 - Pour y détecter des tentatives d'intrusion, des paquets mal formés ou des attaques DoS.

- Les sondes IPS (suite)

- Remarque

- Si la signature qui correspond au trafic se trouve à la fois dans la liste des signatures IPS et dans la liste des filtres IPS, FortiGate applique l'action spécifiée dans la liste des signatures.



- Ajouter des signatures à une sonde IPS

Sélectionner les signatures individuellement

Security Profiles > Intrusion Prevention > Create new

Add Signatures

Type: **Filter** Signature

Action: **Default**

Packet logging: **Enable** **Disable**

Status: **Enable** **Disable** **Default**

Filter: **Filter**

Rate-based settings: **Default** **Specify**

Threshold: 0

Duration (seconds): 60

Track By: **Any** Source IP Destination IP

Exempt IPs: 0 Edit IP Exemptions

Signature List:

Name	Severity	Target	OS	Action	CVE-ID
2Wire.Wireless.Router.XSRF.Password.Reset	High	Server	Linux	Monitor	CVE-2007-4387
3CX.Phone.System.VAD_Deploy.Arbitrary.FL...	High	Server	Windows	Reset	
3Com.3CDaemon.FTP.Server.Buffer.Overflo...	High	Server	Windows	Default	CVE-2005-0277
3Com.3CDaemon.FTP.Server.Information.D...	High	Client	Windows	Quarantine	CVE-2005-0278

Packet Logging: **Packet Logging**

IPS sensors

- Les règles sont lues dans l'ordre
 - Si possible, placer les règles les plus utilisées en premier.
 - Ne pas utiliser de trop gros filtres ni trop de filtres (consommation de ressources).

Security Profiles > Intrusion Prevention

Possible d'exempter certaines adresses source ou destination (analyse faux positifs)
Uniquement sur les signatures individuelles.

Source IP/Netmask	Destination IP/Netmask
10.0.1.10/32	0.0.0.0/0

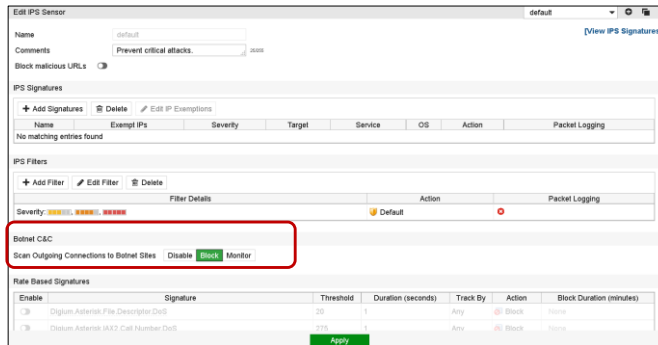
Rate Based Signatures

- Les signatures basées sur les taux/seuils
 - Blocage du trafic en fonction d'un seuil
 - Ces signatures permettent de bloquer le trafic concerné lorsqu'un des seuils est dépassé pendant la période de temps configurée.
 - Cela permet d'économiser les ressources du système et peut décourager une attaque répétée.
 - Elles ne devraient s'appliquer qu'aux protocoles que vous utilisez réellement
 - Inutile de rechercher à inspecter des protocoles non utilisés dans le réseau.

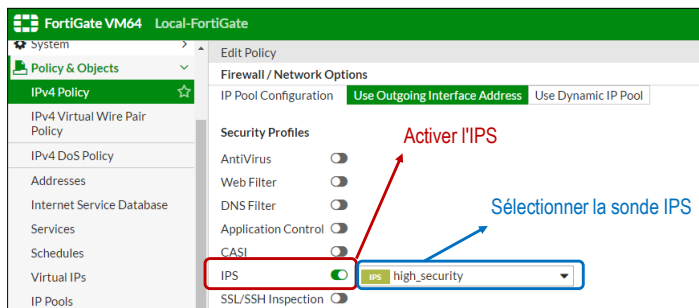
Security Profiles > Intrusion Prevention

Enable	Signature	Threshold	Duration (seconds)	Track By	Action	Block Duration (minutes)
☐	Digium.Asterisk.File.Descriptor.DoS	20	1	Any	Block	None
☐	Digium.Asterisk.IAX2.Call.Number.DoS	275	1	Any	Block	None
☐	DotNetNuke.Padding.Oracle.Attack	1000	5	Any	Block	None
☒	FTPLLogin.Brute.Force	200	10	Source IP	Block	None
☒	FreeBSD.TCP.Reassembly.DoS	10	2	Destination IP	Monitor	None
☒	IMAPLogin.Brute.Force	60	10	Any	Block	None
☐	MS.Active.Directory.LDAP.Packet.Handling.DoS	100	1	Any	Block	None

- Activer la protection contre les botnets
 - Fait partie de la licence IPS depuis FortiOS 6.2



- Activer un profil d'inspection IPS
 - Activer le profil de sécurité IPS et sélectionner la sonde à associer à la règle de pare-feu.



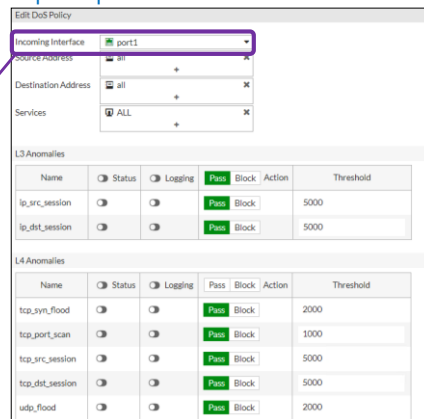
Denial of Service (DoS)

- DoS, DDoS
 - Dénier de service, Dénier de service distribué
 - Une attaque DoS vise à consommer toutes les ressources
 - La RAM, le CPU, le nombre de connexions, etc.
 - Dans le but de ralentir ou empêcher le fonctionnement d'un système
 - Trop de requêtes vont saturer la cible.
 - Via des requêtes valides ou non valides
 - Bloquer une attaque DoS
 - Appliquer une règle DoS (DoS Policy)
 - Celle-ci exécute une action lorsqu'un seuil est dépassé.
 - » Trop de connexions à moitié ouvertes, trop de trafic provenant de la même source, ...
 - Utiliser plusieurs sondes permet de détecter différentes anomalies.

Denial of Service (DoS)

- Configuration des règles de protection DoS
 - La protection DoS peut être appliquée à quatre protocoles
 - TCP, UDP, ICMP et SCTP.
 - Plusieurs règles sont prédéfinies.

Plusieurs règles DoS peuvent être appliquées à une interface physique ou logique.



Edit DoS Policy

Incoming Interface: port1

Source Address: all

Destination Address: all

Services: ALL

L3 Anomalies

Name	Status	Logging	Pass	Block	Action	Threshold
ip_src_session	☐	☐	☒	☐	Block	5000
ip_dst_session	☐	☐	☒	☐	Block	5000

L4 Anomalies

Name	Status	Logging	Pass	Block	Action	Threshold
tcp_syn_flood	☐	☐	☒	☐	Block	2000
tcp_port_scan	☐	☐	☒	☐	Block	1000
tcp_src_session	☐	☐	☒	☐	Block	5000
tcp_dst_session	☐	☐	☒	☐	Block	5000
udp_flood	☐	☐	☒	☐	Block	2000

Denial of Service (DoS)

- Configuration des règles de protection DoS (suite)
 - Quatre types différents de détection d'anomalies peuvent être appliqués à chaque protocole supporté
 - **Flood sensor**
 - Détecte un volume élevé de trafic d'un protocole particulier (e.g. TCP SYN flood).
 - **Sweep/scan**
 - Détecte les tentatives de scan de ports (ou de réseau :ICMP sweep) ou de recherche de cibles (*probing attempts*).
 - **Source (SRC)**
 - Détecte de gros volumes de trafic provenant d'une seule adresse IP.
 - **Destination (DST)**
 - Détecte de gros volumes de trafic destinés à une seule adresse IP.

Denial of Service (DoS)

- Configuration des règles de protection DoS
 - Conseil
 - Consulter la Network Baseline pour déterminer les seuils à appliquer.
 - Si vous ne disposez pas de références précises
 - Pour la première implémentation :
 - » Ne pas bloquer le trafic.
 - » Journalisez le trafic.
 - Analysez les journaux pour déterminer les niveaux normaux et les pics pour chaque protocole.
 - Réglez les seuils de façon à ce que les pics habituels ne soient pas bloqués.

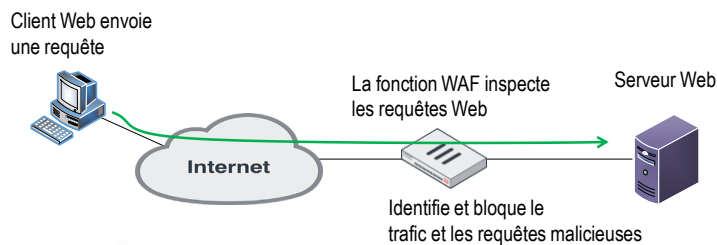
Name	Status	Logging	Pass	Block	Action	Threshold
tcp_syn_flood	☐	☐	Pass	Block		2000

Seuils trop élevés → risque d'épuisement des ressources avant que la règle ne déclenche.

Seuils trop bas → risque d'abandon du trafic normal.

Web Application Firewall

- WAF
 - Web Application Firewall
 - **Web filter** = pour protéger des postes clients.
 - **WAF** = Utilisé pour protéger des services Web.
 - Disponible uniquement en mode proxy
 - Analyse en profondeur du trafic HTTP(S).



Web Application Firewall

- WAF signatures
 - Les signatures WAF
 - L'UTM effectue une action prédéfinie sur le trafic qui correspond à une signature.
 - Base étendue de signatures
 - Peut être nécessaire dans les environnement très sécurisés mais génère plus de faux-positifs.
 - Offre une protection contre une série d'attaques contre les serveurs Web
 - Cross-site scripting (XSS).
 - SQL injection.
 - Exploits web connus.
 - Injection de commandes OS.
 - Robots/spiders/scripts malicieux.
 - Chevaux de Troie.
 - Divulgateur d'informations à propos du serveur (Server information disclosure).
 - Fuites de données concernant des cartes de crédit.
 - ...

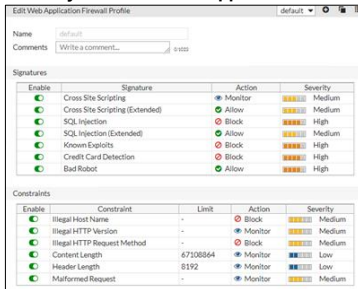
Web Application Firewall

- FortiGate implémente un WAF
 - Disponible uniquement en mode proxy

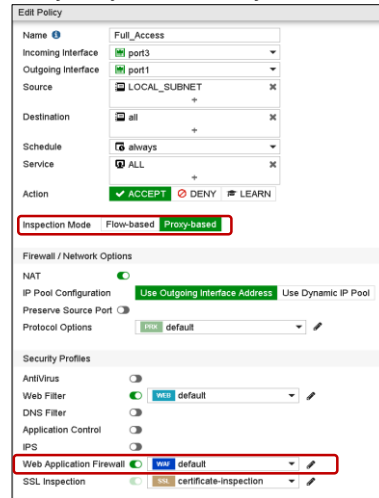
System > Feature Visibility



Security Profiles > Web Application Firewall



Policy & Objects > IPv4 Policy



149

One-arm-sniffer IPS

- One-arm-sniffer IPS
 - One-arm topology
 - Le FortiGate doit être connecté à un port en mirroring (SPAN).
 - Il inspecte donc une copie des paquets, pas les paquets originaux.
 - Utilisation
 - Permet de placer un FortiGate en offline pour faire du sniffing
 - On parle de mode sniffer parce que le FortiGate ne peut pas bloquer le trafic.
 - Permet la journalisation des actions que le FortiGate aurait appliqués aux paquets.
 - Actuellement utilisé pour des phases de test ou d'évaluation
 - Utilisé au début de l'introduction des IPS qui étaient trop lents et introduisaient trop de latence.

150

One-arm-sniffer IPS

- One-arm-sniffer Configuration
 - Uniquement activable sur des interfaces physiques

Permet de préciser que type de trafic doit être inspecté

Par défaut, seul le trafic non tagué (VLAN Natif) est inspecté

Liste des profils de sécurité supportés

Implémentation IPS

- Conseils d'implémentation d'un IPS
 - Analyser les besoins
 - Toutes les règles de pare-feu ne nécessitent pas une inspection IPS
 - Commencez par les services les plus critiques pour l'entreprise.
 - Commencez par monitorer avant de bloquer.
 - Évaluer les menaces applicables
 - Créer des sondes IPS spécifiquement pour les ressources à protéger
 - Inutile de scanner les signatures MacOS si votre parc est en Windows.
 - Inutile de garder des signatures si une menace n'existe plus (correctif)
 - Surveillance et ajustement régulier
 - Surveiller régulièrement les journaux pour détecter les modèles de trafic anormaux.
 - Ajuster les profils IPS en fonction des observations.

- **Conseils d'implémentation (suite)**
 - **Trafic chiffré**
 - N'oubliez pas le profil d'inspection SSL/SSH (deep inspection), sans lui il est impossible d'inspecter le trafic chiffré.
 - **Règles DoS**
 - Il n'est pas possible d'appliquer un profil d'inspection SSL pour les règles DoS.
 - Ces règles n'inspectent pas la charge utile des paquets mais les types de session et le volume qui leur est associé.

- **Conseils d'implémentation (suite)**
 - **Accélération matérielle**
 - Les modèles FortiGate qui prennent en charge la fonction « Nturbo » peuvent décharger le traitement IPS sur les processeurs NP6, NP7 ou SoC4.
 - Si la commande `np-accel-mode` est disponible sous config system global, le modèle FortiGate prend en charge NTurbo.

```
# config ips global
# set np-accel-mode [ basic | none ]
# set cp-accel-mode [ basic | advanced | none ]
# end
```

- Afficher les logs de l'IPS
 - Log & Report > Security Events

Summary Details

 Intrusion Prevention 

Top Attack
Apache.Expect.Header.XSS

Summary Details

  Add Filter 1M Intrusion Prevention  

Date/Time	Severity	Source	Protocol	User	Action	Log Details
2 seconds ago		10.200.1.254	6		dropped	 General Absolute Date/Time 2022/04/21 22:44:13 Time 22:44:13 Session ID 10137 Virtual Domain root Agent Mozilla/5.0 (Nikto/2.1.5) (Evasions:None) (Test:004131)
2 seconds ago		10.200.1.254	6		detected	
2 seconds ago		10.200.1.254	6		detected	
2 seconds ago		10.200.1.254	6		detected	
12 seconds ago		10.200.1.254	6		dropped	
22 seconds ago		10.200.1.254	6		dropped	
32 seconds ago		10.200.1.254	6		dropped	
42 seconds ago		10.200.1.254	6		dropped	
53 seconds ago		10.200.1.254	6		dropped	 Source IP 10.200.1.254 Source Port 42810 Country/Region Reserved Source Interface port1 User
Minute ago		10.200.1.254	6		dropped	

155

Compléments IPS

- **Encyclopédie FortiGuard**
 - Disponible sur le site Web FortiGuard
 - Contient des renseignements utiles comme les systèmes touchés et les mesures correctives recommandées.

Home > FortiGuard Encyclopedia

Vulnerability: WordPress.Shortcode.Tags.XSS

Info

Last Updated: March 1, 2015

Severity: High

Description

This indicates an attack attempt against a Cross-Site Scripting vulnerability in WordPress. The vulnerability is due to insufficient sanitizing of user supplied inputs in the application. A remote attacker may be able to exploit this to execute arbitrary script code within the context of the application, via crafted HTTP requests.

Affected Products

WordPress versions 4.3 and earlier

Recommended Actions

Apply the most recent upgrade or patch from the vendor.
<https://wordpress.org/download/>

Update History

Date	Version	Detail
2016-03-02	6.804	Released

Free Tools

FortiClient
is free, industry-certified, all-in-one personal security suite. It includes Anti-Virus, Web Filtering, Application Firewall, VPN and more.

Online Virus Scan
Upload a suspicious file for scanning by FortiGuard for Online Scanner.

- **Les options de filtres**
 - Le minuteur « hold time »
 - Permet de définir la durée pendant laquelle les signatures sont maintenues avec l'action « Monitor » après une mise à jour de signature FortiGuard IPS.
 - L'action par défaut des nouvelles signatures est activée à l'expiration du minuteur, afin d'éviter les faux positifs.
 - Configurable entre 0 jour et 0 heure (par défaut) et 7 jours.

```
# config system ips
set signature-hold-time 3d12h
set override-signature-hold-by-id enable
end
```

– Fichiers journaux

- Les logs renseignent si le minuteur est actif.

```
date=2021-04-06 time=00:00:57 logid="0419016384" type="utm" subtype="ips"
eventtype="signature" level="alert" vd="vd1" eventtime=1278399657778481842 tz="-0700"
severity="info" srcip=10.1.100.22 srccountry="Reserved" dstip=172.16.200.55
srcintf="port13" srcintfrole="undefined" dstintf="port14" dstintfrole="undefined"
sessionid=3620 action="detected" proto=6 service="HTTP" policyid=1
attack="Eicar.Virus.Test.File" srcport=52170 dstport=80 hostname="172.16.200.55"
url="/virus/eicar" direction="incoming" attackid=29844 profile="test"
ref="http://www.fortinet.com/ids/VID29844" incidentserialno=25165825 msg="file_transfer:
Eicar.Virus.Test.File, (signature is on hold)"
```

- Les options de filtres
 - CVE (Common Vulnerabilities and Exposures)
 - CVE est une liste publique des informations relatives aux vulnérabilités de sécurité informatique.
 - Fournit un descriptif succinct de chaque vulnérabilité.
 - Fournit un ensemble de liens pour plus d'informations.
 - Il est maintenu par l'organisme à but non lucratif MITRE.
 - <https://www.cve.mitre.org>
 - Aident les professionnels
 - A coordonner leurs efforts visant à hiérarchiser et résoudre les vulnérabilités.
 - Format : CVE-AAAA-NNNN
 - AAAA = l'année de publication.
 - NNNN = un numéro d'identification unique.

- Les options de filtres (suite)
 - Exemple de CVE
 - La vulnérabilité qui a permis une attaque massive par le ransomware Wannacry.
 - A l'origine de l'arrêt des lignes de production de Renault. Plus 200.000 ordinateurs on été impactés dans environ 100 pays.

CVE-ID	
CVE-2017-0144	Learn more at National Vulnerability Database (NVD) • CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information
Description	
The SMBv1 server in Microsoft Windows Vista SP2; Windows Server 2008 SP2 and R2 SP1; Windows 7 SP1; Windows 8.1; Windows Server 2012 Gold and R2; Windows RT 8.1; and Windows 10 Gold, 1511, and 1607; and Windows Server 2016 allows remote attackers to execute arbitrary code via crafted packets, aka "Windows SMB Remote Code Execution Vulnerability." This vulnerability is different from those described in CVE-2017-0143, CVE-2017-0145, CVE-2017-0146, and CVE-2017-0148.	
References	
Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.	
• BID: 96704 • URL: http://www.securityfocus.com/bid/96704 • CONFIRM: https://cert-portal.siemens.com/productcert/pdf/ssa-201903.pdf • CONFIRM: https://cert-portal.siemens.com/productcert/pdf/ssa-966241.pdf • CONFIRM: https://portal.msrc.microsoft.com/en-US/security-guidance/advisory/CVE-2017-0144 • EXPLOIT-DB: 41891 • URL: https://www.exploit-db.com/exploits/41891/ • EXPLOIT-DB: 41987 • URL: https://www.exploit-db.com/exploits/41987/ • EXPLOIT-DB: 42030	

- Les options de filtres (suite)

- L'option « CVE Pattern »

- Permet de filtrer les signatures IPS sur la base des ID CVE ou sur un ensemble de CVE (CVE wildcard).
 - Facilite l'utilisation des CVE : toutes les signatures marquées avec ce CVE sont automatiquement incluses.

- Exemple

```
# config ips sensor
edit "cve"
  set comment "cve"
  config entries
    edit 1
      set cve "cve-2010-0177"
      set status enable
      set log-packet enable
      set action block
    next
  end
```

- FortiWeb (NSE6)

- Offre de meilleures performances que la fonction WAF d'un FortiGate

- Équipement dédié à la protection Web.

- Protection plus complète que le WAF d'un FortiGate

- Meilleure connaissance du protocole HTTP.
 - Peut effectuer des analyses de vulnérabilités.
 - Peut réaliser des tests de pénétration.

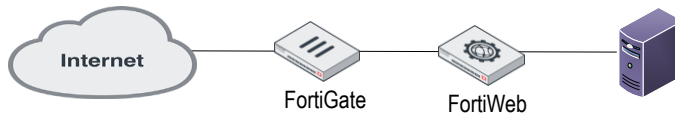
- Contrôleur de mise à disposition d'applications

- Peut réécrire des paquets HTTP et acheminer le trafic en fonction du contenu HTTP.
 - « Application Delivery Controller » (ADC) basique.
 - Leur fonction est d'améliorer les performances, la sécurité et la résilience des applications Web.
 - Répartition de charge serveur, traffic shaping, cache, accélération SSL, ...

- **Architecture**

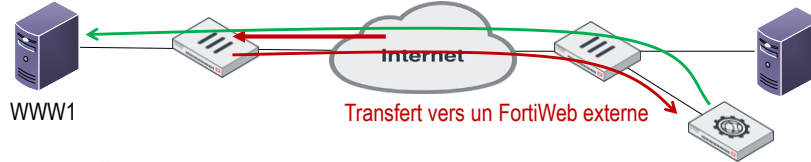
- **Inline FortiWeb**

- Le FortiWeb est placé entre le FortiGate et le serveur Web à protéger.

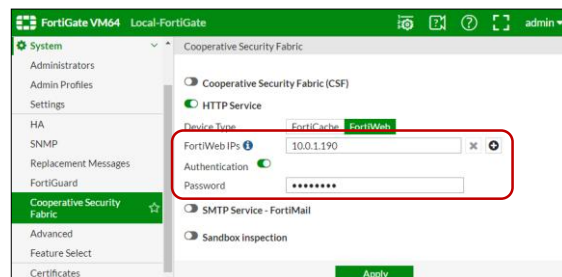


- **Offline FortiWeb**

- Le FortiGate doit être configuré pour transférer le trafic vers le FortiWeb.
 - Le Fortiweb peut être externe.



- **Configuration pour rediriger le trafic vers un FortiWeb offline**



- Dépannage IPS

- Vérifier les mises à jour : System > FortiGuard

- Mises envoyées à update.fortiguard.net sur TCP 443

Intrusion Prevention	Licensed (Expiration Date: 2023/01/18)	
IPS Definitions	Version 18.00052	Actions
IPS Engine	Version 7.00018	
Malicious URLs	Version 2.00970	
Botnet IPs	Version 7.01436	View List
Botnet Domains	Version 2.00721	View List

- Forcer une mise à jour manuelle

```
# diagnose debug application update -1
# diagnose debug enable
# execute update-now
```

- Dépannage IPS (suite)

- Utilisation élevée du processeur

- L'option 5 laisse le moteur IPS fonctionner, mais il n'inspecte pas le trafic.
 - Si l'utilisation du processeur diminue, cela indique généralement que le volume de trafic inspecté est trop élevé pour ce modèle de FortiGate.

```
# diagnose test application ipsmonitor <Integer>

1: Display IPS engine information
2: Toggle IPS engine enable/disable status
3: Display restart log
4: Clear restart log
5: Toggle bypass status
6: Submit attack characteristics now
10: IPS queue length
11: Clear IPS queue length
12: IPS L7 socket statistics
13: IPS session list
14: IPS NTurbo statistics
15: IPS A statistics
97: Start all IPS engines
98: Stop all IPS engines
99: Restart all IPS engines and monitor
```

- Dépannage IPS (suite)

- Mode « Fail-open »

- Si l'IPS manque de mémoire pour traiter les nouveaux paquets, il passe en mode fail-open.

```
date=2021-04-21 time=09:07:59 logid=0100022700 type=event
subtype=system level=critical vd="root" logdesc="IPS session scan
paused" action="drop" msg="IPS session scan, enter fail open mode"
```

- Comportement

- Si le paramètre fail-open est activé : certains nouveaux paquets (en fonction de la charge du système) passeront sans être inspectés.
 - Si le paramètre fail-open est désactivé : tous les nouveaux paquets sont abandonnés

```
config ips global
set fail-open <enable|disable>
```

- Essayez de déterminer la cause et réalisez les ajustement nécessaires

- Le volume de trafic a-t-il augmenté récemment ?
 - Le mode fail-open se déclenche-t-il à des heures précises de la journée ?

Chapitre 5

Contrôle d'application

Application control

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Configurer et appliquer les profils de contrôle applicatif.
 - Configurer le trafic shaping.
 - Analyser les journaux relatifs aux événements du contrôle d'application.

Contrôle d'application

- Capable de détecter et agir sur le trafic applicatif
 - Détecter
 - Par exemple les jeux ou les applications utilisant beaucoup de bande passante.
 - Prend en charge de nombreuses applications et catégories.
 - Si une application n'est pas prise en charge, il est possible de demander à FortiGuard de la prendre en charge.
 - Le scan de protocoles sécurisés est possible via le profil d'inspection SSL/SSH.
 - Agir
 - Monitorer, laisser passer, bloquer ou appliquer du contrôle de flux (trafic shaping)



- **Avantages du contrôle d'application**
 - Apporter une meilleure visibilité et un contrôle fin des applications.
 - Quel que soit le port ou le protocole utilisé.
 - Réduire les risques liés au Bring-Your-Own-Device (BYOD).
 - Ne maîtrisant pas les applications installées sur les équipements BYOD, les administrateurs doivent pouvoir réaliser un contrôle d'application afin de réguler ce qu'un utilisateur peut faire sur le réseau.
 - Limiter l'exposition notamment créée par les applications de médias sociaux
 - Certaines fonctionnalités peuvent être intéressante pour l'entreprise, tout bloquer pourrait causer une perte de productivité.
 - Réduire les surfaces d'attaque
 - En bloquant certaines applications ou fonctionnalités des applications, certaines attaques sont rendues impossibles.
 - Récupérer la bande passante
 - En contrôlant la BP allouées aux applications de streaming ou encore de partage (P2P).
 - En garantissant une bande passante suffisante pour les applications stratégiques.

- **Principe du contrôle d'application FortiGate**
 - Utilise le moteur IPS pour analyser le trafic
 - Peut être utilisé dans des règles de pare-feu en mode flow-based ou proxy-based.
 - Cependant, le scan est toujours de type flow-based.
 - Comme il utilise le moteur IPS, il devrait consommer plus ou moins la même chose que la fonction IPS.
 - Pas de risque de tomber à court de connexions proxy.
 - Le moteur IPS recherche des motifs (pattern) connus dans tout le flux d'octets
 - Permet de détecter les applications même si elles utilisent des protocoles et des ports non standards.
 - Permet d'identifier les applications même si l'utilisateur passe par un proxy externe.
 - Il faut que l'application utilise des motifs (pattern) spécifiques (reconnaissables).

Contrôle d'application

- Mise à jour des signatures

- La mise à jour des signatures est importante

- Lorsque le comportement des applications sont modifiées notamment lorsque les développeurs y ajoutent des fonctionnalités.
 - Lorsque de nouveaux protocoles / applications sont utilisés.

- La mise à jour nécessite un abonnement Fortiguard

System > FortiGuard

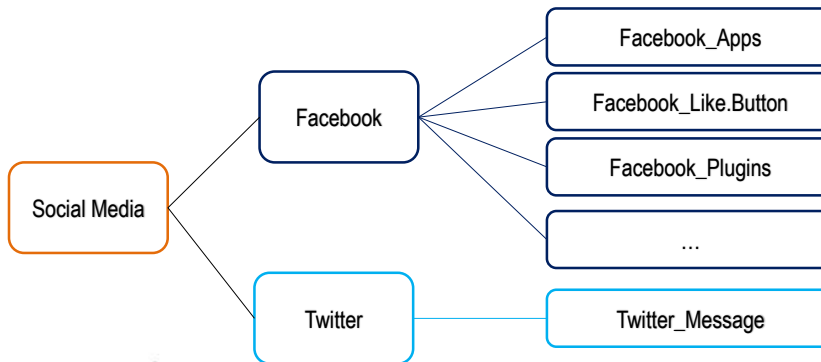
Firmware & General Updates	✓ Licensed (Expiration Date: 2023/01/18)	
Application Control Signatures	⊙ Version 16.00943	⋮ Actions ▾
Device & OS Identification	⊙ Version 1.00111	➤ Upgrade Database
Internet Service Database Definitions	⊙ Version 7.01069	☰ View List

Contrôle d'application

- Signatures (suite)

- Les signatures sont organisées de manière hiérarchique

- Les signatures parentes prevlent sur les signatures enfants.



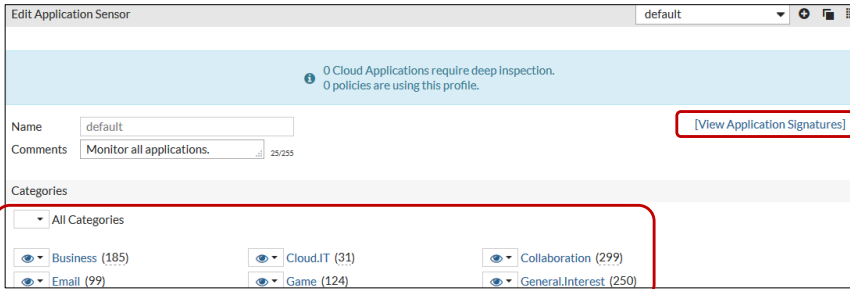


Contrôle d'application

- Signatures
 - Afficher les signatures du contrôle d'applications

Security Profiles

- AntiVirus
- Web Filter
- DNS Filter
- Application Control** ★

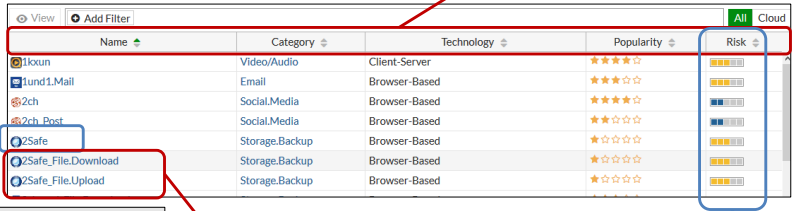


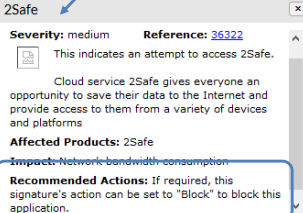
 175



Contrôle d'application

- Signatures (suite)
 - Classement par nom, catégorie, technologie, popularité ou risque





 176

- Common Vulnerability Scoring System

- Quels risques sont liés à une vulnérabilité?

- De nombreux éditeurs de solutions de sécurité utilisent leurs propres méthodes propriétaires pour attribuer des notes à l'impact des vulnérabilités.
 - Il n'est pas facile pour une entreprise d'évaluer l'importance des vulnérabilités afin de les prioriser et remédier à celles qui posent les plus grands risques.

- Système de notation des vulnérabilités

- CVSS permet de classer les vulnérabilités et fournir un score représentant la gravité globale et le risque que présente une vulnérabilité.
 - CVSS est une initiative publique conçue pour aider les analystes à noter les vulnérabilités et pour aider les organisations à utiliser les scores.

- FIRST

- Le CVSS est actuellement géré par le Forum of Incident Response and Security Teams (FIRST).

- Niveau de risque

Niveau de risque	Icone	Description	Exemples
Critical		Applications utilisées pour dissimuler des activités, utilisant des techniques d'évasion.	Tor, Spyboss.
High		Applications pouvant causer des fuites d'informations ou susceptibles d'introduire des malwares.	P2P, torrent, remote desktop
Medium		Applications qui peuvent être mal utilisées.	Gmail, VoIP, ...
Elevated		Applications pouvant mener à une perte de productivité.	Facebook, Youtube, jeux
Low		Applications métier ou inoffensives.	Mises à jour OS

- Profils du contrôle d'application
 - NGFW profile-based
 - Pour utiliser les profils, l'option NGFW doit être réglée sur le mode «profile-based».
 - Rappel : Le scan des paquets est toujours flow-based.
 - Les applications sont filtrées sur base de 3 filtres :
 1. Application overrides
 2. Filter overrides
 3. Categories
 - Une fois configuré, le profil doit être appliqué à une règle de pare-feu

- Profils du contrôle d'application (suite)
 - Ordre du filtrage d'application
 1. Le moteur IPS identifie l'application.
 2. Application overrides (si configuré) et Filter overrides (si configuré).
 - ATTENTION : l'ordre (*application* en premier ou *filter* en premier) dépend de la configuration réalisée.
 3. Categories.
 - Actions
 - **Allow** : le trafic est accepté et ne génère pas de log.
 - **Monitor** : le trafic peut passer et il y a génération d'un log (utile pour découvrir le trafic d'un réseau).
 - **Block** : abandonne le trafic et journalise. Un message de blocage est envoyé s'il s'agit d'une application HTTP.
 - **Quarantine** : bloque le trafic de l'IP source jusqu'à l'expiration du temps de quarantaine et journalise.

Configuration du contrôle d'application

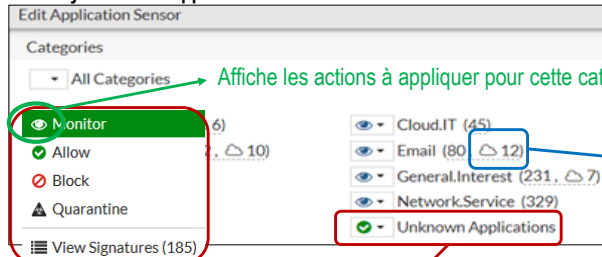
• Profils du contrôle d'application (suite)

– Categories

• Une catégorie est un regroupement d'applications

– Par exemple, toutes les applications P2P ou toutes les applications de médias sociaux.

Security Profiles > Application Control



Correspond au trafic qui n'a pu être associé à aucune signature de contrôle d'application

Configuration du contrôle d'application

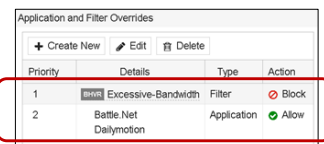
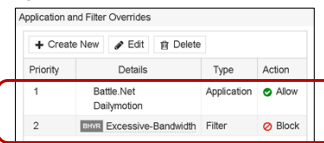
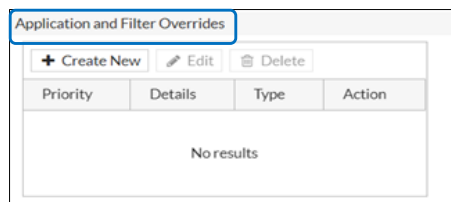
• Profils du contrôle d'application (suite)

– Application overrides

• Offre de la flexibilité en permettant de configurer des actions pour des signatures d'applications spécifiques (individuelles).

– Filter overrides

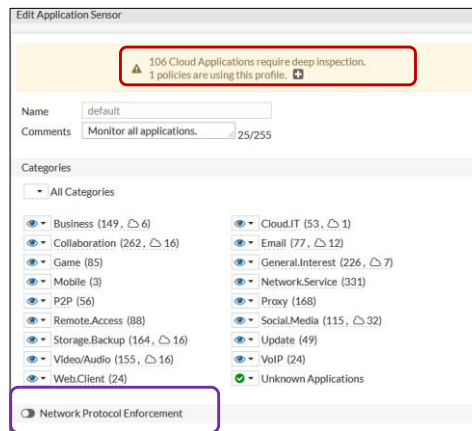
• Permet de définir ses propres catégories de filtrage dans le cas où celles proposées ne conviennent pas.



Attention à l'ordre

Configuration du contrôle d'application

- Profils du contrôle d'application (suite)
 - Deep inspection (SSL/SSH) est requis pour scanner le trafic chiffré avec SSL

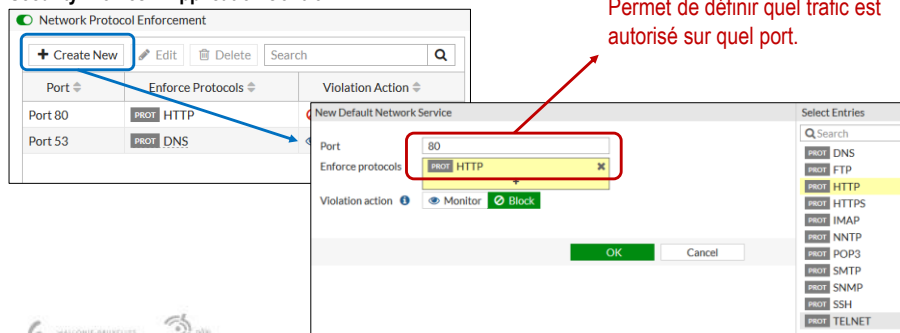


183

Configuration du contrôle d'application

- Profils du contrôle d'application (suite)
 - Protocol enforcement
 - Permet d'empêcher l'utilisation de protocoles connus sur d'autres ports que ceux normalement prévus.

Security Profiles > Application Control



184

Configuration du contrôle d'application

- Profils du contrôle d'application (suite)
 - Appliquer le profil à une règle de pare-feu

Policy & Objects > Firewall Policy

Ne pas oublier de choisir le profil « deep inspection », sans quoi le trafic chiffré avec SSL ne sera pas inspecté

185

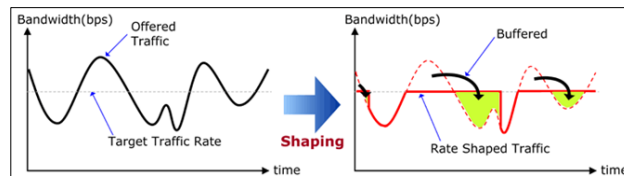
Configuration du contrôle d'application

- Page de blocage
 - Permet d'afficher les raisons du blocage à l'utilisateur
 - Ces pages sont personnalisables.

186

Application Control Traffic Shaping

- **Régulation du trafic (Traffic shaping)**
 - **Régulation de la bande passante utilisée par les applications**
 - Permet de définir une bande passante maximale utilisable par les applications
 - Uniquement le trafic qui correspond à une signature d'application.
 - N'interfère pas avec d'autres applications qui utilisent le même port/protocole.
 - **File d'attente**
 - Les paquets excédentaires sont maintenus dans une file d'attente.
 - Cette régulation nécessite de la mémoire pour stocker tous les paquets retardés.
 - **Les paquets retardés sont transmis graduellement dans le temps**
 - Uniquement lorsque de la BP pour l'application concernée est à nouveau disponible.



Configuration du contrôle d'application

- **Configuration de la régulation du trafic**
 - **Policy & Objects > Traffic Shaping Policy**

Il est nécessaire qu'une règle du pare-feu autorise le trafic à réguler.

La règle de pare-feu ne doit pas nécessairement correspondre exactement à la règle de régulation de flux (all $\leftrightarrow$ 10.10.0.x/24).

- Le traffic shaping peut s'appliquer à
- une catégorie d'applications,
 - une application spécifique,
 - un groupe personnalisé d'applications (> FortiOS 6.2)

Application Category Group

Configuration du contrôle d'application

Types de traffic shaping

Shared shaper

- Fixe une limite à la bande passante en upload, tous les utilisateurs se partagent cette bande passante.

Reverse shaper

- Idem shared shaper mais pour le téléchargement/streaming.

Per-IP Shaper

- Applique la mise en forme du trafic à toutes les adresses IP source listée dans la politique de sécurité. Chaque IP se verra allouer la même bande passante maximale.

Then:

Action Apply Shaper Assign Shaping Class ID

Outgoing interface port2 + ✕

Shared shaper ☒ shared-1M-pipe

Reverse shaper ☒ medium-priority

Per-IP shaper ☒ limited-10-sessions

Then:

Action Apply Shaper Assign Shaping Class ID

Outgoing interface +

Traffic shaping class ID This field is required. Q Search + Create

No entries

Journalisation

Journalisation du contrôle d'application

Afficher les journaux

- Log & Report > Application Control.
- La journalisation **doit** être activée dans la règle de pare-feu.

Exemple d'un client essayant d'accéder à BitTorrent

Log & Report > Security Events

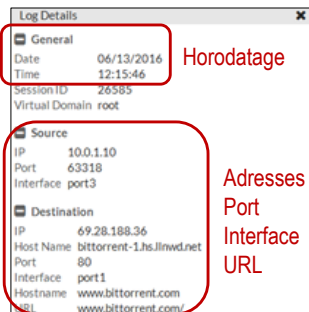
Summary	Details
Application Control ☒	
Top Category	
Web/Client	Pass 601
Network/Service	Pass 279
Video/Audio	Pass 71
Video/Audio	Block 31

#	Date/Time	Source	Destination	Application	Action
37	12:15:53	10.0.1.10	4.2.2.2	DNS	pass
38	12:15:52	10.0.1.10	4.2.2.2	DNS	pass
39	12:15:52	10.0.1.10	172.217.3.78	YouTube	pass
40	12:15:52	10.0.1.10	172.217.3.67	Google.Accounts	pass
41	12:15:51	10.0.1.10	172.217.3.78	YouTube	pass
42	12:15:51	10.0.1.10	172.217.3.78	YouTube	pass
43	12:15:51	10.0.1.10	172.217.3.78	HTTPBROWSER_Firefox	pass
44	12:15:46	10.0.1.10	69.28.188.36	BitTorrent	pass
45	12:15:46	10.0.1.10	98.143.146.7	HTTPBROWSER_Firefox	pass
46	12:15:21	10.0.1.10	69.28.188.36	BitTorrent	pass
47	12:15:20	10.0.1.10	69.28.188.36	BitTorrent	pass
48	12:14:27	10.0.1.10	205.178.187.13	HTTPS.BROWSER	pass
49	12:13:44	10.0.1.10	69.171.239.11	DNS	pass

Clic pour afficher les détails (voir diapo. suivante)

Journalisation

- Journalisation du contrôle d'application
 - Exemple de détail d'un log



Horodatage

Adresses
Port
Interface
URL

Catégorie

N° de la règle

Journalisation

- Dashboard
 - Les événements du contrôle d'applications sont visibles dans le widget « Top Applications » du dashboard
 - Nécessite un disque dur.
 - Les modèles sans disque dur peuvent utiliser FortiView via la journalisation avec FortiCloud.

Dashboard > Top Applications

Application	Category	Risk	Bytes	Sessions	Bandwidth
SSL	Network.Service	Low	12.29 MB	33	1.11 Mbps
YouTube_HDStreaming	Video/Audio	Low	3.94 MB	1	2.47 Mbps
YouTube_VideoAccess	Video/Audio	Low	2.32 MB	1	13.48 kbps
HTTPBROWSER_Firefox	Web.Client	Low	2.15 MB	7	3.64 kbps
Vimeo_VideoPlay	Video/Audio	Low	1.95 MB	2	872.04 kbps
YouTube_VideoPlay	Video/Audio	Low	1.07 MB	3	1.92 Mbps
Vimeo	Video/Audio	Low	173.10 kB	5	46.79 kbps
LinkedIn	Social.Media	Low	75.13 kB	6	37.69 kbps
Dailymotion	Video/Audio	Low	70.19 kB	1	13.13 kbps
Google.Services	General.Interest	Low	33.66 kB	2	3.67 kbps
Vimeo_VideoAccess	Video/Audio	Low	19.31 kB	1	1.18 kbps
OCSP	Network.Service	Low	7.10 kB	4	1.66 kbps
NTP	Network.Service	Low	152 B	1	16 kbps

Quand utiliser le contrôle applicatif?

- **Conseils**

- Evitez de consommer des ressources inutilement

- Appliquez le contrôle d'application uniquement au trafic qui le nécessite
 - Ne pas appliquer le contrôle d'applications au trafic interne-interne si vous connaissez exactement les applications installées sur les serveurs et les clients du réseau.

- Balancement de charge

- Appliquez les mêmes inspections sur tous les périphériques redondants.

- Inspection SSL/SSH

- Choisissez « Deep SSL/SSH inspection » plutôt que la simple vérification des certificats.

- Loguez

- Pour voir les logs depuis un FortiGate qui n'a pas de disque interne, utilisez FortiCloud.

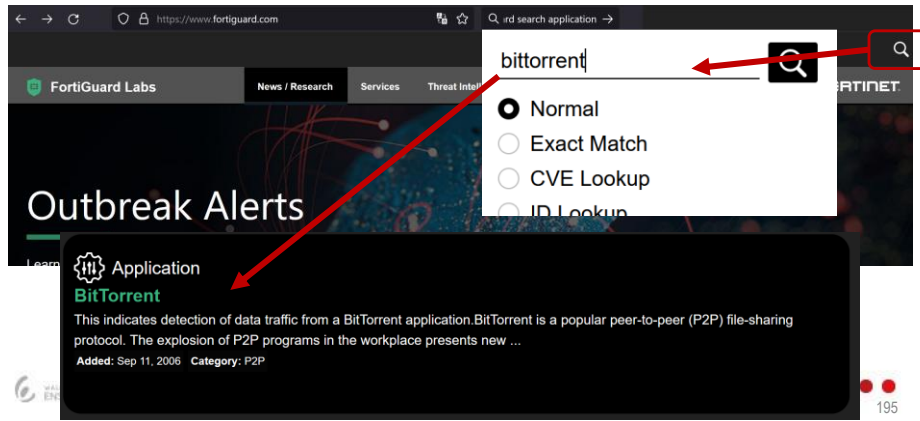
- Si elle est disponible, utilisez l'accélération matérielle

Compléments Contrôle d'application

Contrôle d'application

- Recherche d'une application

- Sur <https://fortiguard.com>, Fortinet garde une encyclopédie des applications supportées.



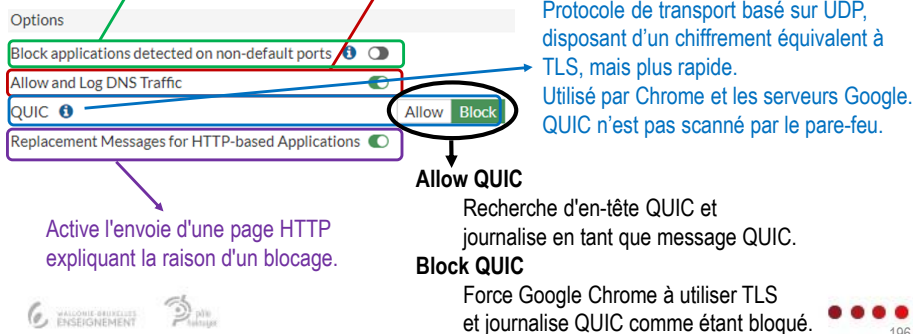
Configuration du contrôle d'application

- Profils du contrôle d'application

- Options

Bloquer les applications n'utilisant pas le port par défaut (HTTP 80, SSL 443, ...)

Attention à la consommation de ressources si trop de logs



Configuration du contrôle d'application

- NGFW Policy-based mode (Cont.)
 - Example

Ces applications de médias sociaux sont bloquées par la règle N°1

Policy & Objects > Firewall Policy

The screenshot shows the 'Interface Pair Views' tab in the Palo Alto Networks User Interface. The interface displays a list of network interfaces and their associated policies. A red box highlights the 'Facebook' interface, which is currently set to 'DENY'. A green box highlights the 'All' interface, which is currently set to 'ACCEPT'. A blue box highlights the 'Social Media' interface, which is currently set to 'DENY'. A red arrow points from the 'Facebook' interface to the 'Social Media' interface.

Trafic journalisée ou non

Les autres applications de médias sociaux sont autorisées par la règle N°2

Chapitre 6

Transport Layer Security

TLS

- Objectifs
 - Comprendre et expliquer le fonctionnement de SSL/TLS.
 - Comprendre et expliquer les différents niveaux de validations des certificats numériques.
 - Pouvoir vérifier la sécurité d'un site et d'un navigateur en ce qui concerne les accès en HTTPS.

- VPN d'accès à distance
 - Communications sécurisées entre les télétravailleurs et l'entreprise
 - Le VPN peut assurer la confidentialité, l'intégrité, l'authentification et l'anti-rejeu.
 - Les droits d'accès peuvent être adaptés selon les utilisateurs
 - Employés, sous-traitants, partenaires, ...
 - Déploiement d'un VPN d'accès à distance
 - Via le protocole SSL (VPN SSL)
 - Permet la connectivité à partir de périphérique BYOD.
 - Peu, voir pas de maintenance logicielle.
 - Portails Web personnalisés pour les utilisateurs à l'ouverture d'une session.
 - Via le protocole IPsec (VPN IPsec)
 - D'un point de vue sécurité (Puissance du chiffrement et de l'authentification), IPsec est meilleur que SSL.
 - Le VPN IPsec prend en charge un plus grand nombre d'applications que le VPN SSL.

- SSL et TLS

- Secure Socket Layer

- Développé initialement par Netscape pour protéger les échanges sur Internet.
 - A l'époque, norme imparfaite et non normalisée.

- Transport Layer Security

- L'IETF a poursuivi le développement de SSL

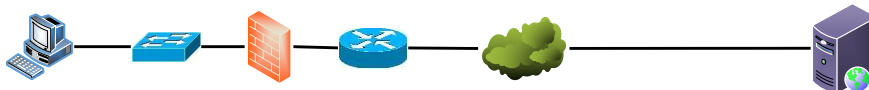
- En le rebaptisant TLS pour des questions de droits.
 - Fonctionne en mode client-serveur.
 - Norme actuelle = TLS 1.2

On emploie souvent SSL
bien que ce soit TLS qui
est maintenant utilisé.

- TLS est un ensemble de protocoles de sécurisation des échanges

- Il permet d'authentifier le serveur et le client.
 - Il permet de chiffrer les données.
 - Il permet de vérifier l'intégrité des données.
 - Il permet d'empêcher le replay.

TLS est complètement
transparent pour les utilisateurs



Client Hello

1) Requête https du client (versions TLS, algorithmes supportés, ... + nombre aléatoire)

Keys	Cipher	Hash
RSA, DH-RSA	AES, 3DES	HMAC-SHA2, AEAD

Server Hello

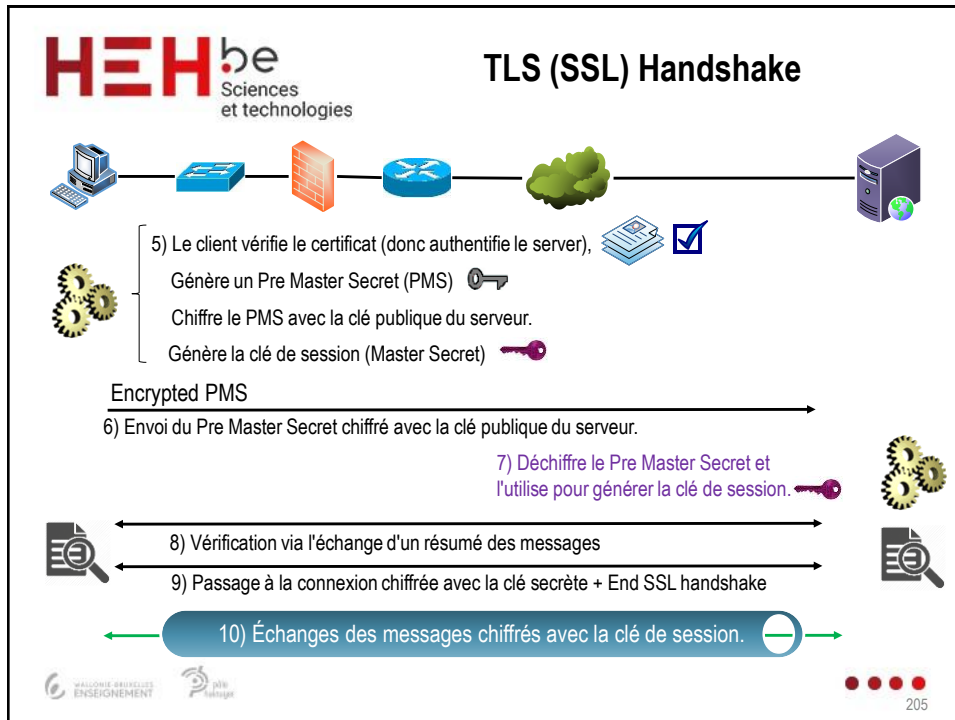
2) Utilise tels algorithmes + nombre aléatoire.

Server Hello Done

3) Le serveur envoie son certificat

Demand Client Certificate

4) Optionnel : demande le certificat du client et l'authentifie.



HEH.be Sciences et technologies

SSL/TLS

- TLS est transparent pour l'utilisateur
 - Comment savoir si l'on se connecte à un site sécurisé?

Cadenas (lock icon) and **HTTPS** (text) are highlighted in the browser address bar.

support.google.com
Connexion sécurisée

Permissions
Vous n'avez pas accordé de permission particulière à ce site.

Vérifier la sécurité de la connexion d'un site

Pour savoir si un site peut être consulté en toute sécurité, vous pouvez vous reporter aux informations de sécurité relatives au site en question. Un message d'avertissement s'affiche dans Chrome s'il s'avère impossible de consulter le site de manière sécurisée ou de manière confidentielle.

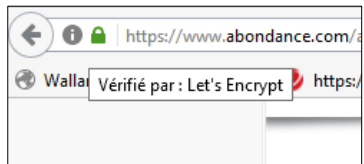
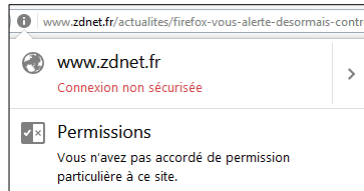
1. Ouvrez une page dans Chrome sur votre ordinateur.
2. Pour vérifier la sécurité d'un site, consultez l'état de sécurité à gauche de l'adresse Web :
 - Sécurisé
 - Informations ou Non sécurisé
 - Non sécurisé ou Dangereux
3. Pour afficher les détails et les autorisations du site, cliquez sur l'icône. En haut du panneau se trouve un récapitulatif sur le niveau de sécurité de la connexion selon Chrome.

Logos: WALLONIE BRUXELLES ENSEIGNEMENT, Université de la Région wallonne

206

- Reconnaitre un site sécurisé avec TLS

Indique aussi la société ou l'individu qui possède le nom de domaine → certificat EV.



- Let's Encrypt (LE)
 - Autorité de certification (depuis 2015)
 - Plus de 10 millions de certificats ont été délivrés après seulement un an.
 - Peut fournir des certificats gratuits X.509
 - Pour la sécurisation des sites Internet avec TLS.
 - Tout est automatisé
 - Création, validation, signature, installation et renouvellement des certificats,
- Niveaux de validations des certificats
 - Domain Validated (DV)
 - Organization Validated (OV)
 - Extended Validation (EV)

- WHOIS

- Service de recherche

- Permet d'obtenir des informations sur une adresse IP ou un nom de domaine.

dns.belgium Nom de domaine Produits Base d'information

NOM DE DOMAINE heh.be

DOMAINE:

Nom	heh.be
Statut	REGISTERED
Enregistrement	11 octobre 2005 11:05 CEST
Dernière mise à jour	06 septembre 2017 7:59 CEST

DÉTENTEUR DU NOM DE DOMAINE:

Nom	Heu DNS master
Organisation	Haute Ecole en Hainaut
Langue	Néerlandais
Adresse	Avenue Maelstiau 8 7000 Mons Belgique
Téléphone	+32.65397983
Télécopie	+32.65397983
Email	informatique@heh.be

Ces informations sont purement déclaratives
Elles ne sont pas vérifiées par les registraires.

- Domain Validated (DV SSL)

- Avantages

- Certificat bon marché et délivré rapidement (automatisé).

- Inconvénients

- La CA vérifie uniquement que le propriétaire du nom de domaine est le demandeur du certificat**
 - Vérification généralement par envoi d'un e-mail à l'adresse trouvée dans le WHOIS.
 - Ne garanti pas l'identité du propriétaire du site Web ni même l'existence de l'organisation/entreprise.
 - Une attaque par phishing est possible. Un pirate peut :**
 - Faire enregistrer www.belfius.be (un L au lieu du i).
 - Fournir de fausses informations au WHOIS (adresse gmail, numéro de téléphone VoIP, ...).
 - Créer un faux site ressemblant à celui de la banque.
 - le pirate aura un faux site similaire au site de Belfius, avec une URL très similaire et un certificat valide.

HEH.be Sciences et technologies

Niveaux de validations des certificats

- **Domain Validated (DV)**
 - **Vérification du type de certificat**

Informations sur la page - https://www.heh.be/

Identité du site web
Site web : www.heh.be
Propriétaire : Ce site web ne fournit pas d'informations sur son propriétaire.
Vérifiée par : TERENA

211

HEH.be Sciences et technologies

Niveaux de validations des certificats

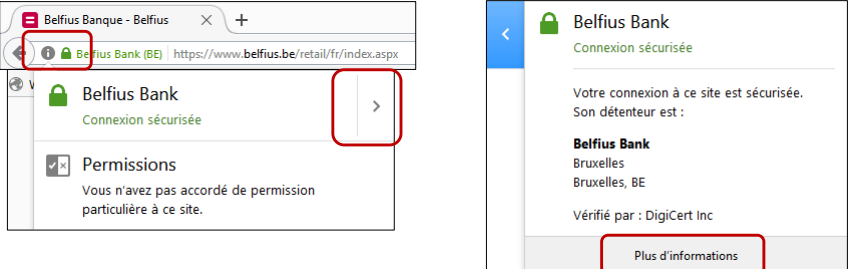
- **Organization Validated (OV SSL)**
 - **Ils garantissent la légitimité de l'organisation**
 - Ils "activent" le protocole https, ainsi que le cadenas sur les navigateurs.
 - L'identité de l'entreprise est affichée sur les navigateurs, prouvant que le site est légitime.
- **Extended Validation (EV SSL)**
 - **Appelé aussi High-Assurance Certificate**
 - Ils "activent" le protocole https, le cadenas et la barre d'adresse verte.
 - **Haut niveau de vérification**
 - Vérification du droit exclusif d'utilisation du nom de domaine.
 - Vérification de l'accord de l'organisation pour l'émission du certificat.
 - Vérification de l'existence légale, physique et opérationnelle de l'organisation.
 - Vérification de l'exactitude des informations transmises (adresse, n° de téléphone), etc.

212

HEH.be
Sciences
et technologies

Les certificats

- Afficher les certificats

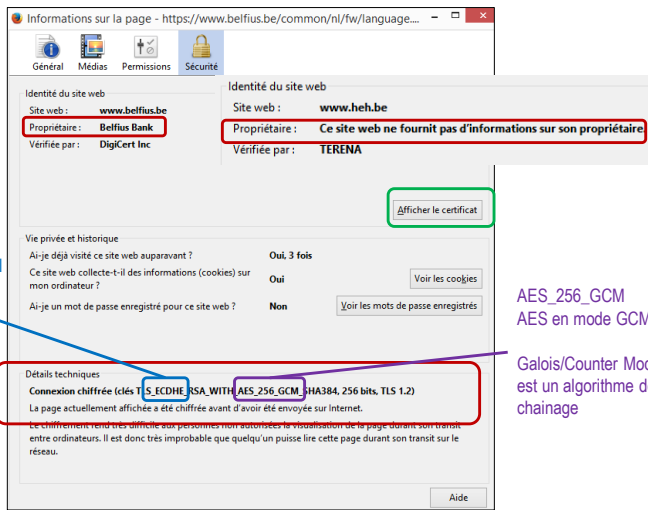


WALLONIE BRUXELLES
ENSEIGNEMENT

213

HEH.be
Sciences
et technologies

Les certificats



Informations sur la page - https://www.belfius.be/common/nl/fw/language...

Général Médias Permissions Sécurité

Identité du site web

Site web : **www.belfius.be**

Propriétaire : **Belfius Bank**

Vérifiée par : **DigiCert Inc**

Identité du site web

Site web : **www.heh.be**

Propriétaire : **Ce site web ne fournit pas d'informations sur son propriétaire**

Vérifiée par : **TERENA**

[Afficher le certificat](#)

Vie privée et historique

Ai-je déjà visité ce site web auparavant ? **Oui, 3 fois**

Ce site web collecte-t-il des informations (cookies) sur mon ordinateur ? **Oui** [Voir les cookies](#)

Ai-je un mot de passe enregistré pour ce site web ? **Non** [Voir les mots de passe enregistrés](#)

Détails techniques

Connexion chiffrée (clés **TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384**, 256 bits, TLS 1.2)

La page actuellement affichée a été chiffrée avant d'avoir été envoyée sur Internet.

Le chiffrement rend très difficile aux personnes non autorisées la visualisation de la page durant son transit entre ordinateurs. Il est donc très improbable que quelqu'un puisse lire cette page durant son transit sur le réseau.

[Aide](#)

WALLONIE BRUXELLES
ENSEIGNEMENT

214

- **Algorithme de chaînage**
 - **Algorithmes symétriques**
 - Ils utilisent toujours la même clé et chiffrent des petits blocs de données : il y a risque de chiffrer plusieurs fois les mêmes blocs.
 - En chiffrant toujours avec la même clé, il y a plus de risques qu'un pirate arrive à retrouver les clés (voir méthodes de cryptanalyse).
 - **Algorithme de chaînage.**
 - Ces algorithmes permettent de s'assurer que des chiffrements distincts sont produits même lorsque le même texte est chiffré plusieurs fois avec la même clé.
 - Exemples d'algorithmes
 - **CBC** : Cipher Block Chaining
 - **GCM** : Galois/Counter Mode
 - **EBC** : Electronic Codebook

Détails du certificat : « www.belfius.be »

Général Détails

Hierarchie des certificats

- ▾ DigiCert High Assurance EV Root CA
- ▾ DigiCert SHA2 Extended Validation Server CA
- ▾ **www.belfius.be**

Le certificat de Belfius a été signé par DigiCert SHA2.

Ce serveur a le droit de parler pour www.belfius.be

Champs du certificat

- ▾ www.belfius.be
 - ▾ Certificat
 - Version
 - Numéro de série
 - Algorithme de signature des certificats
 - Émetteur
 - Validité
 - Pas avant

On peut voir les attributs du certificat : N° de série, validité, ...

Valeur du champ



Attributs du certificat

Champs du certificat

- Numéro de série
- Algorithme de signature des certificats
- Émetteur
- Validité
 - Pas avant
 - Pas après
- Sujet
- Info clé publique du sujet

Valeur du champ

PKCS #1 SHA-256 avec chiffrement RSA

Champs du certificat

- Numéro de série
- Algorithme de signature des certificats
- Émetteur
- Validité
 - Pas avant
 - Pas après
- Sujet
- Info clé publique du sujet

Valeur du champ

11 juin 2018 à 14:00:00
(11 juin 2018 à 12:00:00 GMT)

Public-Key Cryptography Standards

Spécifications permettant d'accélérer le déploiement de la cryptographie à clé publique en définissant des normes de stockage et d'échange de certificats.

Attributs du certificat

Champs du certificat

- Numéro de série
- Algorithme de signature des certificats
- Émetteur
- Validité
 - Pas avant
 - Pas après
- Sujet
- Info clé publique du sujet

Valeur du champ

CN = DigiCert SHA2 Extended Validation Server CA
 OU = www.digicert.com
 O = DigiCert Inc
 C = US

Le certificat a été émis par l'autorité de certification DigiCert SHA2 Extended Validation Server

• Attributs du certificat

Champs du certificat

- Sujet
 - Info clé publique du sujet
 - Algorithme clé publique du sujet
 - Clé publique du sujet**
- Extensions
 - Identificateur de la clé d'autorité de certification
 - Clé d'identification du sujet du certificat
 - Nom alternatif du sujet du certificat

Valeur du champ

Module (2048 bits) :

```
d3 f7 06 54 d3 02 38 44 aa df d7 63 78 39 9f 8b
a1 25 41 dd 3b 26 bd 6c 22 fb 5a df f8 46 54 55
b4 d0 f8 fa c0 76 48 73 5e 2d 93 6e 9e 8a 80 68
11 e3 0a 53 7a 09 34 c7 56 53 ec 15 17 9b 33 f3
5f c7 6d 1c f1 0e 64 33 64 90 17 10 df 17 1b 73
5d 6f f8 2d 2f 09 8e 74 fe e2 75 16 39 b7 aa 54
dd 7c ef 07 11 94 a8 5d 4e 4d a1 40 d5 09 20 eb
b5 98 28 7f 89 ad fe 0a 5a 90 4b 5d 07 83 a6 c5
```

Le certificat contient la clé publique du serveur www.belfius.be

• Attributs du certificat

Champs du certificat

- Utilisation de la clé étendue
- Points de distribution de listes de certificats révoqués (LCR)
- Politiques du certificat
- Accès aux informations de l'autorité
- Contraintes de base du certificat
- Identificateur d'objet (1 3 6 1 4 1 11129 2 4 2)
- Algorithme de signature des certificats
- Valeur de signature du certificat**

Valeur du champ

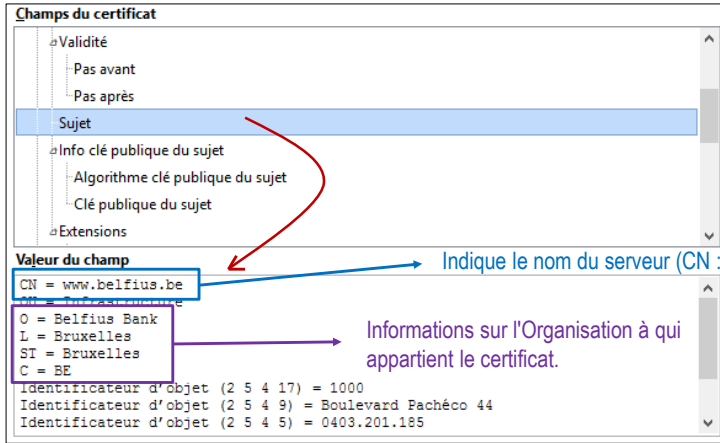
Taille : 256 octets / 2048 bits

```
43 99 81 37 62 0a a9 5b f1 2a d4 db 6d 3f 97 07
57 ae 9d c6 a1 98 84 37 ef 29 c7 74 63 04 57 11
73 c1 4b 51 33 74 17 ea 32 3d ae 17 7a 89 93 05
02 79 73 05 2a 14 4c 3b 75 44 3b 9c 1c e5 b5 d1
46 4a 3d ce d2 ef 7e 00 1d ae 51 36 5e 03 ce 76
73 d5 84 9a 00 b5 40 35 78 1f 0a 75 37 b5 99 66
15 93 57 61 37 9a 21 96 06 83 2e fb ac 77 4d d4
7f 2e e4 35 5a 57 13 93 bc fc 05 f8 a6 18 3e 39
```

Les informations du certificat (dont la clé publique de Belfius) ont été chiffrées par la clé privée de DigiCert SHA2 Extended Validation Server

Les certificats

Attributs du certificat



Champs du certificat

- Validité
 - Pas avant
 - Pas après
- Sujet
- Info clé publique du sujet
 - Algorithme clé publique du sujet
 - Clé publique du sujet
- Extensions

Valeur du champ

CN = www.belfius.be

O = Belfius Bank
L = Bruxelles
ST = Bruxelles
C = BE

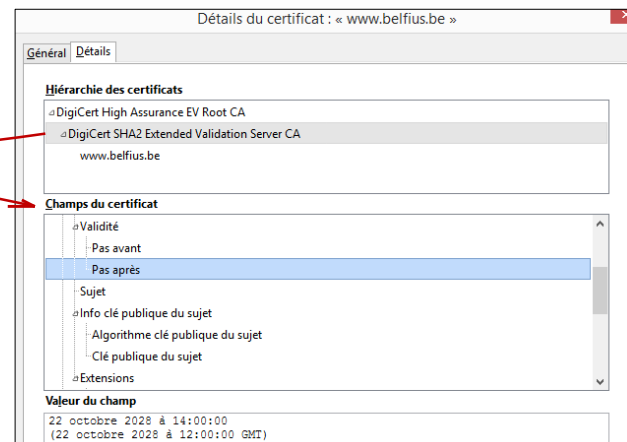
Indique le nom du serveur (CN : Common Name).

Informations sur l'Organisation à qui appartient le certificat.

Identificateur d'objet (2 5 4 17) = 1000
Identificateur d'objet (2 5 4 9) = Boulevard Pachéco 44
Identificateur d'objet (2 5 4 5) = 0403.201.185

Les certificats

Chaine de certificats



Détails du certificat : « www.belfius.be »

Général Détails

Hiérarchie des certificats

- DigiCert High Assurance EV Root CA
- DigiCert SHA2 Extended Validation Server CA
- www.belfius.be

Champs du certificat

- Validité
 - Pas avant
 - Pas après
- Sujet
- Info clé publique du sujet
 - Algorithme clé publique du sujet
 - Clé publique du sujet
- Extensions

Valeur du champ

22 octobre 2028 à 14:00:00
(22 octobre 2028 à 12:00:00 GMT)

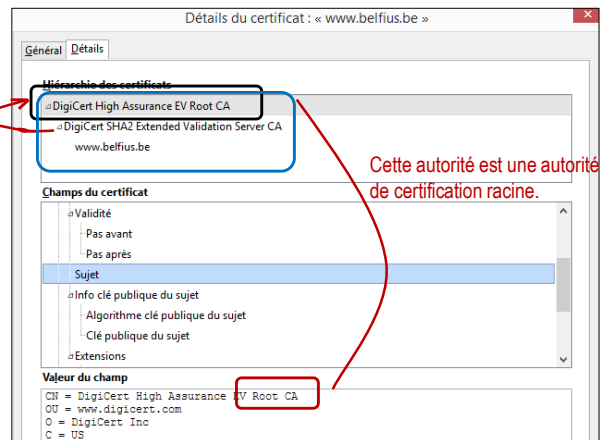
DigiCert SHA2 a lui-même un certificat qui est joint au certificat de Belfius.

• Chaîne de certificats

Le certificat DigiCert SHA2 est lui-même signé par une autre autorité de certification :
 DigiCert High Assurance EV Root CA

C'est la chaîne de certificats classique :

- Le certificat de l'autorité racine,
- Le certificat de l'autorité d'enregistrement,
- Le certificat client



• Pourquoi une chaîne de certificats ?

– Le navigateur doit pouvoir vérifier le certificat que le serveur lui envoie

- Le certificat du serveur contient la signature de la CA (signé avec la clé privée de la CA).
- Si le client parvient à déchiffrer la signature du certificat avec la clé publique de la CA, le certificat est authentique.

– Certains certificats sont intégrés aux navigateurs Il faut donc faire confiance à l'éditeur du navigateur !

• La clé publique de la CA se trouve dans un de ces certificats intégrés

- Pour que le navigateur puisse authentifier le certificat du serveur, il doit avoir le certificat de la CA contenant la clé publique de la CA.
- Tous les certificats de toutes les CA et RA ne sont pas intégrés aux navigateurs.
 - » Les certificats des CA racines pourraient suffire.

• Au niveau mondial

- Si une CA veut vendre des certificats au niveau mondial, ceux-ci vont se retrouver sur des milliers de machines à travers le monde.

Les certificats

• Pourquoi une chaîne de certificat ? (suite)

– Et si une CA racine perd sa clé privée?

- Si une CA racine perd ou se fait voler sa clé privée, il faut aller sur tous les navigateurs du monde pour modifier le certificat !
- Pour cette raison, la clé privée de la CA racine est utilisée une seule fois puis placée en sécurité.

– Autorité intermédiaire

• Avant de la mettre « au coffre » :

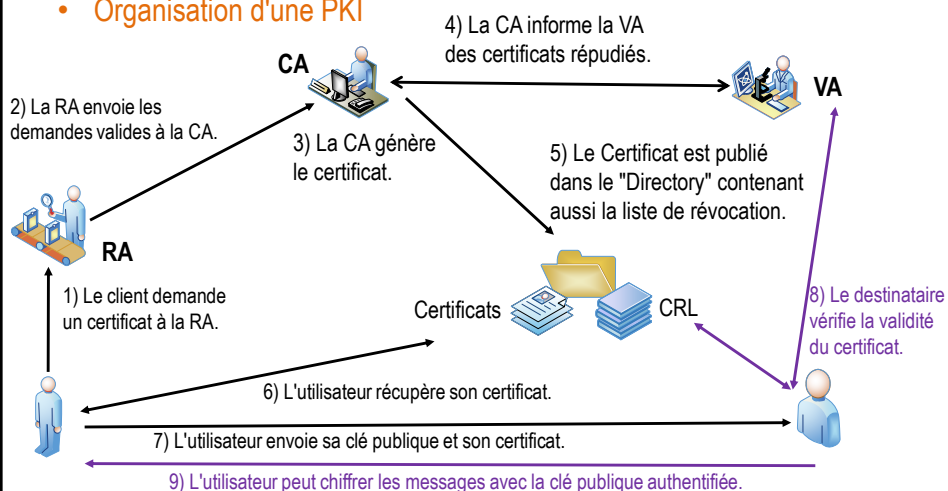
- On utilise la clé privée de l'autorité racine pour signer la paire de clé d'une autorité intermédiaire : l'autorité d'enregistrement.
- C'est cette nouvelle paire de clés de la RA qui va signer tous les certificats des serveurs.

• Si les clés de la RA sont compromises :

- On révoque le certificat de la RA.
 - On ressort la clé privée de la CA root de son coffre et on signe une nouvelle RA.
- On n'a pas du aller modifier tous les navigateurs car on garde la même CA root en qui on a toujours confiance.

Certificat

• Organisation d'une PKI



Une PKI est un ensemble de technologies, de procédures et de logiciels conçus pour gérer de manière sécurisée le cycle de vie des certificats numériques.

Les certificats

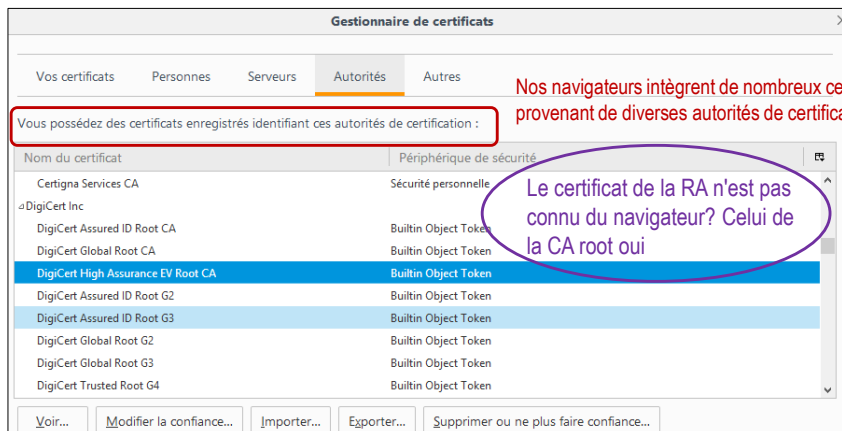
- Afficher les certificats connus du navigateur (Firefox)

Fichier Édition Affichage Historique Marque-pages Outils ?



Les certificats

- Afficher les certificats connus du navigateur (Firefox)



Nos navigateurs intègrent de nombreux certificats provenant de diverses autorités de certification.

Le certificat de la RA n'est pas connu du navigateur? Celui de la CA root oui

Les certificats

- Usage des certificats
 - Exemple n°1 : le certificat du serveur www.belfius.be

Champs du certificat

- Clé publique du sujet
- Extensions
 - Identificateur de la clé d'autorité de certification
 - Clé d'identification du sujet du certificat
 - Nom alternatif du sujet du certificat
 - Usage de la clé de certificat
 - Utilisation de la clé étendue
 - Points de distribution de listes de certificats révoqués (LCR)

Valeur du champ

- Critique
- Signature
- Chiffrement de la clé

Un des champ renseigne à quoi peut servir le certificat.

La clé publique du certificat peut être utilisée pour signer et chiffrer.

Critique

Le certificat doit être utilisé uniquement pour le ou les objectifs indiqués.
Le contraire constituerait une violation de la politique de la CA.

Les certificats

- Usage des certificats
 - Exemple n°2 : le certificat de la RA

Champs du certificat

- Clé publique du sujet
- Extensions
 - Contraintes de base du certificat
 - Usage de la clé de certificat
 - Utilisation de la clé étendue
 - Accès aux informations de l'autorité
 - Points de distribution de listes de certificats révoqués (LCR)
 - Politiques du certificat

Valeur du champ

- Critique
- Signature
- Signature de certificat
- Signature LCR

La clé de la RA peut aussi servir à signer des certificats ou des CRL.

- Certification Practice Statement (CPS)
 - La politique de certification (CPS) est un document reprenant l'ensemble des règles que suit l'autorité d'enregistrement pour ses prestations.

Champs du certificat	
	Utilisation de la clé étendue
	Points de distribution de listes de certificats révoqués (LCR)
	Politiques du certificat
	Accès aux informations de l'autorité
	Contraintes de base du certificat
	Identificateur d'objet (1 3 6 1 4 1 11129 2 4 2)
	Algorithme de signature des certificats
	Valeur de signature du certificat
Valeur du champ	
Non critique	
2.16.840.1.114412.2.1:	
Pointeur de déclaration de pratique de certification:	
	https://www.digicert.com/CPS
2.23.140.1.1	

La PCS est renseignée dans le certificat.

- OCSP

Champs du certificat	
	Utilisation de la clé étendue
	Points de distribution de listes de certificats révoqués (LCR)
	Politiques du certificat
	Accès aux informations de l'autorité
	Contraintes de base du certificat
	Identificateur d'objet (1 3 6 1 4 1 11129 2 4 2)
	Algorithme de signature des certificats
	Valeur de signature du certificat
Valeur du champ	
Non critique	
OCSP: URI: http://ocsp.digicert.com	
Émetteurs CA: URI: http://cacerts.digicert.com/DigiCertSHA2ExtendedValidationServerCA.crt	

URL permettant de valider le certificat via OCSP

- Répondeur OCSP

- Problème

- La validation des certificats est généralement faite par les clients PKI
 - Le client va vérifier dans le "Directory" la liste actualisée des certificats révoqués.
 - Les clients ne gèrent pas toujours cette validation correctement
 - Par exemple, la mise à jour des informations des CRL n'est pas automatisée.
 - Les navigateurs ne disposent donc pas toujours d'une liste correcte des certificats révoqués.

- Online Certificate Status Protocol

- Protocole utilisé pour vérifier la validité d'un certificat numérique X.509
 - OCSP permet de centraliser les CRL au sein d'une PKI.
 - Le client communique alors avec qu'avec une seule entité.
 - Standard IETF (RFC 6960)

- Répondeur OCSP

- Comme les serveurs OCSP répondent aux requêtes clients, ils sont appelés répondeurs OCSP.

- OCSP Stapling

- Inconvénients d'OCSP

- Cela ajoute de la latence aux connexions HTTPS
 - Il faut une connexion supplémentaire vers l'autorité de validation afin de vérifier le certificat.
 - Cela peut bloquer l'accès au site si le répondeur OCSP ne répond pas.
 - Peut être considéré comme une fuite d'informations
 - Vous indiquez au répondeur OCSP les sites que vous visitez, ce qui peut être dommageable en termes de respect de la vie privée.

- L'agrafage OCSP

- Principe
 - Le serveur HTTPS va lui même fournir une réponse OCSP, directement lors de la négociation TLS (handshake).
 - » Il va agraffer cette réponse OCSP aux informations échangées lors de la phase de handshake TLS.
 - » Ce n'est donc plus au client d'effectuer le contrôle de validité.
 - La réponse OCSP agrafée par le serveur est fiable car elle est horodatée (donc non périmée) et signée par la CA.
 - Le navigateur doit être compatible OCSP stapling

Quelques outils

- Qualys SSL Labs
 - Documentations et outils
 - Nombreux conseils pour gérer la sécurité de son site Web.
 - Des outils permettent de vérifier son site Web ainsi que son navigateur.
 - Exemple de vérification d'un navigateur

Protocol Support

Your user agent has good protocol support.

Your user agent supports TLS 1.2, which is recommended protocol version at the moment.

Logjam Vulnerability

Your user agent is not vulnerable.

For more information about the Logjam attack, please go to weakuh.org. To test manually, click [here](#). Your user agent is not vulnerable if it fails to connect to the site.

FREAK Vulnerability

Your user agent is not vulnerable.

POODLE Vulnerability

Your user agent is not vulnerable.

WALLONIE BRUXELLES
ENSEIGNEMENT

HOGESCHOOL
VIVES

235

Quelques outils

- Qualys SSL Labs (suite)
 - Exemple de vérification d'un navigateur (suite)

Protocol Features



Protocols

TLS 1.3	No
TLS 1.2	Yes
TLS 1.1	Yes
TLS 1.0	Yes
SSL 3	No
SSL 2	No

- Qualys SSL Labs (suite)
 - Exemple de vérification d'un navigateur (suite)

 **Cipher Suites (in order of preference)**

TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (0xc02b) <i>Forward Secrecy</i>	128
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f) <i>Forward Secrecy</i>	128
TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca9) <i>Forward Secrecy</i>	256
TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8) <i>Forward Secrecy</i>	256
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (0xc030) <i>Forward Secrecy</i>	256
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc031) <i>Forward Secrecy</i>	256
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (0xc00a) <i>Forward Secrecy</i>	256
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (0xc009) <i>Forward Secrecy</i>	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013) <i>Forward Secrecy</i>	128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014) <i>Forward Secrecy</i>	256
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (0x33) <i>Forward Secrecy</i>	128
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x39) <i>Forward Secrecy</i>	256
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)	256
TLS_RSA_WITH_3DES_EDE_CBC_SHA (0x2a) WEAK	112

(1) When a browser supports SSL 2, its SSL 2-only suites are shown only on the very first connection to this site. To see the suites, close all browser windows, then open this exact page directly. Don't refresh.

- Qualys SSL Labs (suite)
 - Exemple de vérification d'un navigateur (suite)

 **Protocol Details**

Server Name Indication (SNI)	Yes
Secure Renegotiation	Yes
TLS compression	No
Session tickets	Yes
OCSP stapling	Yes
Signature algorithms	SHA256/ECDSA, SHA384/ECDSA, SHA512/ECDSA, RSA_PSS_SHA256, RSA_PSS_SHA384, RSA_PSS_SHA512, SHA256/RSA, SHA384/RSA, SHA512/RSA, SHA1/ECDSA, SHA1/RSA
Named Groups	x25519, secp256r1, secp384r1, secp521r1
Next Protocol Negotiation	No
Application Layer Protocol Negotiation	Yes h2 http/1.1
SSL 2 handshake compatibility	No

- Qualys SSL Labs (suite)
 - Exemple de vérification d'un navigateur (suite)

Mixed Content Handling

 **Mixed Content Tests**

Images	Passive	Yes
CSS	Active	No
Scripts	Active	No
XMLHttpRequest	Active	No
WebSockets	Active	No
Frames	Active	No

(1) These tests might cause a mixed content warning in your browser. That's expected.
(2) If you see a failed test, try to reload the page. If the error persists, please get in touch.

[Related Functionality](#)

Upgrade Insecure Requests request header (more info)	Yes
--	-----

   239

- Qualys SSL Labs (suite)
 - Exemple de vérification d'un site Web ne supportant pas HTTPS
 - Résultat du test effectué en aout 2017

SSL Report:

Assessed on: Thu, 10 Aug 2017 08:02:28 UTC | [Hide](#) | [Clear cache](#) [Scan Another »](#)

Assessment failed: Unable to connect to the server

Known Problems

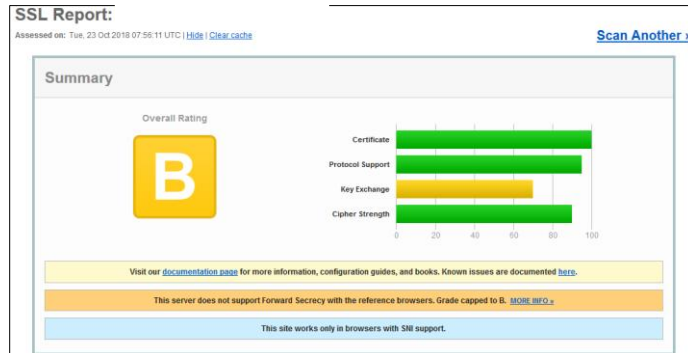
There are some errors that we cannot fix properly in the current version. They will be addressed in the next generation version, which is currently being developed.

- **No secure protocols supported** - if you get this message, but you know that the site supports SSL, wait until the cache expires on its own, then try again, making sure the hostname you enter uses the "www" prefix (e.g., "www.ssllabs.com", not just "ssllabs.com").
- **no more data allowed for version 1 certificate** - the certificate is invalid; it is declared as version 1, but uses extensions, which were introduced in version 3. Browsers might ignore this problem, but our parser is strict and refuses to proceed. We'll try to find a different parser to avoid this problem.
- **Failed to obtain certificate and Internal Error** - errors of this type will often be reported for servers that use connection rate limits or block connections in response to unusual traffic. Problems of this type are very difficult to diagnose. If you have access to the server being tested, before reporting a problem to us, please check that there is no rate limiting or IDS in place.
- **NetScaler issues** - some NetScaler versions appear to reject SSL handshakes that do not include certain suites or handshakes that use a few suites. If the test is failing and there is a NetScaler load balancer in place, that's most likely the reason.
- **Unexpected failure** - our tests are designed to fail when unusual results are observed. This usually happens when there are multiple TLS servers behind the same IP address. In such cases we can't provide accurate results, which is why we fail.

   240

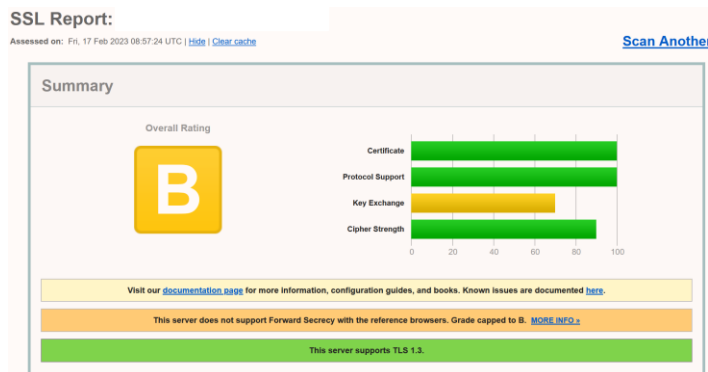
Quelques outils

- Qualys SSL Labs (suite)
 - Exemple moins sécurisé
 - Résultat du test effectué en octobre 2018



Quelques outils

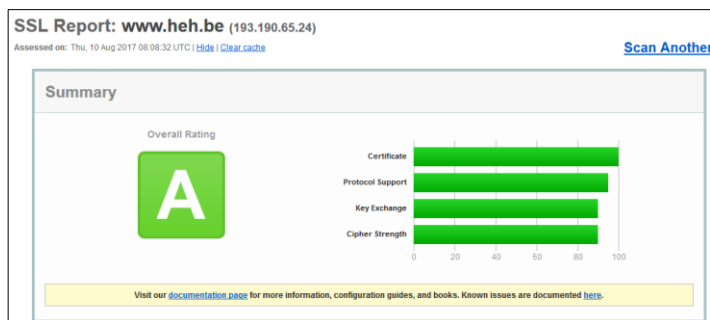
- Qualys SSL Labs (suite)
 - Exemple moins sécurisé
 - Résultat du test effectué en février 2023



- Qualys SSL Labs (suite)

Cipher Suites		
# TLS 1.2 (server has no preference)		
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)	WEAK	128
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (0x33)	DH 2048 bits FS	128
TLS_RSA_WITH_CAMELLIA_128_CBC_SHA (0x41)	WEAK	128
TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA (0x45)	DH 2048 bits FS	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	EC DH sec571r1 (eq. 15360 bits RSA) FS	128
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)	WEAK	128
TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (0x67)	DH 2048 bits FS	128
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)	WEAK	128
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 2048 bits FS	128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	EC DH sec571r1 (eq. 15360 bits RSA) FS	128
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	EC DH sec571r1 (eq. 15360 bits RSA) FS	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)	WEAK	256
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x39)	DH 2048 bits FS	256
TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (0x84)	WEAK	256
TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (0x88)	DH 2048 bits FS	256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	EC DH sec571r1 (eq. 15360 bits RSA) FS	256
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)	WEAK	256

- Qualys SSL Labs (suite)
 - Exemple de vérification d'un site Web
 - L'outil permet de vérifier la négociation du certificat, la négociation du protocole, l'échange de clé et la force du chiffrement.



Quelques outils

- Qualys SSL Labs
 - Exemple de vérification d'un site Web (suite)

Certificate #1: RSA 2048 bits (SHA256withRSA)	
 Server Key and Certificate #1	
Subject	mail.hedh.be Fingerprint (SHA256) a2028a52ef4a1a083a3ef1032a712952a47100210a089143a4a3247a7a0 Fp SHA256: Fp04g9X01220v1n08b0a04g9v0v02020g4g9
Common names	mail.hedh.be mail.hedh.be admin.hedh.be admin.hedh.be autodiscover.hedh.be autodiscover.hedh.be extranet.hedh.be extranet.hedh.be mail.hedh.be mail.hedh.be phpmyadmin.hedh.be phpmyadmin.hedh.be student.hedh.be student.hedh.be weinmail.hedh.be weinmail.hedh.be www.hedh.be www.hedh.be
Alternative names	
Serial Number	5cd25807612ca6a520236797afe434
Valid from	Tue, 17 Mar 2015 00:00:00 UTC
Valid until	Fri, 16 Mar 2018 23:59:59 UTC (expires in 7 months and 7 days)
Key	RSA 2048 bits (is 65537)
Weak key (Debian)	No
Issuer	TERENA SSL CA 2 AKA: http://net.usertrust.com/TERENASSLCA2.at
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	CRL OCSP CRL: http://net.usertrust.com/TERENASSLCA2.at OCSP: http://ocsp.usertrust.com
Revocation status	Good (not revoked)
OWS CAA	No (more info)
Trusted	Yes

Quelques outils

- Qualys SSL Labs
 - Exemple de vérification d'un site Web (suite)

Configuration		
	Protocols	
	TLS 1.3	No
	TLS 1.2	Yes
	TLS 1.1	Yes
	TLS 1.0	Yes
	SSL 3	No
	SSL 2	No
For TLS 1.3 tests, we currently support draft version 18.		

- Qualys SSL Labs
 - Exemple de vérification d'un site Web

Cipher Suites		
# TLS 1.2 (suites in server-preferred order)		
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp211r1 (eq. 15360 bits RSA)	FS
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp211r1 (eq. 15360 bits RSA)	FS
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp211r1 (eq. 15360 bits RSA)	FS
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp211r1 (eq. 15360 bits RSA)	FS
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x3d)		256
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x3c)		128
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)		256
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)		256
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)		128
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)		128
TLS_RSA_WITH_3DES_EDE_CBC_SHA (0xa)		112
# TLS 1.1 (suites in server-preferred order)		
# TLS 1.0 (suites in server-preferred order)		

- Qualys SSL Labs
 - Exemple de vérification d'un site Web (suite)

Handshake Simulation		
Android 2.3.7	RSA 2048 (SHA256)	TLS 1.0 TLS_RSA_WITH_AES_128_CBC_SHA No FS
Android 4.0.4	RSA 2048 (SHA256)	TLS 1.0 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 4.1.1	RSA 2048 (SHA256)	TLS 1.0 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 4.2.2	RSA 2048 (SHA256)	TLS 1.0 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 4.3	RSA 2048 (SHA256)	TLS 1.0 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 4.4.2	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 5.0.0	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 6.0	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Android 7.0	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Bandu Jan 2015	RSA 2048 (SHA256)	TLS 1.0 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
BinpReview Jan 2015	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 ECDH secp211r1 FS
Chrome 48 / XP SP3	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Chrome 57 / Win 7	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Firefox 31.3.0 ESR / Win 7	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Firefox 47 / Win 7	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Firefox 49 / XP SP3	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Firefox 53 / Win 7	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
Googlebot Feb 2015	RSA 2048 (SHA256)	TLS 1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS
IE 6 / XP	No FS 1 No FS 2	Server closed connection
IE 7 / Vista	RSA 2048 (SHA256)	TLS 1.0 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA ECDH secp211r1 FS

- **Qualys SSL Labs**
 - Exemple de vérification d'un site Web (suite)

OpenSSL CCS vuln. (CVE-2014-0224)	Unknown (more info)
OpenSSL Padding Oracle vuln. (CVE-2016-2107)	No (more info)
Forward Secrecy	With modern browsers (more info)
ALPN	No
NPN	No
Session resumption (caching)	Yes
Session resumption (tickets)	No
OCSP stapling	Yes
Strict Transport Security (HSTS)	No
HSTS Preloading	Not in: Chrome Edge Firefox IE

- **HTTP Strict Transport Security (HSTS)**
 - **HSTS doit être activé sur le site Web**
 - Permet à un serveur web de signifier au navigateur web compatible, qu'il doit obligatoirement être contacté en HTTPS.
 - **Strict**
 - Si la sécurité de la connexion n'est pas garantie (certificat auto-signé), l'utilisateur ne peut accéder au site.
 - **Liste de pré-préchargement pour les pages HTTPS**
 - Chaque première visite d'un site est vulnérable aux attaques (SSL stripping).
 - HSTS ne fonctionne que si un site Internet a été consulté au moins une fois dans le passé via une connexion HTTPS non manipulée.
 - Les navigateurs populaires utilisent aujourd'hui des listes basées sur un service de pré-chargement pour HSTS.
 - <https://hstspreload.org/>

Quelques outils

- Qualys SSL Labs
 - Exemple de vérification d'un site Web (suite)

	HTTP Requests	
	1 https://www.heh.be/ (HTTP/1.1 200 OK)	
	Miscellaneous	
	Test date	Wed, 09 Aug 2017 18:16:35 UTC
	Test duration	83.588 seconds
	HTTP status code	200
	HTTP server signature	Microsoft-IIS/8.0
	Server hostname	-

Chapitre 7

Haute disponibilité

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Choisir le bon mode de fonctionnement haute disponibilité (HA).
 - Implémenter et configurer une solution HA.
 - Configurer la synchronisation de session pour un basculement en douceur.
 - Utiliser le clustering virtuel pour une haute disponibilité par VDOM.
 - Mettre à niveau le firmware d'un cluster HA.
 - Vérifier le fonctionnement d'un cluster HA.

High Availability (HA)

- Principe de la HA
 - Haute disponibilité
 - La HA relie et synchronise deux ou plusieurs appareils.
 - Un des appareils doit être actif, les autres peuvent être actif ou passif.
 - FortiGate actif
 - Le FortiGate qui traite le trafic.
 - Il synchronise sa configuration avec les autres appareils.
 - FortiGate passif
 - FortiGate qui ne traite pas le trafic.
 - Il synchronise sa configuration sur celle d'un FortiGate primaire pour être prêt à traiter le trafic dans le cas où le primaire a un problème.
 - Heartbeat link
 - Liens (UTP RJ45) reliant tous les appareils participant à la HA.
 - Utilisé pour détecter les appareils qui ne répondent plus.

HEH.be
Sciences
et technologies

Topologie

- Topologie HA

Actif

Heartbeat Link

Actif ou Passif

Si un Sw est utilisé au niveau d'un lien heartbeat, il doit être dédié à cette fonction et isolé du reste du réseau

WALLONIE BRUXELLES
ENSEIGNEMENT

255

HEH.be
Sciences
et technologies

Modes de haute disponibilité

- Mode actif-passif
 - FortiGate primaire
 - Diffuse des paquets Hello pour la découverte et la surveillance.
 - Le FortiGate qui agit en tant qu'appareil primaire synchronise sa configuration avec les autres appareils.
 - Seul le primaire traite le trafic, il est actif.
 - Si le primaire est redémarré ou éteint, il devient un FortiGate secondaire et attend que le trafic soit redirigé vers le nouveau primaire avant de s'éteindre.
 - FortiGate secondaire
 - Diffuse des paquets Hello pour la découverte et la surveillance.
 - Il synchronise sa configuration sur celle d'un FortiGate primaire.
 - Il peut y avoir plusieurs secondaires.
 - Il surveille l'état du primaire (paquet Hello reçu du primaire?).
 - Si le primaire ne « répond » plus, un secondaire reprend le rôle de primaire et traite le trafic.
 - On parle alors de *HA failover* (basculement).

WALLONIE BRUXELLES
ENSEIGNEMENT

256

Modes de haute disponibilité

- **Mode actif-actif**
 - **FortiGate primaire**
 - Il synchronise sa configuration avec les autres appareils.
 - Le primaire traite le trafic, il est actif.
 - Le primaire a la charge d'équilibrer le trafic entre tous les dispositifs du cluster HA.
 - **FortiGate secondaire**
 - Tous les FortiGate secondaires traitent le trafic, ils sont aussi actifs.
 - Ils surveillent l'état du primaire.
 - Si le primaire a un problème, un des secondaires reprend le rôle de primaire.
 - On parle alors de *HA failover* (basculement).

FortiGate Clustering Protocol (FGCP)

- **FGCP**
 - **FGCP fonctionne uniquement sur les liens Heartbeat et est utilisé pour :**
 - Découvrir des FortiGates qui appartiennent au même groupe HA.
 - Élire le primaire.
 - Synchroniser les configurations et d'autres données.
 - Détecter la défaillance d'un FortiGate.
 - **EtherType et ports utilisés**
 - Découverte des membres via diffusion sur les liens heartbeat (En mode NAT, le champ type Ethernet = 0x8890. En mode transparent, EtherType = 0x8891)
 - Si le cluster fonctionne en mode actif-actif, le premier paquet d'une session distribuée au secondaire est encapsulé dans des trames Ethernet de type 8891
 - Pour la synchronisation des données, la gestion locale de la CLI et la journalisation, les membres échangent des Ethernet trames de type 8893 .
 - Selon le type de données à synchroniser, le port TCP 703 ou le port UDP 703, est utilisé pour la synchronisation des données.
 - Le primaire relaie les journaux et les courriels d'alerte des secondaires sur le port TCP 700.

- Conditions requise pour la HA

- De deux à quatre FortiGates avec les mêmes :

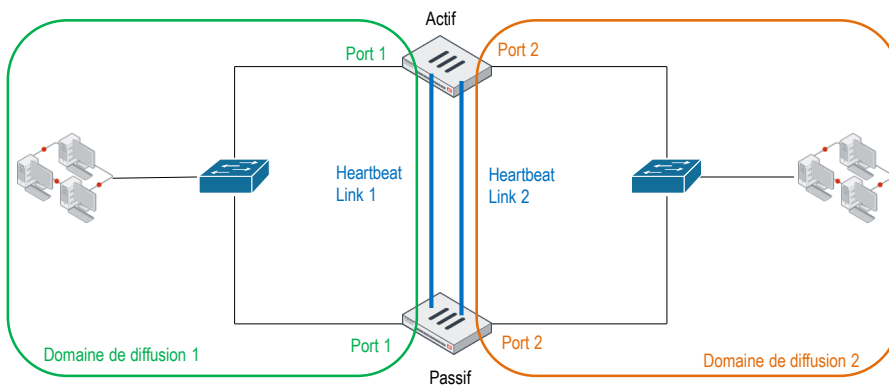
- Firmware.
- Modèle pour le matériel et même licence pour les VM.
- Licenses FortiGuard, FortiCloud, and FortiClient.
- Capacité du disque dur et partitions.
- Mode de fonctionnement (transparent ou NAT) du VDOM de management.

- Au moins une liaison entre les appareils FortiGate

- Pour la communication HA (Heartbeat traffic).
- Pour la redondance, jusqu'à huit interfaces Heartbeat peuvent être utilisées.
 - Si un lien échoue, HA utilisera le suivant, selon la priorité et la position dans la liste des interfaces Heartbeat.

- Mêmes interfaces connectées aux mêmes domaines de diffusion

- Les mêmes interfaces sur chaque appareil FortiGate doivent être connectées au même commutateur ou segment de réseau local (voir diapositive suivante).



• Remarques

– Adressage dynamique

- Depuis FortiOS 5.2, la HA supporte les interfaces dont les adresses IP sont assignées dynamiquement (DHCP ou PPPoE).
- Pour éviter des problèmes d'attribution d'adresses, il est recommandé de
 1. Configurer le cluster avec des IP statiques.
 2. Configurer l'adressage dynamique des interfaces uniquement lorsque le cluster HA est formé.

– Licences différentes

- Si les membres du cluster n'ont pas les mêmes licences, le cluster s'aligne sur la "licence la plus faible".
- Par exemple, si un des FortiGate n'a pas de licence Antivirus, l'ensemble du cluster fonctionnera sans licence antivirus.

• Processus d'élection du FortiGate primaire

a) Avec le paramètre "HA override" désactivé

1. Le cluster compare le nombre d'interfaces monitorées dont le statut est up.
 - Le FortiGate avec le plus grand nombre d'interfaces monitorées disponibles devient le primaire.
 2. Le cluster compare les temps de fonctionnement du système (system uptime).
 - Si le temps de fonctionnement du système d'un appareil est supérieur de cinq minutes au temps de fonctionnement du système des autres FortiGate, il devient le primaire.
 3. Le FortiGate avec la priorité la plus élevée devient le primaire.
 4. Le FortiGate dont le numéro de série est le plus élevé devient le primaire.
- **Modifier le primaire si "HA override" est désactivé**
 - Il est possible de forcer manuellement le basculement (HA failover) en réinitialisant le temps de fonctionnement.

```
# diagnose sys ha reset-uptime
```

Le processus de sélection s'arrête au premier critère permettant d'élire le primaire.

Élection du FortiGate primaire

- Processus d'élection du FortiGate primaire (suite)

- b) Avec le paramètre "HA override" activé

- La priorité est prise en compte avant le temps de fonctionnement du système.
 - Permet de configurer la priorité pour favoriser l'élection d'un FortiGate.
 - Conséquence sur le basculement HA
 - Le basculement se produit lorsque le primaire tombe en panne (cas normal).
 - Se produit aussi lorsque l'ancien primaire redevient disponible (à cause de sa priorité).

- Ordre des critères de sélection

1. Nombre d'interfaces monitorées dont le statut est up.
2. Priorité la plus élevée.
3. System uptime.
4. Numéro de série le plus élevée.

Le processus de sélection s'arrête au premier critère permettant d'élire le primaire

- Modifier le primaire si "HA override" est activé

- Il est possible de forcer manuellement le basculement (HA failover) en modifiant la priorité d'un FortiGate.

Élection du FortiGate primaire

- Remarques

- Synchronisation

- Les paramètres "override" et "priority" ne sont pas synchronisés au sein du cluster, ils doivent être ajustés manuellement sur chaque FortiGate.

- Afficher les temps de fonctionnement des membres du cluster HA

Renseigne la différence de uptime en 1/10ème de seconde.

Ce FGT a un uptime de 781,4 secondes plus grand que l'autre.

```
# diagnose sys ha dump-by vcluster
...
FGVMxxxx92:...uptime/reset_cnt = 7814 / 0
FGVMxxxx36:...uptime/reset_cnt = 0 / 1
```

La valeur 0 indique le FortiGate avec le plus faible uptime

Indique le nombre de fois que l'uptime a été réinitialisé

- **Rôles du primaire**
 - **Découvrir et surveiller les membres du cluster**
 - Échanges de paquets "heartbeat hello" avec tous les secondaires.
 - Permet de découvrir des FortiGates ou vérifier que les FortiGates sont toujours présents dans le cluster HA.
 - **Synchronisation**
 - Le primaire synchronise notamment
 - une partie de sa configuration avec tous les secondaires.
 - sa table de routage (FIB), DHCP leases, ARP table, Ipsec SA.
 - Le primaire peut être configuré pour synchroniser certaines informations de sessions de trafic pour un basculement en douceur. (voir plus loin)
 - **En mode actif-actif**
 - Le primaire répartit le trafic entre tous les périphériques du cluster.

- **Rôles des secondaires**
 - **Surveille le primaire**
 - Surveille les paquets hello du primaire pour déceler des signes de défaillance.
 - Met à jour sa configuration en fonction du primaire.
 - Si un problème est détecté avec le primaire, les secondaires élisent un nouveau primaire et surveillent ce nouveau primaire.
 - **Diffuse des paquets Hello**
 - Pour indiquer sa présence
 - **Traite le trafic distribué par le primaire**
 - En mode actif-actif uniquement.

- Adresses IP des interfaces "Heartbeat"
 - Le cluster assigne automatiquement des IP virtuelles aux interfaces Heartbeat
 - Les adresses sont distribuées en fonction du N° de série de chaque FortiGate
 - 169.254.0.1 : pour le numéro de série le plus élevé.
 - 169.254.0.2 : pour le deuxième numéro de série le plus élevé.
 - 169.254.0.3 : pour le troisième numéro de série le plus élevé
 - Etc.
 - Ces IP sont utilisées pour distinguer les membres du cluster et synchroniser les données
 - Modification de l'adresse IP virtuelle Heartbeat
 - Les FortiGates conservent leurs adresses IP virtuelles Heartbeat
 - Peu importe leur rôle (primaire ou secondaire).
 - Peu importe s'il y a basculement (primaire vers secondaire ou secondaire vers primaire).
 - Les FortiGates changent d'adresses IP virtuelles Heartbeat
 - Uniquement lorsqu'un FortiGate quitte ou rejoint le cluster.
 - Le cluster renégocie alors l'attribution de l'adresse IP Heartbeat en tenant compte du numéro de série de tout nouveau périphérique.

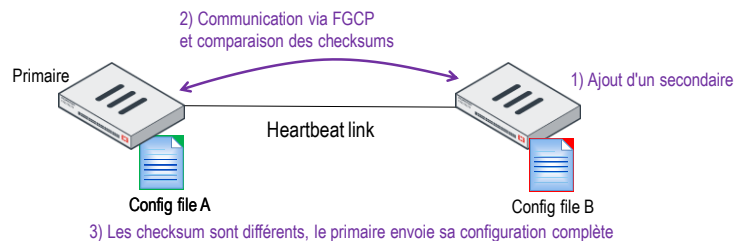
- Les ports "Heartbeat"
 - Le trafic heartbeat est important pour le bon fonctionnement du cluster
 - Il est nécessaire de disposer d'une BP suffisante
 - Permet de garantir que les configurations du cluster sont dans un état synchronisé à tout moment.
 - Si un switch est présent entre deux FortiGates
 - Il doit être dédié et isolé du reste du réseau.
 - Ainsi, FGCP n'est pas concurrencé par d'autres trafics pour l'utilisation de la BP.
 - Interfaces physiques routées requises
 - La communication Heartbeat est activée sur les interfaces physiques routées
 - Pas sur les sous-interfaces VLAN, les interfaces VPN IPsec, les interfaces redondantes, les interfaces agrégées 802.3ad ou les ports "switchés" du FortiGate.

Fonctionnement HA

- **Les ports monitorés**
 - Un cluster HA peut être configuré pour surveiller l'état des liens de certaines interfaces
 - Les ports surveillés sont généralement des interfaces réseaux traitant un trafic hautement prioritaire.
 - Les interfaces physique, VLAN et les LAG peuvent être monitorées.
 - Rappel LAG = Link Aggregation Group (= Etherchannel)
 - **Basculement nécessaire ?**
 - **Éviter de configurer la surveillance pour toutes les interfaces**
 - Vous ne devez configurer la surveillance d'interface que pour les ports dont la défaillance doit déclencher un basculement de périphérique.
 - Notamment, ne surveillez pas les interfaces heartbeat.

Synchronisation des configurations

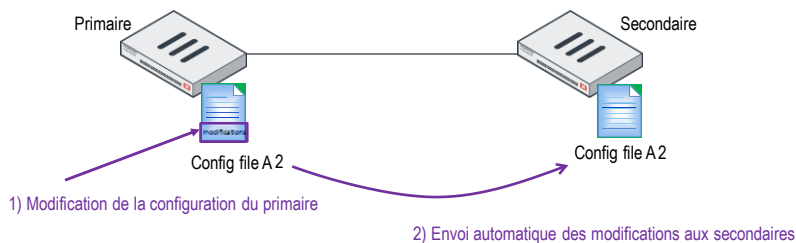
- **Synchronisation complète**
 - 1) Un secondaire est ajouté au cluster.
 - 2) Le primaire compare la somme de contrôle de sa configuration avec celle du secondaire.
 - 3) Si elles sont différentes, le primaire envoie sa configuration au secondaire.



Synchronisation des configurations

• Synchronisation incrémentale

- Est utilisée lorsque la synchronisation initiale (complète) est terminée.
- Le primaire enverra tout changement de configuration à tous les secondaires.
 - Seules les modifications sont envoyées.



Synchronisation des configurations

• Caractéristiques de la synchronisation incrémentale

– Quelles informations sont synchronisées ?

- Les configurations mais aussi d'autres données telles que la table de routage, les baux DHCP, les SA IPsec, les tables ARP, ...
- Les sessions peuvent être synchronisées (désactivé par défaut).

– Vérifications périodiques

- **Par défaut, le primaire vérifie toutes les 60 secondes que tous les périphériques sont synchronisés**
 - Si l'un des secondaires n'est pas synchronisé, le checksum des secondaires est vérifié toutes les 15 secondes.
 - Si le checksum ne correspond pas pour cinq contrôles consécutifs, une re-synchronisation complète est effectuée.

- Session Synchronization

- La synchronisation des sessions permet un basculement en douceur

- Les informations de sessions étant synchronisées, les sessions peuvent rester ouvertes.
 - Le nouveau primaire peut prendre le relais là où les sessions en étaient arrivées.
 - Le trafic peut être interrompu pendant un court instant lors du basculement
 - Cependant, les applications n'ont pas besoin de reconnecter les sessions à nouveau.

- Uniquement possible pour certains types de trafic

- Les sessions TCP et IPsec VPN qui ne sont pas traitées par une inspection en mode proxy
 - Exception : les sessions SIP peuvent être synchronisées même en mode proxy.
 - La commande `set session-pickup` permet d'activer la synchronisation des sessions TCP

```
config system ha
  set session-pickup enable
end
```

- Session Synchronization (suite)

- Il est possible d'activer la synchronisation des sessions UDP et ICMP

- Bien que les deux protocoles soient sans session
 - Des entrées sont créées dans la table de session FortiGate pour chaque flux de trafic UDP et ICMP.
 - Généralement pas nécessaire
 - La plupart des applications réseau basées sur UDP ou ICMP sont capables de garder la communication même lorsque leurs informations de session sont perdues.

```
config system ha
  set session-pickup enable
  set session-pickup-connectionless enable
end
```

Synchronisation des configurations

- **Éléments non synchronisés**
 - Tous les paramètres de configuration ne sont pas synchronisés, c'est notamment de cas :
 - Des paramètres de l'interface de gestion du HA.
 - Du paramètre "HA override".
 - De la priorité HA du FortiGate.
 - De la priorité du cluster virtuel HA.
 - Du nom d'hôte.
 - Des licences.
 - Les licences et FortiToken (numéros de series) sont synchronisés.
 - Des caches (Filtrage Web, Email, ...).
 - Des priorités HA du "ping server" (permettant la détection de passerelles en panne).
 - Les widgets du dashboard.

Failover

- **Causes de basculement**
 - **Device failover (Membre mort)**
 - Le basculement est déclenché lorsque le FortiGate primaire cesse d'envoyer des paquets Hello (trafic heartbeat).
 - **Failed link (Liaison défaillante)**
 - Le basculement est déclenché lorsque l'état d'une interface surveillée sur le FortiGate primaire tombe en panne.
 - Seules les interfaces physique, redondante et LAG peuvent être surveillées.
 - **Failed remote link (Lien distant défaillant)**
 - Le FortiGate utilise la fonction de surveillance de l'état des liens (Link Health Monitor) pour surveiller l'état d'une ou de plusieurs interfaces.
 - Le FortiGate primaire est considéré comme défaillant si la pénalité cumulée de toutes les interfaces défaillantes atteint le seuil fixé.

Surveiller une interface :

```
config system ha
  set monitor <interface1> <interface2> ...
end
```


• Causes de basculement (suite)

– Memory-based (Basé sur l'utilisation de la mémoire)

- Un seuil d'utilisation de la mémoire peut être configuré. Lorsque ce seuil est dépassé pendant le laps de temps défini, il y a basculement.

– Failed SSD (SSD défaillant)

- Le basculement est déclenché lorsque FortiOS détecte une défaillance ou des erreurs dans le système de fichiers d'un SSD.
- Uniquement disponible pour les appareils équipés de disques SSD.

– Admin-triggered (déclenché par l'administrateur)

- Le basculement est déclenché manuellement par l'administrateur.

– Remarque

- Lorsqu'un basculement se produit, un fichier journal est généré.
- Le Fortigate peut également générer un trap SNMP et un email d'alerte.

Activer le memory-based failover :

```
config system ha
  set ssd-failover enable
end
```



277

• Causes de basculement et de journalisation

– Device failover (dead member)

- Ce type de basculement est toujours actif.
- Réduire les valeurs accélère le basculement
- Augmentez les valeurs réduit les faux positifs.

```
config system ha
  set hb-interval <1 - 20>
  set hb-interval-in-milliseconds 100ms | 10ms
  set hb-lost-threshold <1 - 60>
end
```

Réduire les valeurs accélère le basculement

Augmentez les valeurs réduit les faux positifs.

Nombre d'échecs de réception de paquets Hello avant que l'appareil ne soit considéré comme mort

Temps entre deux envois de Hello (nombre entier fois 100ms) ou intervalle fixé à 10 ou 100ms



278

- Causes de basculement et de journalisation

- Remote link failover (Failed link)

- Configurer le Link Health Monitor (voir chapitre sur le routage)

```
config system link-monitor
  edit "port1-ha"
    set srcintf "port1"
    set server "4.2.2.1" "4.2.2.2"
    set ha-priority 10
```

Pénalité à affecter si le lien est défaillant

- Configurer les paramètres HA relatifs à la défaillance de lien

Active le remote
link failover sur port1

```
config system ha
  set pingserver-monitor-interface port1
  set pingserver-failover-threshold 5
  set pingserver-secondary-force-reset enable
  set pingserver-flip-timeout 30
end
```

Seuil de pénalité déclenchant
un basculement

Pas d'élection de nouveau primaire avant le flip-timeout (30 min.)
Impose l'élection d'un nouveau primaire à l'expiration du flip-timeout.

- Causes de basculement et de journalisation

- Memory-based failover (Utilisation élevée de la mémoire)

- Un seuil d'utilisation de la mémoire peut être configuré. Lorsque ce seuil est dépassé pendant le laps de temps défini, il y a basculement.

```
config system ha
  set memory-based-failover enable
  set memory-failover-threshold 70
  set memory-failover-monitor-period 30
  set memory-failover-sample-rate 2
  set memory-failover-flip-timeout 20
end
```

Basculement lorsque l'utilisation de la mémoire
dépasse 70% pendant 30 secondes

Vérification du pourcentage de mémoire
utilisée toutes les 2 secondes

- Adresses MAC virtuelles et basculement
 - Pour transférer le trafic, la HA utilise des adresses MAC virtuelles
 - **Assignment automatique d'une adresse MAC virtuelle**
 - Lorsqu'un primaire rejoint un cluster HA, une adresse MAC virtuelle est assignée à chacune de ses interfaces (hormis les interfaces heartbeat).
 - **Le primaire informe tous les secondaires de l'adresse MAC virtuelle assignée**
 - Via les liens heartbeat.
 - En cas de basculement
 - **L'adresse MAC virtuelle du FortiGate actif ne change pas**
 - Lors du basculement, le secondaire qui devient le nouveau primaire adopte les mêmes adresses MAC virtuelles que l'ancien primaire pour les interfaces équivalentes.
 - **Le nouveau primaire informe tous les secondaires**
 - Après le basculement, le nouveau primaire informe, via des paquets gratuits ARP, que chaque adresse MAC virtuelle est désormais accessible via un autre chemin.

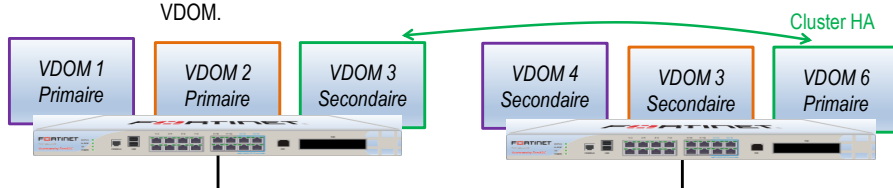
- Panne d'un secondaire
 - Dans un cluster actif-passif
 - Le primaire met à jour la liste des FortiGate secondaires disponibles.
 - Le primaire surveille le secondaire défaillant en attendant qu'il soit de nouveau opérationnel.
 - Dans un cluster actif-actif
 - **Tous les secondaires gèrent aussi le trafic**
 - Le primaire suit et assigne des sessions à chaque secondaire.
 - **En cas de défaillance d'un secondaire**
 - Le primaire doit également réassigner les sessions du FortiGate défaillant à un autre FortiGate secondaire.
 - Le primaire surveille le secondaire défaillant en attendant qu'il soit de nouveau opérationnel.

Active-Active Load Balancing

- Répartition de la charge en mode actif – actif
 - Le client envoie un paquet SYN au FortiGate primaire
 - Il utilise l'adresse MAC virtuelle de l'interface interne comme destination.
 - Le primaire décide si la session sera traitée par un secondaire
 - Si oui, il transmet le paquet SYN au secondaire qui effectuera les inspections.
 - Le primaire utilise l'adresse MAC physique du FortiGate secondaire comme adresse de destination.
 - Par défaut, seule les session en mode proxy sont envoyées à un secondaire.
 - L'option `load-balance-all` permet de distribuer n'importe quelle session.
 - Le secondaire traite la session
 - Le secondaire répond avec un SYN/ACK au client.
 - Le secondaire démarre la connexion avec le serveur (auquel le client souhaite se connecter) en lui envoyant directement un paquet SYN.

Virtual clustering

- Virtual clustering
 - Multiples VDOM
 - Lorsque plusieurs VDOM sont utilisés, il est possible de configurer des clusters virtuels.
 - Répartition de charge
 - Chaque FortiGate peut agir à la fois comme primaire pour un VDOM d'un cluster et comme secondaire pour un autre VDOM d'un autre cluster.
 - De cette manière, la charge de trafic est répartie entre les FortiGate des clusters.
 - Limitation
 - Le clustering virtuel est réalisable uniquement entre deux FortiGate ayant plusieurs VDOM.



Full mesh HA

- Full mesh HA

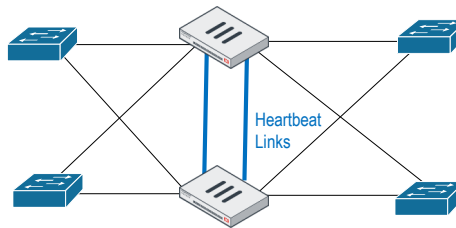
- Haute disponibilité avec maillage complet

- Topologie plus robuste

- Offre une tolérance aux pannes au niveau des commutateurs, des FortiGate et des interfaces des FortiGate (Pas de Single point of failure).

Redondance :

- Des fortigates
- Des switches
- Des interfaces
- Des liens



- Limitation

- Uniquement disponible sur le matériel haut de gamme.

Mise à jour d'un cluster

- Firmware updates (GUI ou CLI)

- Procédure identique à la mäj d'un FortiGate seul

- Charger le nouveau firmware sur le primaire.
 - Comme pour une mise à jour classique, chaque FortiGate devra redémarrer.

- Processus de mise à jour (Uninterruptable upgrade)

1. Le primaire envoie le firmware à tous les secondaires.
2. Le paramètre "Uninterruptable upgrade" est activé par défaut, cela implique que le cluster mettra d'abord à niveau les FortiGate secondaires.
3. Le premier secondaire à finir la mise à jour devient primaire
4. Le firmware de l'ancien primaire est mis à niveau.

- Cluster en mode actif - actif

- L'équilibrage de la charge de trafic est temporairement désactivé pendant que tous les périphériques mettent à jour leur firmware.

Mise à jour d'un cluster

- Firmware updates (GUI ou CLI) (suite)

- Cluster en mode actif - actif

- L'équilibrage de la charge de trafic est temporairement désactivé pendant que tous les périphériques mettent à jour leur firmware.

- Autres options de mise à jour

- **Simultaneous**

- Met à jour tous les FortiGate en même temps.

- **Local-only**

- Met à jour uniquement ce FortiGate.

- **Secondary-only**

- Met à jour uniquement les FortiGate secondaires.

Permet de mieux contrôler quel FortiGate est mis à jour et à quel moment.

```
config system ha
  set upgrade-mode simultaneous | uninterruptible | local-only | secondary-only
end
```

Mise à jour d'un cluster

- Se connecter à un membre du cluster

- Via l'adresse IP virtuelle du cluster HA

- Dans ce cas, vous vous connectez toujours au FortiGate primaire.

- Via une interface réseau (In-band HA management interface)

- Permet d'utiliser n'importe quelle interface

```
config system interface
  edit "port1"
    set management-ip 10.0.10.1 255.0.0.0
    set allowaccess ping https ssh snmp
```

- Configurer une interface réservée pour l'administration HA (Out-of-band)

- Consiste à utiliser une interface dédiée à l'administration du cluster (pas d'autres trafic via cette interface).

```
config system ha
  set ha-mgmt-status enable
  config ha-mgmt-interfaces
    edit 1
      set interface "port10"
      set gateway 192.168.100.254
```

- Vérifier le statut du cluster HA en GUI

Clic droit sur le menu permet d'ajouter d'autres colonnes

System > HA

Rôle dans le cluster HA

Status	Priority	Hostname	Serial No.	Role	Uptime	Sessions	Throughput
Synchronized	200	Local-FortiGate	FGVM010000064692	Primary	3d 23h	11	22.00 kbps
Synchronized	100	Remote-FortiGate	FGVM010000065036	Secondary	0s	5	17.00 kbps

Affichage de tous les Fortigates dans le cluster

Clic droit permet de déconnecter du cluster

- Vérifier le statut du cluster HA en GUI (suite)

— Un widget peut être ajouté dans le dashboard pour connaître l'état du cluster

HA Status	
Mode	Active-Active
Group	Training
Primary	Local-FortiGate
Secondary	Remote-FortiGate
Uptime	03:23:55:59
State Changed	03:23:54:10

- Vérifier le statut du cluster HA en CLI
 - Permet d'obtenir plus d'informations qu'en GUI

```
# diagnose system ha status
HA Health Status: OK
Model: FortiGate-VM64-KVM
Mode: HA A-P → Mode A-P (Actif-Passif)
Group: 210
Debug: 0
Cluster Uptime: 2 days 21:28:23
Cluster state change time: 2022-04-20 18:28:23 → Dans cet exemple, SN1 remplace le N° de série
Primary selected using:
<2022/04/20 18:28:23> vcluster-1: SN1 is selected as the primary because its uptime
is larger than peer member SN2.
<2022/04/20 16:13:49> vcluster-1: SN2 is selected as the primary because its uptime
is larger than peer member SN1.
ses_pickup: enable, ses_pickup_delay=disable
overRide: disable
Configuration Status:
  SN1(updated 4 seconds ago): in-sync
  SN2(updated 4 seconds ago): in-sync

System Usage stats:
  SN1(updated 4 seconds ago):
    sessions=17, average-cpu-user/nice/system/idle=0%/0%/0%/100%, memory=57%
  SN2(updated 4 seconds ago):
    sessions=1, average-cpu-user/nice/system/idle=0%/0%/0%/100%, memory=56%
<suite diapositive suivante>
```

```
# suite de la commande "diagnose system ha status"
HBDEV stats:
  SN1(updated 4 seconds ago):
    port9: physical/10000full, up, rx-bytes/packets/dropped/errors=154684218/384596/0/0,
    tx=352015560/498020/0/0
  SN2(updated 4 seconds ago):
    port9: physical/10000full, up, rx-bytes/packets/dropped/errors=386075683/578563/0/0,
    tx=269160874/516602/0/0
MONDEV stats:
  SN1(updated 4 seconds ago):
    port1: physical/10000full, up, rx-bytes/packets/dropped/errors=238546316/964449/0/0,
    tx=13209070/157763/0/0
  SN2(updated 4 seconds ago):
    port1: physical/10000full, up, rx-bytes/packets/dropped/errors=214804265/993451/0/0,
    tx=6345393/37126/0/0
PINGSVR stats:
  SN1(updated 4 seconds ago):
    port1: physical/10000full, up, rx-bytes/packets/dropped/errors=238546316/964449/0/0,
    tx=13209070/157763/0/0
    pingsvr: state=up(since 2022/04/20 16:13:50), server=10.9.15.40, ha_prio=5
  SN2(updated 4 seconds ago):
    port1: physical/10000full, up, rx-bytes/packets/dropped/errors=214804265/993451/0/0,
    tx=6345393/37126/0/0
    pingsvr: state=N/A(since 2022/04/20 16:13:54), server=10.9.15.40, ha_prio=5

Primary   : Local-FortiGate, SN1, HA cluster index = 0
Secondary : Remote-FortiGate, SN2, HA cluster index = 1
number of vcluster: 1
vcluster 1: work 169.254.0.1
Primary: SN1, HA operating index = 0
Secondary: SN2, HA operating index = 1
```

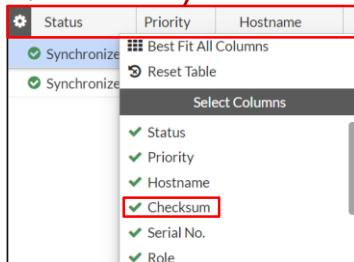
Statut des interfaces heartbeat (HBDEV),
monitorées (MONDEV) et surveillées (PINGSRV)

Rôle des membres, noms d'hôte,
numéro de série, et ID.

- Vérifier l'état de la synchronisation de la configuration

Clic droit sur l'en-tête des colonnes et sélectionnez la colonne Checksum.
 Vous pouvez alors comparer les checksum.

System > HA



Status	Priority	Hostname	Checksum	Role
✓ Synchronized	200	Local-FortiGate	9da6935ad11a1093675bf5f72a4b33d	Primary
✗ Not Synchronized	100	Remote-FortiGate	cbf3d163ffa8363a738c90d8486582ed	Secondary

Status	Priority	Hostname	Checksum	Role
✓ Synchronized	200	Local-FortiGate	cfb4f9c0ac340d93f60306a66093596e	Primary
✓ Synchronized	100	Remote-FortiGate	cfb4f9c0ac340d93f60306a66093596e	Secondary

- Si les checksum ne correspondent pas, essayez de les faire recalculer :

```
# diagnose sys ha checksum recalculate
```

- Vérifier l'état de la synchronisation de la configuration
 - Si le primaire et le secondaire présentent les mêmes checksum, ils sont synchronisés.

```
# diagnose sys ha checksum cluster
```

```
===== FGVM010000112065 =====

is_manage_master()=1, is_root_master()=1
debugzone
global: 7b 05 62 17 8f cd 76 29 57 da 32 8e
root: 97 91 80 67 9d 97 e3 a1 dd 0d ca
all: e1 ad dd fb ff f6 e5 55 2c ed 3b

checksum
global: 7b 05 62 17 8f cd 76 29 57 da 32 8e
root: 97 91 80 67 9d 97 e3 a1 dd 0d ca
all: e1 ad dd fb ff f6 e5 55 2c ed 3b
```

```
# diagnose sys ha checksum cluster
```

```
===== FGVM010000065036 =====

is_manage_master()=0, is_root_master()=0
debugzone
global: 7b 05 62 17 8f cd 76 29 57 da 32 8e
root: 97 91 80 67 9d 97 e3 a1 dd 0d ca
all: e1 ad dd fb ff f6 e5 55 2c ed 3b

checksum
global: 7b 05 62 17 8f cd 76 29 57 da 32 8e
root: 97 91 80 67 9d 97 e3 a1 dd 0d ca
all: e1 ad dd fb ff f6 e5 55 2c ed 3b
```

- Si les checksum ne correspondent pas, essayez de les faire recalculer :

```
# diagnose sys ha checksum recalculate
```

- Se connecter à un membre du cluster en CLI

- La CLI d'un membre permet de se connecter à un autre membre

```
# execute ha manage <HA_device_index> <Admin_Username>
```

- Le point d'interrogation permet de lister les numéros d'index de chaque FortiGate.

```
# execute ha manage ?
<id>      please input peer box index.
<l>       Subsidiary unit FGVM0100000xxxxx
```

- Afficher ou recalculer les checksum

```
# diagnose sys ha checksum
cluster      Show HA cluster checksum
show         Show HA checksum of logged
              in FortiGate
recalculate  Re-calculate HA checksum
```

- Vérifier l'état de la synchronisation de la configuration

Checksum de la configuration globale

Checksum de la configuration du
VDOM racine

Checksum de la configuration globale + toutes les
sommées de contrôle des VDOM

```
# diagnose sys ha checksum cluster
===== FGVM010000030273 =====

is_manage_master()=1, is_root_master()=1
debugzone
global: a4 f7 cf 90 21 b2 c7 51 72 ca 13 dc 6f 1c b1 9f
root: 7c 52 f6 c7 28 d4 e7 34 7d fa 86 48 42 c1 17 7d
all: 59 4c e3 6b c6 1d b1 c7 e3 42 97 cf 05 13 0c 42

checksum
global: a4 f7 cf 90 21 b2 c7 51 72 ca 13 dc 6f 1c b1 9f
root: 7c 52 f6 c7 28 d4 e7 34 7d fa 86 48 42 c1 17 7d
all: 59 4c e3 6b c6 1d b1 c7 e3 42 97 cf 05 13 0c 42
```

- Interfaces de management d'un cluster HA
 - Réserver une interface dédiée pour la gestion du cluster
 - Il est possible de réserver une interface physique de gestion différente pour chaque appareil.
 - Permet de se connecter en CLI et GUI directement à chaque FortiGate du cluster sans devoir se connecter via le primaire.
 - Permet que chaque appareil envoie ses logs et son trafic SNMP indépendamment.
 - La configuration de cette interface de gestion n'est pas synchronisée.
 - Fonction disponible en mode NAT et en mode transparent.
 - Interface de gestion "In-band"
 - Permet de se connecter directement à chaque FortiGate du cluster sans devoir se connecter via le primaire et sans devoir réserver une interface de gestion.

```
config system interface
  edit <port name>
    set management-ip <IP address and subnet mask>
```

Chapitre 8

Fortinet Single Sign On

FSSO

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Définir la notion de *Fortinet Single Sign On* (FSSO)
 - Expliquer les différentes méthodes FSSO.
 - Configurer un FortiGate pour FSSO.
 - Dépanner des problèmes liés au FSSO.

SSO

- **Single Sign-On (SSO)**
 - **Authentification unique**
 - Après avoir été identifiés une première fois, les utilisateurs peuvent accéder à diverses ressources du réseau :
 - Sans avoir à saisir à nouveau leurs identifiants.
 - Indépendamment de la plate-forme, de la technologie ou du domaine.
 - **La première authentification se fait auprès d'un serveur d'authentification**
 - **Annuaire**
 - Active Directory ou NTLM pour les réseaux Microsoft.
 - eDirectory pour les réseaux Novell.
 - **Serveur AAA**
 - Serveur RADIUS.
 - FortiAuthenticator est un serveur AAA qui comprend un serveur RADIUS, un serveur LDAP et peut remplacer l'agent de collecte FSSO sur un réseau Windows AD.

- Fortinet Single Sign-On agents
 - Agent logiciel Fortinet utilisé pour faire du SSO
 - Logiciel à installer sur certains serveurs de la topologie.
 - Permet à un FortiGate de récupérer les identifiants des utilisateurs de manière passive.
 - Sans leur demander directement leurs identifiants via un prompt.
 - Quel agent faut-il installer et où?
 - Le mode de déploiement du SSO et (le ou) les agents à installer et dépendent du type de serveur d'authentification.
- Mode de déploiement du SSO avec Novell eDirectory
 - eDirectory agent mode
 - Fonctionne sensiblement comme l'agent collecteur sur un DC Windows AD.

- Les modes de déploiement du SSO avec Windows AD
 1. Domain Controller agent mode
 - Nécessite un agent (*DC agent*) sur chaque contrôleur du domaine ainsi qu'au moins un agent collecteur.
 - Nécessite un redémarrage après l'installation des agents.
 2. Polling mode
 - Ce mode permet le SSO lorsqu'il n'est pas possible d'installer un agent sur les DC.
 - Ce mode génère plus de trafic.
 - Deux options :
 - **Soit avec un agent collecteur** (Collector agent) installé sur un serveur du domaine.
 - **Soit sans agent** (agentless).
 3. Terminal Server agent mode
 - Utilise un agent collecteur (TS agent) ou un Fortiauthenticator.
 - Utilisé exclusivement pour les environnements Citrix et Terminal Services.

FSSO avec Active Directory

• Domain Controller agent mode

– DC agent

- **Nécessite un agent (DC agent) installé sur chaque contrôleur du domaine**
 - Sous forme de dll dans Windows\system32\dcagent.dll
 - Un redémarrage est nécessaire après l'installation de l'agent.
- **L'agent DC surveille les connexion des utilisateurs sur le DC**
 - L'agent DC envoie les informations de connexion à l'agent collecteur.
 - Effectue les résolutions DNS pour connaître les IP des utilisateurs.

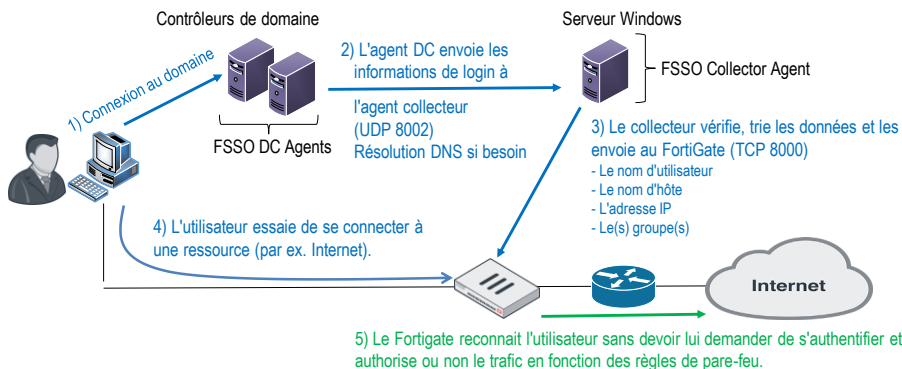
– Collector agent

- Nécessite au moins un agent collecteur sur un serveur Windows membre du domaine.
- L'agent collecteur est chargé de :
 - Vérifier les groupes d'utilisateurs.
 - Vérifier les stations de travail (workstation check).
 - » Refait les résolutions DNS au cas où des IP auraient changé.
 - Envoyer les informations de connexion mises à jour vers les FortiGates.

FSSO avec Windows AD

• Principe du "DC Agent Mode"

– Le mode avec agent DC est le mode le plus évolutif



- **Collector Agent-based Polling Mode**
 - **Collector agent**
 - **Nécessite au moins un agent collecteur**
 - Sur un serveur Windows membre du domaine.
 - **Aucun agent DC n'est requis**
 - Pas besoin de redémarrer les DC.
 - Pas besoin de maintenir à jour les agents DC.
 - **Polling**
 - **L'agent collecteur questionne chaque DC régulièrement sur les événements de connexion**
 - Génère du trafic (parfois inutile si aucun utilisateur ne se connecte)
 - Par défaut via SMB (TCP 445)
 - Sinon via TCP 135, TCP 139, and UDP 137
 - **Trois méthodes de polling**
 - WMI, WinSecLog, NetAPI

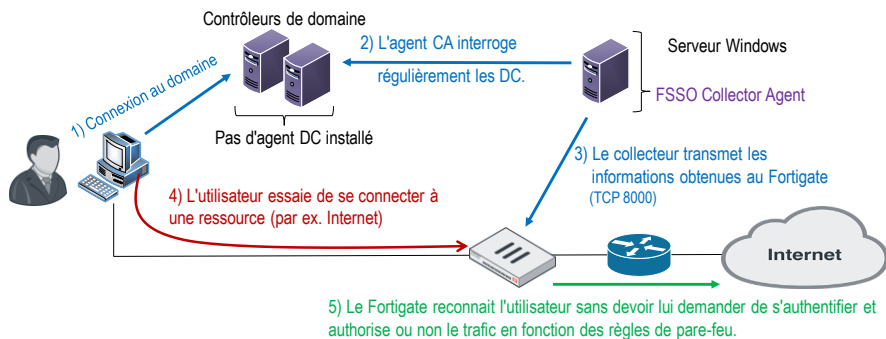
- **Event log polling using WMI**
 - **Windows Management Instrumentation (WMI)**
 - **WMI est une API Windows**
 - Permet d'obtenir des informations système d'un serveur Windows.
 - L'agent collecteur joue le rôle de client WMI et envoie des requêtes au DC qui agit en tant que Serveur WMI.
 - **Caractéristiques**
 - **Ne renvoie que les événements de connexion demandés**
 - Utilisation de BP optimisée entre l'agent collecteur et le DC.
 - Le collecteur ne doit pas rechercher les événements de connexion parmi tous les logs.
 - Le journal des événements (Event Log) doit être activé.

- **Event log polling (WinSecLog)**
 - Le collecteur interroge le journal des événements des DC
 - Le journal des événements (Event Log) doit donc être activé.
 - **Caractéristiques**
 - **Méthode plus lente**
 - Car il faut aller lire des journaux d'événements plutôt que des tables en RAM.
 - **Aucun événement de connexion n'est manqué, même en cas de forte charge.**
 - Car les logs ne sont généralement pas supprimés (rapidement).
 - **Latence possible**
 - Attention dans les grands réseaux ou en cas de lenteurs des systèmes.
 - Nécessite des liens réseau rapides.
 - **Méthode requise pour les clients Mac OS qui se connectent à l'AD**

- **NetAPI polling**
 - Le collecteur interroge la fonction `NetSessionEnum`
 - Le collecteur récupère les informations de sessions établies sur un serveur DC via des requêtes envoyées à la fonction Windows `NetSessionEnum`.
 - **Caractéristiques**
 - Méthode la plus rapide.
 - Interroge la table des sessions en RAM
 - Les sessions peuvent être rapidement créées et purgées de la RAM, avant que l'agent n'ait la possibilité d'interroger et de notifier les firewalls.
 - Il est donc possible de rater certaines ouvertures de sessions utilisateur en cas de forte charge du serveur AD ou du réseau.

FSSO avec Windows AD

- Principe du "Collector Agent-based Polling Mode"
 - Le collecteur doit régulièrement envoyer des requêtes au DC
 - Pour connaître les événements de connexion (login events).



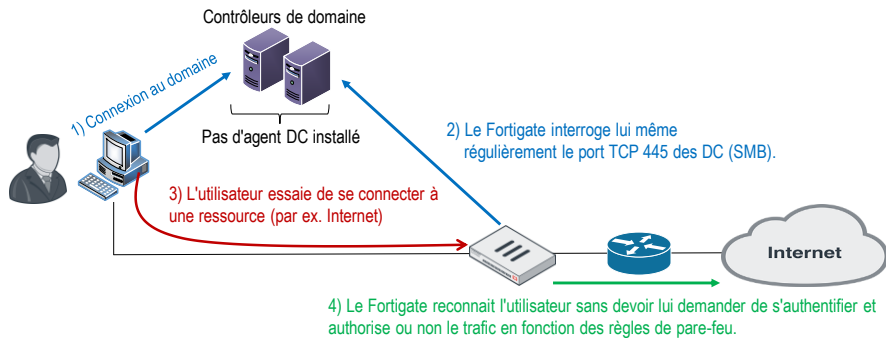
FSSO avec Windows AD

- Agentless polling mode
 - Le Fortigate envoie lui-même les requêtes au DC
 - Aucun agent n'est utilisé (ni DC ni collector).
 - Le Fortigate interroge directement les logs des DC (WinSecLog) via SMB.
 - Le FortiGate SMB pour lire les journaux de l'observateur d'événements.
 - Caractéristiques
 - **Event log doit être activé**
 - Le Fortigate interroge le journal des événements du DC, celui-ci doit donc être activé.
 - **Consomme les ressources du pare-feu**
 - Le Fortigate nécessite des ressources système (CPU, RAM) plus importantes car il collecte et traite toutes les données lui-même.
 - **Certaines fonctionnalités ne sont pas disponibles**
 - Notamment la vérification des stations de travail (workstation check).

- Principe du "Agentless Polling Mode"

- N'utilise aucun agent

- Le Fortigate contacte lui-même les DC pour collecter les informations.



- Remarques (Quelle que soit la méthode)

- Serveur DNS nécessaire

- **Event log fourni le nom d'hôte mais pas l'IP**
 - Les événements de connexion permettent d'obtenir le nom d'utilisateur et le nom de la station de travail mais pas l'adresse IP.
 - **Il est nécessaire de disposer de son propre serveur DNS**
 - Car si l'adresse IP d'un poste de travail change, les enregistrements DNS doivent être mis à jour immédiatement.

- Connectivité avec les postes de travail

- **La déconnexion d'un utilisateur ne génère pas d'entrée dans le journal des événements**
 - Chaque poste de travail utilisateur doit donc être régulièrement interrogé pour voir s'ils sont toujours là.
 - **Les agents collecteurs doivent donc pouvoir contacter les postes de travail**
 - Les ports TCP 139 et 445 doivent être ouverts entre les agents collecteurs/FortiGate et tous les hôtes.
 - "Remote registry service" doit s'exécuter sur chaque poste de travail.

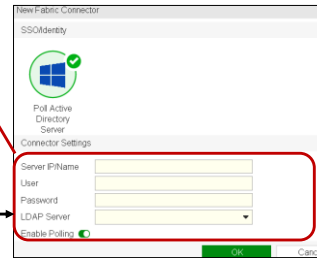
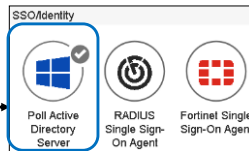
Configuration FSSO

- Agentless polling mode

Security Fabric > Fabric Connectors > Create new



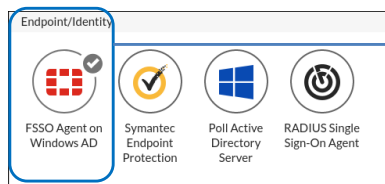
Compléter l'adresse IP et les identifiants "administrateur" du DC



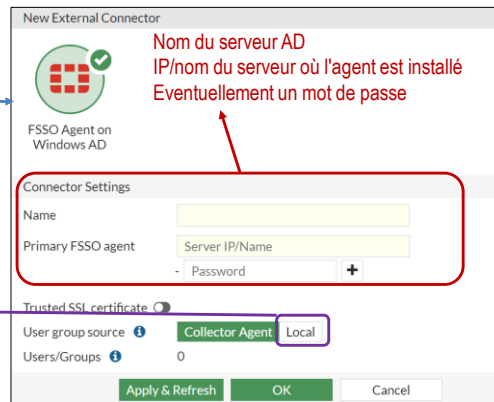
Configuration FSSO

- Collector agent polling mode and DC agent mode

Security Fabric > External Connectors



Nom du serveur AD
 IP/nom du serveur où l'agent est installé
 Eventuellement un mot de passe



En mode Local, les filtres de groupe sont configurés directement sur le FortiGate.



Configuration FSSO

- Installation des agents FSSO
 - A télécharger sur <https://support.fortinet.com>
 - Les versions des agent DC et collector doivent correspondre.

Name
DCAgent_Setup_5.0.0250.exe
DCAgent_Setup_5.0.0250.msi
DCAgent_Setup_5.0.0250_x64.exe
DCAgent_Setup_5.0.0250_x64.msi
FSSO_Setup_5.0.0250.exe
FSSO_Setup_5.0.0250_x64.exe
FSSO_Setup_edirectory_5.0.0250.exe
FSSOV500Md5_build0250.sum
TSAgent_Setup_5.0.0250.exe
TSAgent_Setup_5.0.0250.msi

Image File Path
/ FortiGate/ v5.00/ 5.4/ 5.4.1/

Image Folders/Files
Up to higher level directory

Name
FSSO

Configuration FSSO

- Installation des agents "DC"
 1. Entrer l'IP/port de l'agent collecteur.
 2. Sélectionner le domaine à surveiller

Fortinet Single Sign On Agent - Install DC Agent

Welcome to the DC Agent installation wizard. This wizard will install DC Agent on the Domain Controllers in your domain.

First please confirm the Collector Agent address and listening port.

Collector Agent

Collector Agent IP address: 10.0.1.10

Collector Agent listening port: 8002

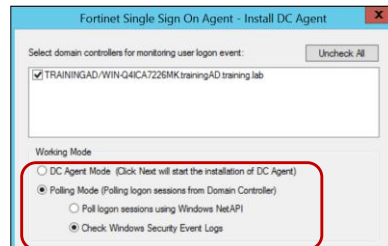
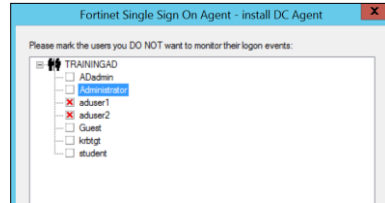
Fortinet Single Sign On Agent - Install DC Agent

Please select the domain(s) you want to monitor:

TRAININGAD trainingad training lab

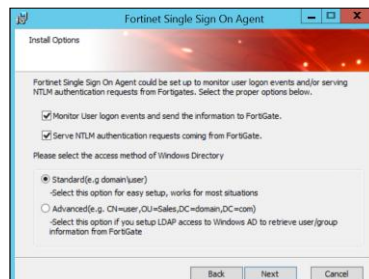
Configuration FSSO

- Installation des agents "DC"
 3. (Optionnel) Sélectionner les utilisateurs à ne pas surveiller.
 4. Sélectionner les DC sur lesquels installer l'agent. Au moins un DC doit être sélectionné.
Le mode polling n'installera pas d'agent DC.
Redémarrer le serveur.



Configuration FSSO

- Installation des agents "collector"
 1. Exécuter en tant qu'admin.
 2. Compléter le nom d'utilisateur
 - DomainName\UserName
 3. Sélectionner quels événements le collecteur doit surveiller
 - "User login events"
 - "NTLM authentication"
 4. Sélectionner la méthode d'accès
 - Standard / advanced



Configuration FSSO

• Configuration des agents collecteur

The screenshot shows the 'Fortinet Single Sign-On Agent Configuration' window. Annotations with arrows point to specific settings:

- Ports d'écoute par défaut du Fortigate et de l'agent DC:** Points to the 'Listening ports' section where 'FortiGate: 8000' and 'DC Agent: 8002' are listed.
- Activer le monitoring des événements de connexion des utilisateurs:** Points to the checked checkbox for 'Monitoring user login events'.
- Activer ou désactiver l'authentification NTLM:** Points to the checked checkbox for 'Support NTLM authentication'.
- Configuration des logs (voir plus loin):** Points to the 'Logging' section, which includes 'Log level: Warning', 'Log file size limit(MB): 10', and a 'View Log' button.
- Activer l'authentification entre FortiGate et l'agent collecteur:** Points to the checked checkbox for 'Require authenticated connection from FortiGate'.
- Configuration des minuteurs:** Points to the 'Times' section, which includes 'Workstation verify interval (minutes): 5', 'Dead entry timeout interval (minutes): 480', 'IP address change verify interval (seconds): 60', and a 'Clear Group Cache' button.

On the right side of the window, the 'Collector Agent Status' is 'RUNNING' and there are several 'Common Tasks' buttons like 'Show Service Status', 'Show Monitored DCs', etc.

Configuration FSSO

• Configuration des minuteurs (collecteur)

– Workstation verify interval

- Intervalle de temps entre deux vérifications (si un utilisateur est toujours connecté).
- Par défaut : 5 minutes.
- Désactivation : régler la valeur sur 0.
- Le statut de l'utilisateur devient "not verified" si le collecteur ne peut pas se connecter au poste de travail pour faire la vérification

– IP address change verify interval

- Vérifie les IP et met à jour le FortiGate lorsque les adresses IP des utilisateurs changent (Environnement DHCP).
 - Le serveur DNS doit mettre à jour rapidement les modifications d'IP en cas de modification d'IP.
- Par défaut = 60 secondes.

Configuration FSSO

- Configuration des minuteurs (collecteur) (suite)

- Dead entry timeout

- Si le statut est *not verified*, ce timer démarre.
- Utilisé pour purger les informations de connexion non vérifiées.
 - Du point de vue du Fortigate, toutes les entrées sont valides (vérifiées ou non).
- Par défaut : 480 minutes (8h).
- Désactivation : régler la valeur sur 0 → Le statut est toujours *log on*.

- Cache users group

- L'agent collecteur met en cache l'appartenance à un groupe d'utilisateurs pendant une période de temps définie.
- Pendant cette période, il n'est pas mis à jour, même si l'utilisateur change de groupe dans l'AD.

Configuration FSSO

- Configuration des filtres de groupe (collecteur)

- Permet de définir quelles informations de connexion sont envoyées à quel FW

- Surveiller trop d'informations (grande structure AD) est inefficace et consomme des ressources.

Collector Agent Status: RUNNING

Common Tasks

- Show Service Status
- Show Monitored DCs
- Show Logon Users
- Select Domains To Monitor
- Set Directory Access Information
- Set Group Filters**
- Set Ignore User List
- Sync Configuration With Other Agents
- Export Configuration

FortiGate Filter List

Specify monitoring groups of FortiGates. Users logon/off activities will only be sent to the FortiGate if the users belongs to its monitored groups. If a default filter is defined, it will be used when no matching FortiGate filter is found.

FortiGate ID	Description	Monitored groups
Default	Default filter	CU=AD-users,OU=Training,DC=training4C.DC

Add Remove OK

FortiGate Group Filter

FortiGate Group Filter

☐ Default filter

FortiGate Serial Number:

Description:

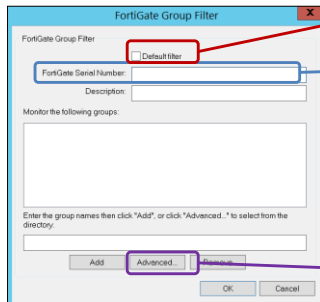
Monitor the following groups:

Enter the group names then click "Add", or click "Advanced..." to select from the directory.

Add Advanced... Remove OK Cancel

Configuration FSSO

- Configuration des filtres de groupe (collecteur) (suite)



Filtre par défaut si aucun filtre n'est défini

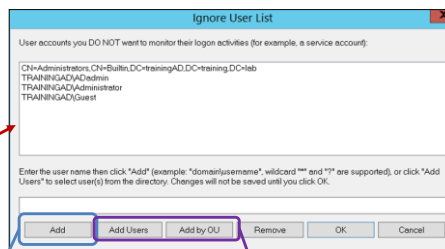
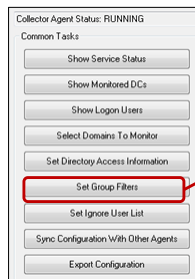
Un filtre est lié à un Fortigate via son numéro de série.

Vous pouvez filtrer sur le FortiGate au lieu de l'agent collecteur, mais seulement si l'agent collecteur fonctionne en mode avancé.
En mode avancé, le filtrage de groupe du FortiGate aura la priorité sur le filtre défini sur l'agent collecteur

Configuration FSSO

- Ignored User List

- Les événements de connexion qui correspondent aux entrées de cette liste ne sont pas enregistrés par l'agent collecteur.
 - Par exemple, il est intéressant d'y ajouter les comptes des services réseau.



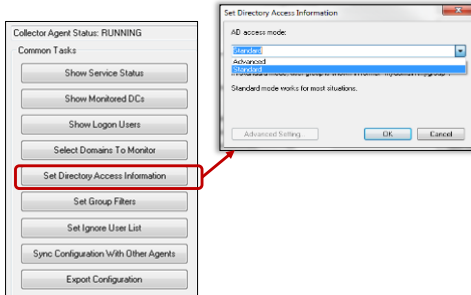
Ajout manuel d'un nom

Ajout d'un nom ou d'une OU via une liste

Configuration FSSO

• AD Access Mode Configuration

- Permet de définir comment l'agent collecteur accède et recueille les informations sur les utilisateurs et les groupes d'utilisateurs.



Mode d'accès standard

- Utilise la convention Windows-NetBIOS :
`Domain\username`
- Les profils de sécurité peuvent être appliqués uniquement à des groupes d'utilisateurs.
- Les groupes imbriqués ne sont pas supportés.
- Filtres de groupe uniquement sur l'agent collecteur.

Mode d'accès avancé

- Utilise la convention LDAP :
`CN=User, OU=Name, DC=Domain`
- Les profils de sécurité peuvent être appliqués aux utilisateurs ou aux groupes (imbriqués).
- Supporte les filtres de groupe sur le Fortigate ou sur l'agent collecteur.

Configuration FSSO

• AD Group Support

- Tous les types de groupes ne sont pas pris en charge, les groupes supportés pour le filtrage sont :
 - Les groupes de sécurité (Security groups).
 - Les groupes universels (Universal groups).
 - Les groupes à l'intérieur des unités d'organisation (OU).
 - Les groupes locaux ou universels qui contiennent des groupes universels de domaines enfants (uniquement avec le catalogue global).

• Utilisateurs ne faisant pas partie d'un groupe d'utilisateurs FSSO

- Si l'authentification passive uniquement est utilisée
 - Tous les utilisateurs qui n'appartiennent à aucun groupe FSSO sont automatiquement inclus dans le groupe d'invités SSO_guest_user (créé par défaut).
- Si l'authentifications active et passive sont activées
 - Les utilisateurs qui n'appartiennent à aucun groupe FSSO seront invités à entrer leurs identifiants.

- Affichage des utilisateurs "FSSO" connectés

Adresse IP et nom de l'utilisateur

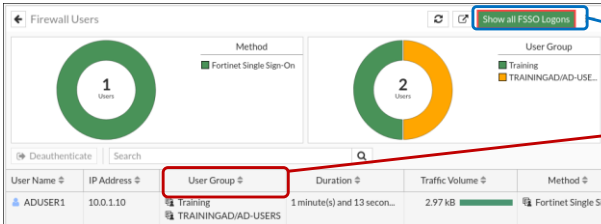
```
# diagnose debug authd fsso list
----FSSO logons----
IP: 192.168.1.1 User: ANNAH2 Groups: TRAININGAD/USERS
Workstation: WIN-INTERNAL MemberOf: Training
IP: 10.0.1.10 User: STUDENT Groups: GROUP3AD/USERS
Workstation: WIN-INTERNAL MemberOf: Training
Total number of logons listed: 2, filtered: 0
----end of FSSO logons----
```

Groupe de l'utilisateur

Nom du poste de travail de l'utilisateur

Groupe créé sur le Fortigate auquel on a mappé le groupe de l'AD

Dashboard > Users & Devices > Firewall Users



execute fsso refresh

User Group Training
Members TRAININGAD/AD-USERS
Group Type Fortinet Single Sign-On (FSSO)

327

- Vérifier la connectivité entre agents collecteurs et FortiGate

```
# diagnose debug enable
# diagnose debug authd fsso server-status
```

Server Name	Connection Status	Version
-----	-----	-----
TrainingDomain	connected	FSSO 5.0.0275

- Vérifier l'état du « polling » fait par le Fortigate (agentless mode)

```
# diagnose debug fsso-polling detail

AD Server Status:
ID=1, name(10.0.1.10),ip=10.0.1.10,source(security),users(0)
port=auto username=administator
read log offset=251636,latest login timestamp: Wed Feb  4 09:47:31 2015
polling frequency: every 10 second(s) success(246), fail(0)
LDAP query: success(0), fail(0)
LDAP max group query period(seconds): 0
most recent connection status: connected

# diagnose sniffer packet any 'host ip address and tcp port 445'

# diagnose debug application fssod -1
```

Fréquence de polling

Statistiques

Activer le débogage en temps réel en mode sans agent.
 fssod = le démon du mode polling

Permet de sniffer le trafic de polling du Fortigate (en mode sans agent).

Chapitre 9

SD-WAN

Software-Defined WAN

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Comprendre ce qu'est le SD-WAN.
 - Identifier les cas d'utilisation principaux du SD-WAN.
 - Configurer le SD-WAN sur un FortiGate.
 - Comprendre et analyser le routage dans un context SD-WAN.
 - Surveiller le comportement du SD-WAN, l'utilisation des liens et l'état de la qualité des liens.

SD-WAN

- **Software Defined Wide Area Network**
 - SD-WAN c'est une surcouche au WAN qui agrège les dernières technologies au niveau des accès WAN
 - **Moteurs de reconnaissances applicatives**
 - Pour détecter les applications, les suivre et donner de la visibilité sur les performances.
 - **Routage applicatif**
 - Afin de router les données en fonction de l'application et de la performance des liens.
 - Permet d'assurer les meilleures performances aux applications critiques.
 - **Solutions de performances applicatives**
 - Contrôle applicatif, compression, accélération TCP, ...
 - **Découplage des plans de contrôle et de données de manière à**
 - Pouvoir gérer le data plane de plusieurs périphériques de manière centralisée.
 - Pouvoir gérer le data plane de plusieurs périphériques depuis le cloud.

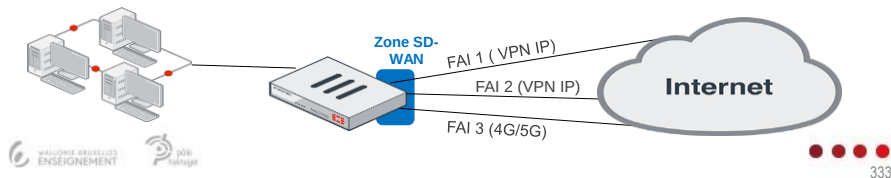
→ SD-WAN permet

- de construire un réseau virtuel prenant appui sur un réseau physique,
- de piloter le réseau depuis un point central,
- une sélection dynamique, basée sur des règles, des chemins d'accès aux applications sur plusieurs connexions WAN

1. Direct Internet Access (local breakout)

– Le trafic est envoyé directement vers Internet

- Trafic acheminé sur plusieurs liaisons internet physiques.
- Le trafic sensible est envoyé sur les liaisons les plus performantes.
- Le trafic non critique sur une ou plusieurs liaisons selon une approche « best-effort ».
- Les liaisons internet coûteuses sont généralement utilisées comme liaisons de secours ou pour diriger le trafic critique uniquement.
- Routage : typiquement des routes statiques par défaut, parfois BGP.



• Overlay and underlay links

– Types de liens

- Dans un environnement SD-WAN, les termes *underlay* et *overlay* sont couramment utilisés pour décrire le type de lien d'un membre SD-WAN.

– Underlay link

- Les liens physiques qui font partie de l'infrastructure physique du FAI que l'on peut louer ou acheter (câble, le DSL, la fibre, le MPLS, le 3G/4G/LTE, FortiExtender).
- Interfaces physiques, VLAN, LAG, 3G/4G.
- Le trafic n'y est généralement pas chiffré.

– Overlay links

- Liens virtuels construits au-dessus des *underlays* (tunnels GRE, IPsec, VXLAN)
- Interfaces IPsec, GRE, IP-in-IP.

– Dans SD-WAN :

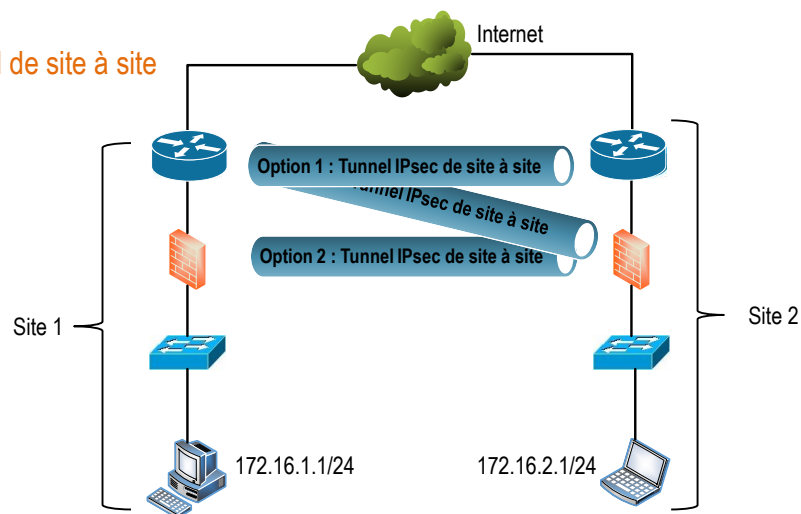
- Les *overlay links* sont dynamiques, ils sont montés automatiquement par FortiGate.
- FortiGate choisit le meilleur tunnel en fonction des conditions du lien sous-jacent (routage flexible)

2. Site-to-Site Traffic

– Caractéristiques principales Identiques au *Direct Internet Access* sauf :

- **Topologie Hub and spoke**
 - Généralement, les entreprises suivent une topologie Hub and spoke et utilisent des tunnels VPN Ipsec dynamiques pour transporter le trafic entre site.
 - Les tunnels peuvent transporter le trafic internet d'un spoke à un hub, d'où il sort ensuite vers Internet.
- **Le hub FortiGate peut effectuer des tests de vitesse sur les spokes**
 - Le hub FortiGate peut ensuite appliquer le résultat du test de vitesse comme vitesse en amont sur le tunnel à des fins de régulation du trafic.
- **Routing**
 - Le routage dynamique BGP est souvent utilisé même si le routage statique est possible.

a) VPN de site à site



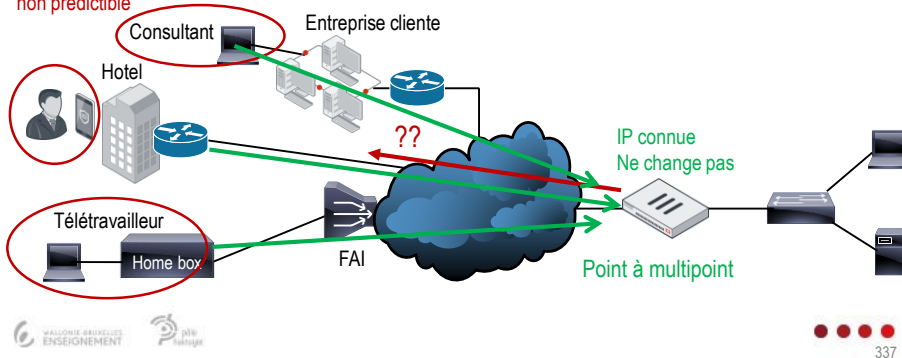
Topologies VPN

b) Dialup VPN

- Utilisé lorsque l'on ne sait pas avec quelle IP le pair distant se connectera

- C'est notamment le cas des travailleurs mobiles (télétravailleurs, en déplacement, ...)
- Point-à-multipoint : une configuration dialup VPN peut être utilisée pour plusieurs tunnels IPsec d'utilisateurs distants.

IP dynamique,
non prédictible



Topologies VPN

c) Hub and spoke

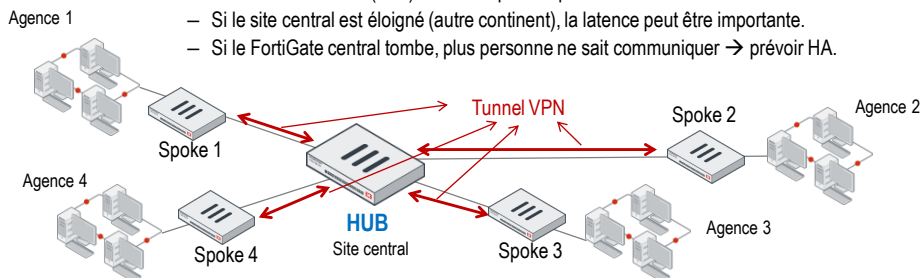
- Tous les clients se connectent via un équipement central appelé hub

- **Avantages**

- La configuration VPN et les règles de pare-feu sont facilement gérées.
- Consommation minimales de ressources dans chaque agence : un seul tunnel suffit.

- **Inconvénients**

- Le FortiGate central (Hub) nécessite plus de puissance.
- Si le site central est éloigné (autre continent), la latence peut être importante.
- Si le FortiGate central tombe, plus personne ne sait communiquer → prévoir HA.



Topologies VPN

d) Full meshed

– Maillage complet

- Tous les FortiGate sont reliés les uns aux autres.

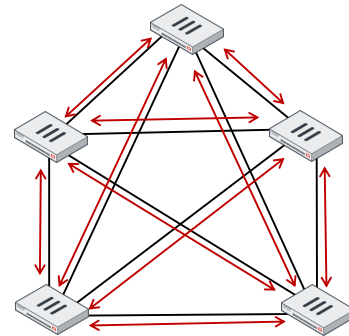
– Avantages

- Moins de latence.
- Excellente tolérance aux pannes.
- Le site central nécessite moins de BP.

– Inconvénients

- **Consommation de ressources**
 - Chaque FortiGate nécessite autant de tunnels qu'il n'y a de FortiGates distants.
- **Topologie la plus complexe**
 - Notamment au niveau du routage.
- **Plus cher**
 - Nécessite du matériel plus puissant.

Exemple de maillage complet



Chaque double flèche représente un tunnel VPN

Topologies VPN

e) Partial meshed

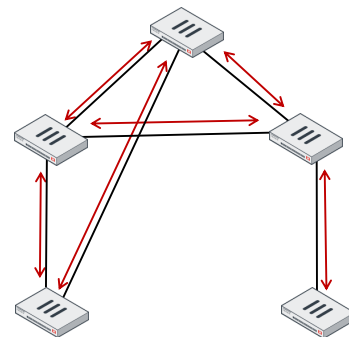
– Maillage partiel

- Chaque FortiGate (site, agence) n'a pas nécessairement besoin de communiquer avec tous les autres.

– Caractéristiques

- Nécessite moins de ressources qu'un maillage complet.
- Conserve une bonne latence par rapport à une topologie hub and spoke.
- La configuration reste plus complexe par rapport à une topologie hub and spoke.

Exemple de maillage partiel



Chaque double flèche représente un tunnel VPN

Comparatif

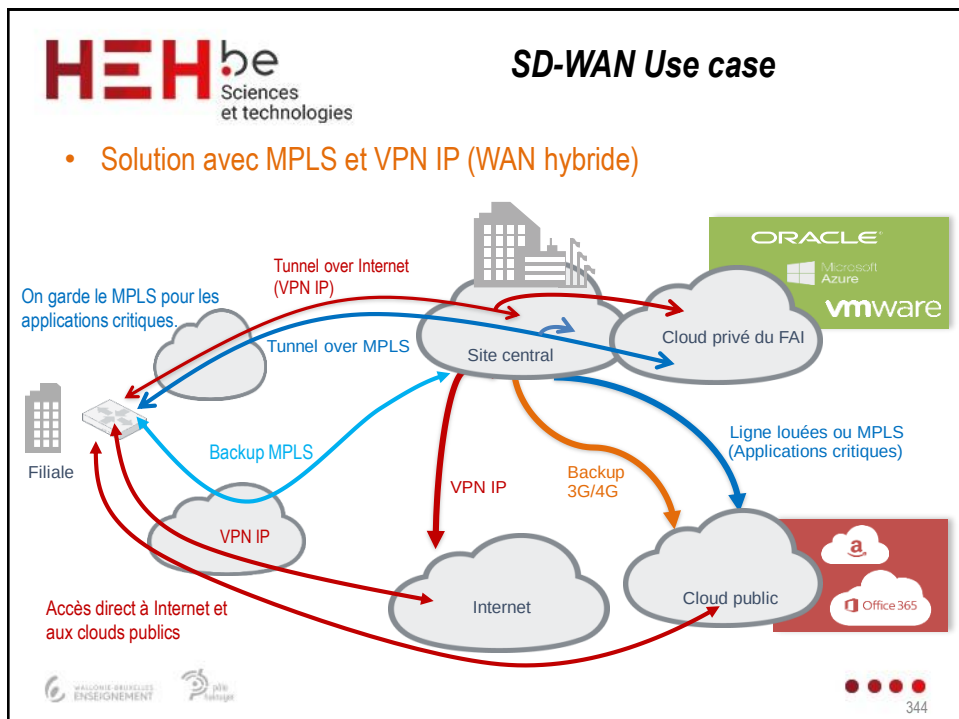
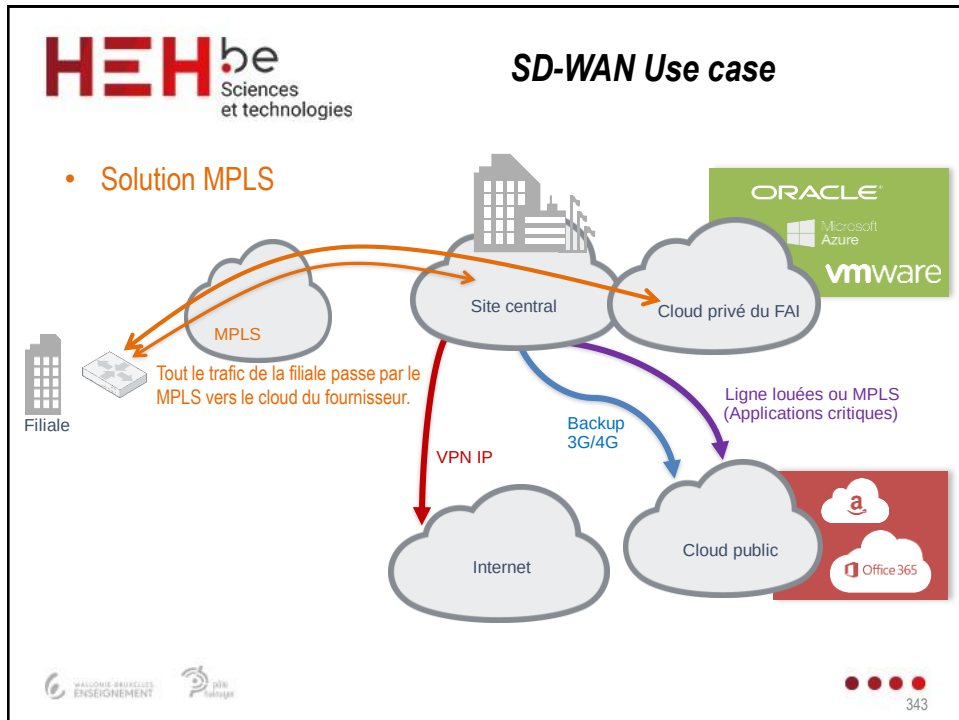
Hub-and-Spoke	Partial Mesh	Full Mesh
Configuration plus facile	Configuration moyenne	Configuration plus complexe
Peu de tunnels	Nombre moyen de tunnels	Plus de tunnels
Nécessite plus de BP aux Hubs	BP moyenne aux hubs	Moins de BP
Pas de tolérance de panne (SPOF)	Tolérance de panne partielle	Tolérance de panne pour chaque site
Spokes : peu de ressources Hubs : beaucoup de ressources	Consommation moyenne de ressources	Nécessite plus de ressources système
Evolutif	Un peu évolutif	Difficilement évolutif
Pas de communications directes entre sites	Communications directes entre certains sites	Communications directes entre tous les sites

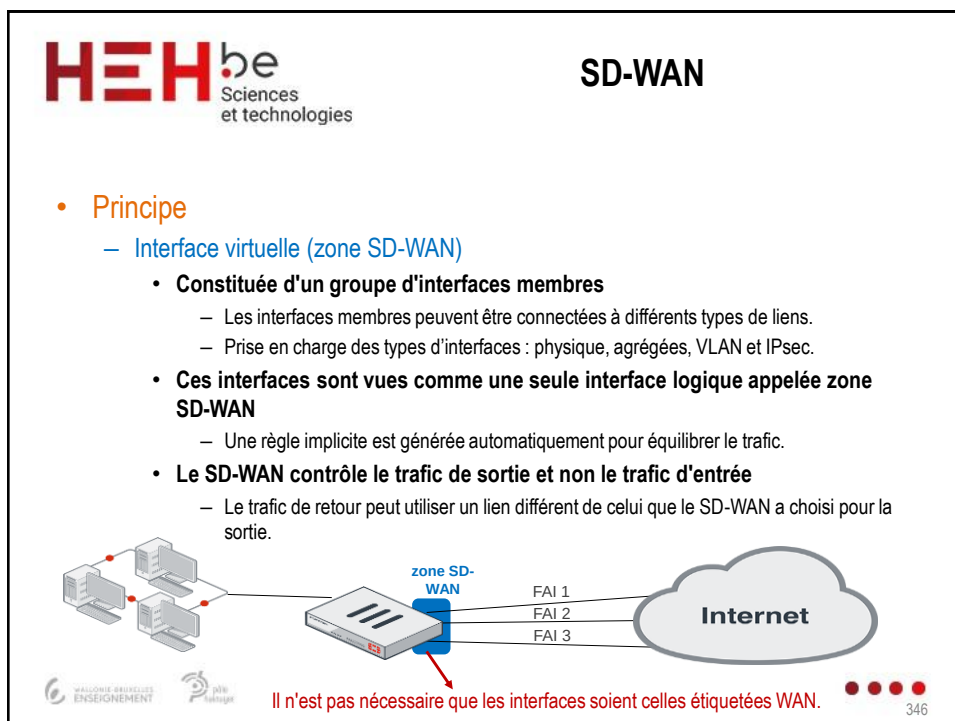
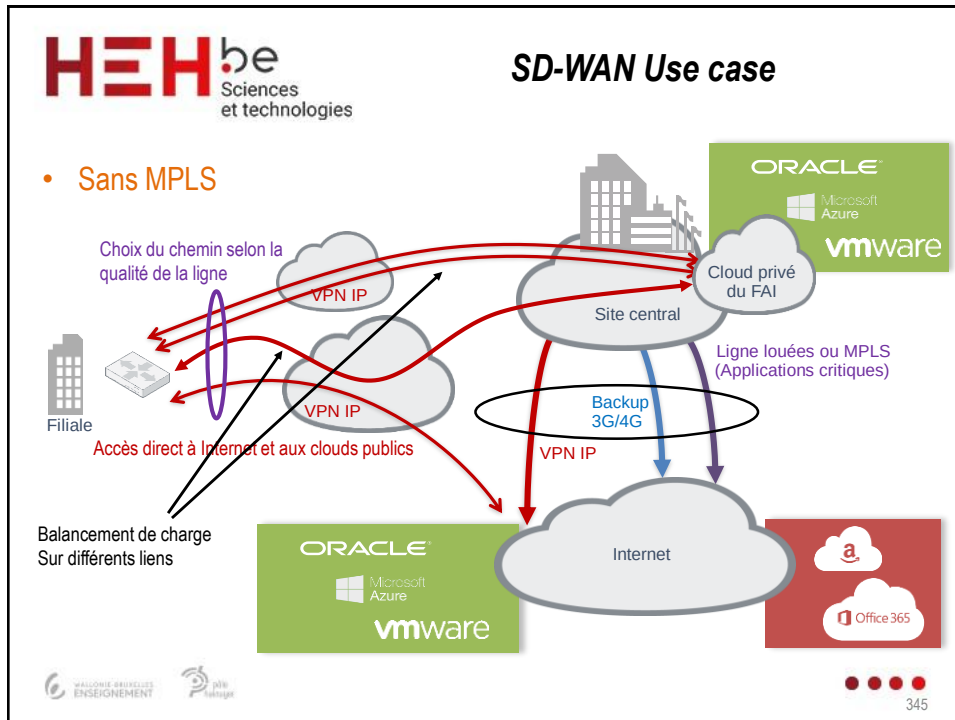
SD-WAN Use case

3. Remote Internet Access (remote breakout)

— Le trafic des agences passe par le site central

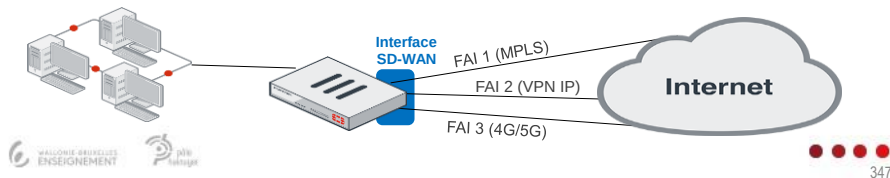
- Le trafic internet provenant des spokes est acheminé par le WAN via les tunnels (*overlay links*). Lorsque le trafic arrive au hub, il est dirigé vers Internet.
- Un intérêt est de centraliser l'inspection de sécurité et l'accès à l'internet sur le hub.
- Un autre est de permettre au trafic d'utiliser les liaisons WAN MPLS de meilleure qualité si les liens d'accès directs sont de moins bonne qualité.





– Caractéristiques d'une zone SD-WAN

- **Permet une utilisation efficace du WAN**
 - Différents algorithmes permettent d'équilibrer la charge en fonction de la BP, du nombre de sessions, de l'application, ...
- **Simplifie la configuration**
 - Permet de configurer un ensemble unique de routes et de règles de pare-feu qui seront appliquées à tous les FAI.
- **Prend en charge la mesure de la qualité des liens (Meilleure performances)**
 - Sélection dynamique des liens basée sur la qualité des liens.
 - Assure une haute disponibilité et une priorité aux applications critiques pour l'entreprise.



• Composants d'une solution SD-WAN sur FortiGate

– Les membres du SD-WAN

- Interfaces (logiques et physiques) utilisées pour acheminer le trafic.
- Appelés liens (links).

– Les zones (obligatoire)

- Groupement d'interfaces membre du SD-WAN.
- Permet d'optimiser la configuration avec un réglage plus granulaire.

– Les niveaux de performances (Performance SLAs)

- Vérifie que la qualité des liens est suffisante pour y envoyer le trafic.

– Les règles SD-WAN (SD-WAN rules)

- Définissent les critères permettant de sélectionner la meilleure interface de sortie pour acheminer tel ou tel type de trafic.
 - Défini que tel type de trafic nécessite un lien avec tel niveau de performance.

- Zones SD-WAN

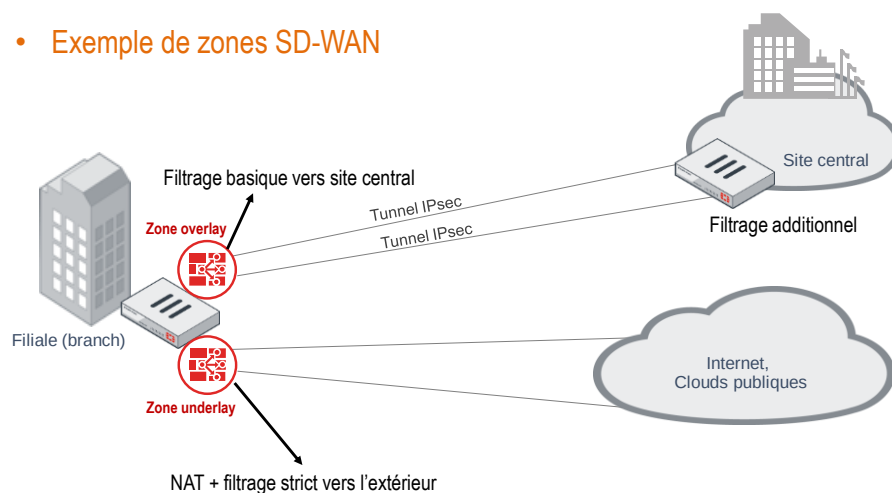
- Plus petit groupement d'interfaces membre du SD-WAN

- Permet un contrôle plus granulaire du trafic
 - Plutôt que de tout avoir regroupé dans une seule zone.
 - Permet de grouper des interfaces ayant les mêmes besoins (~zone-based Fw)
 - Évite la duplication de règles pour des interfaces individuelles.
 - Permet d'appliquer des règles différentes à différentes zones.

- Caractéristiques

- Par défaut, FortiGate crée la zone SD-WAN « virtual-wan-link ».
 - Une même interface membre du SD-WAN ne peut pas être partagée entre plusieurs zones.
 - Les interfaces membres du SD-WAN ne peuvent pas être utilisés individuellement dans une règle de FW.
 - Les zones SD-WAN sont incluses dans la vue topologique de la Security Fabric.

- Exemple de zones SD-WAN



- Configuration de Zones SD-WAN

Network > SD-WAN > SD-WAN Zones

SD-WAN Zones SD-WAN Rules Performance SLAs

Bandwidth Volume Sessions

Download Upload

4 Total 4 Total

port2 T_INET T_MPLS port1

+ Create New

virtual-wan-link

underlay

port2 10.200.2.254 1.90 kbps 1.90 kbps

port1 10.200.1.254 2.21 kbps 1.97 kbps

overlay

New SD-WAN Zone

Name

Interface members

Edit SD-WAN Member

Interface

SD-WAN Zone virtual-wan-link

Gateway 0.0.0.0

Cost 0

Priority 1

Status Enabled Disabled

Zone par défaut. Impossible à supprimer.

351

- Configuration

Une seule interface SD-WAN par VDOM

Spécifier au moins deux interfaces membres et leurs passerelles
 → Ces interfaces ne doivent pas être référencées par un autre élément de configuration (routes ou règle de FW).

Les interfaces membres sont regroupées en une seule interface virtuelle nommée sd-wan

ID	Name	Source	Destination	Criteria	Members
Implicit					
	sd-wan	all	all	Source IP	any

Network > SD-WAN > SD-WAN Zones

SD-WAN

Name SD-WAN

Type SD-WAN Interface

Status Enable Disable

SD-WAN Interface Members

Interface port1

Gateway 10.200.1.254

Cost 0

Status Enable Disable

Interface port2

Gateway 10.200.2.254

Cost 0

Status Enable Disable

Apply

Possible d'ajouter une autre interface membre à une date ultérieure.

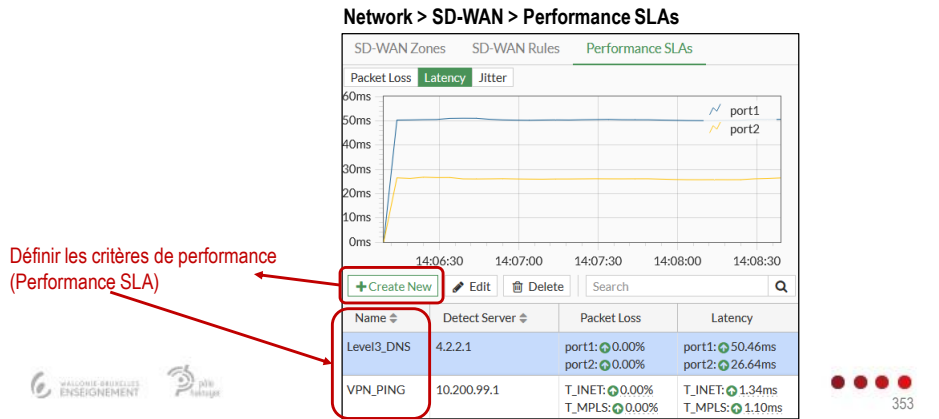
352

Performance SLA

- **Performance SLA**

- Permet de surveiller l'état de santé des membres du SD-WAN

- Mesure de la latence, de la gigue et du pourcentage de perte de paquets.



Performance SLA

- **Performance SLA : surveillance active ou passive**

- Surveillance passive

- FortiGate observe le trafic réel sur les interfaces SD-WAN et en déduit l'état du lien.
 - Le paramètre *passive-wan-health-measurement* doit être activé dans la règle de pare-feu.
 - Prefer passive : idem passive mais envoie des sondes s'il n'y a pas de trafic.

- Surveillance active : *Link Health Monitor (Link health check)*

- Vérifie la santé du membre en envoyant des sondes à un ou deux serveurs.
 - Seule la surveillance active permet de détecter si un lien est vivant ou mort.

Network > SD-WAN > Performance SLAs

New Performance SLA

Name: DemoSLA

Probe mode: ☒ Active ☐ Passive ☐ Prefer Passive

Protocol: ☒ Ping ☐ HTTP ☐ DNS

Servers: 4.2.2.1 4.2.2.2

Participants: ☒ All SD-WAN Members ☐ Specify

Définir 2 serveurs permet d'éviter que le serveur ne soit en faute, et non le lien. IP ou FQDN.

Performance SLA

- **Performance SLA : SLA Targets**

- **SLA Targets**

- Un lien membre SD-WAN affecté à un *performance SLA* doit satisfaire au *SLA Targets* (si activé) pour pouvoir être sélectionné parmi les autres liens participants pour l'envoi du trafic.

Network > SD-WAN > Performance SLA

SLA Target	☒	
Latency threshold	☒	5 ms
Jitter threshold	☒	5 ms
Packet Loss threshold	☒	0 %

Performance SLA

- **Performance SLA : SLA Targets (Cont.)**

Network > SD-WAN > Performance SLAs

SLA Target	☒
Link Status	
Check interval	500 ms
Failures before inactive	5
Restore link after	5 check(s)
Actions when Inactive	
Update static route	☒

Définir la fréquence à laquelle le système vérifie le statut de la liaison (et donc l'éventuel basculement).

Empêchent le "flapping". (Basculement incessant du trafic entre les liens).

Désactive automatiquement les routes statiques pour les interfaces inactives et restaure les routes lors de la restauration des interfaces.



Les valeurs d'une SLA target ne sont utilisées que lorsqu'elles sont référencées par une règle SD-WAN.

SD-WAN Rules

- **SD-WAN Rules strategies**

- **Stratégie d'une règle SD-WAN**

- Définit les exigences relatives aux membres préférés (*preferred members*).
 - Les membres préférés sont les meilleurs membres de la liste des interfaces sortantes (oif : *outgoing interface*) pour acheminer le trafic..
 - La liste oif trie les membres configurés par préférence.
 - Les meilleurs membres sont ceux qui répondent aux exigences SLA (le cas échéant) et qui offrent une route vers la destination.

- **Trois stratégies sont possibles**

- Manual
 - Best Quality
 - Lowest cost (SLA)

Network > SD-WAN Rules > SD-WAN Rules

Outgoing Interfaces

Interface selection strategy

☒ **Manual**
Manually assign outgoing interfaces.

☐ Best quality
The interface with the best measured performance is selected.

☐ Lowest cost (SLA)
The interface that meets SLA targets is selected. When there is a tie, the interface with the lowest assigned cost is selected.

SD-WAN rules

- **SD-WAN Rules strategies (Cont.)**

- **Stratégie de sélection d'une interface de sortie**

1. **Manual**

- Si le trafic correspond aux critères de correspondance, l'interface renseignée dans la configuration est utilisée.
 - Ne tient donc pas compte des éventuelles configurations de *SLA targets*.

Priority Rule

Name: Demo-SDWAN-rules-Manual

Status: ☒ Enabled ☐ Disabled

Source

Address: +

User group: +

Destination

Address: +

Internet service: +

Application: +

Outgoing Interfaces

Interface selection strategy: ☒ **Manual**
Manually assign outgoing interfaces.

SD-WAN rules

1. Manual (suite)

Interface selection strategy	
☒ Manual	Manually assign outgoing interfaces.
☐ Best quality	The interface with the best measured performance is selected.
☐ Lowest cost (SLA)	The interface that meets SLA targets is selected. When there is a tie, the interface with the lowest assigned cost is selected.
Interface preference	+
Zone preference	+
Measured SLA	
Required SLA target	+
Load balancing	☐
Quality criteria	Latency
Forward DSCP	☐
Reverse DSCP	☐

Interface ou zone à utiliser si les critères de la diapositive précédente sont rencontrés (source, destination, Internet services, application, ToS).

Champs non sélectionnables

SD-WAN rules

2. Best Quality

- Se base sur la performance du reseau (health check) mais pas sur les SLA targets.
- Le membre le plus performant selon le critère de qualité défini est sélectionné comme interface de sortie.

Interface preference	+
Zone preference	+
Measured SLA	
Required SLA target	+
Quality criteria	Latency
Forward DSCP	☐
Reverse DSCP	☐

Choix du critères de performance

3. Lowest Cost (SLA)

- Le membre qui répond à l'objectif SLA configuré est sélectionné comme interface de sortie.
- Si plusieurs membres répondent à l'objectif SLA, le coût du membre, suivi de l'ordre de configuration, sont utilisés comme critères de départage.

☒ **Lowest cost (SLA)**
The interface that meets SLA targets is selected. When there is a tie, the interface with the lowest assigned cost is selected.

Interface preference +

Zone preference +

Measured SLA ▾

Required SLA target +

Load balancing ☐

Quality criteria ▾

Forward DSCP ☐

Reverse DSCP ☐

Choix du SLA target à satisfaire.

• SD-WAN Rules strategies (Cont.)

– Application des règles

- **Même principe que pour les règles d'un pare-feu**
 - Lecture séquentielle.
 - La première correspondance est appliquée.
- **Les règles SD-WAN sont traitées comme des policy-based routes**
 - Elles sont prioritaires par rapport aux routes de la table de routage.

Network > SD-WAN Rules

ID	Name	Source	Destination	Criteria	Members	Hit Count	Last Used
IPv4 2							
1	Critical-to-HQ	LOCAL_SUBNET	HQ-Subnet	Latency	T_INET T_MPLS	0	43 minutes ago
2	Critical-DIA	LOCAL_SUBNET	GoToMeeting Microsoft.Office.365.Portal Salesforce		port1 port2	0	43 minutes ago
Implicit 1							
	sd-wan	all	all	Source IP	any		

Règle implicite : équilibre la charge sur toutes les interfaces membre

- Configuration de la méthode d'équilibrage de charge

- Load-balance mode

- Si le SD-WAN est active, le mode "load-balance" remplace le mode "v4-ecmp".

- Pas de balancement de charge pour la stratégie Best Quality

- Stratégie "Manual" : répartition de la charge entre tous les membres disponibles.
 - Stratégie "Best quality" : pas de balancement de charge.
 - Stratégie "Lowest cost (SLA)" : répartition de la charge entre tous les membres qui respectent les objectifs du SLA.

Network > SD-WAN Rules > SD-WAN Rules

☒ Lowest cost (SLA)

The interface that meets SLA targets is selected. When there is a tie, the interface with the lowest assigned cost is selected.

Interface preference	+
Zone preference	+
Measured SLA	▼
Required SLA target	+
Load balancing	☒

- Types d'équilibrage de charge

- Round-robin

- Par défaut, le trafic est distribué via l'algorithme round-robin.
 - Les sessions sont réparties entre les interfaces sélectionnées de manière égale et dans un ordre circulaire.

- Source IP (default)

- Les sessions d'une même adresse IP source utilisent la même interface.

- Source-destination IP

- Les sessions avec la même paire IP source/destination utilisent la même interface.

- Spillover (Usage)

- La même route est utilisée jusqu'à ce qu'un seuil de volume de trafic (en kbps) soit atteint. Tout trafic au-delà de ce seuil est envoyé sur une autre interface.
 - load-balance-mode utilise les seuils de débordement définis dans la configuration du membre SD-WAN, v4-ecmp-mode les seuils de débordement définis dans les paramètres de l'interface.

- Types d'équilibrage de charge (suite)

- Weight

- Le trafic est distribués en fonction du poids de l'interface.
 - Le poids est un nombre entier.
 - Répartit le nombre de sessions en fonctions du poids défini. Chaque session pèse le même poids.

- Volume (Bandwidth)

- FortiGate observe la quantité de données effectivement transférées (nombre d'octets), et répartit le volume de trafic total (pas juste les sessions) selon les poids des interfaces.

- Le mode est configurable uniquement en CLI

```
config system virtual-wan-link
    set load-balance-mode <load balance mode>
end
```

- Configuration des règles de pare-feu

- Le trafic dirigé par une règle SD-WAN doit être autorisé par une règle de FW

- Pour cela, configurer les règles de FW en référençant la zone SD-WAN.

Policy & Objects > Firewall Policy

New Policy

Name	Full_Access
Incoming Interface	port3
Outgoing Interface	sd-wan
Source	LOCAL_SUBNET
Destination	all
Schedule	always
Service	ALL
Action	☒ ACCEPT ☐ DENY ☐ LEARN

- Policy routes

- Rappel

- Elles offrent plus d'options de routage.
 - Elles sont prioritaires sur la table de routage.
 - Les règles sont lues dans l'ordre et une nouvelle règle est placée à la fin de la liste.

- Bonne pratique

- Limiter les critères de correspondance avec les « *policy routes* » régulières à ce qui est strictement nécessaire.
 - Sinon, le trafic qui devrait être acheminé par des règles SD-WAN pourrait être traité par des *policy routes* à la place.

- SD-WAN et policy route

- FortiOS implémente les règles SD-WAN comme des « *policy routes* ».
 - Cependant, les "policy routes" régulières ont une priorité plus élevée que les règles SD-WAN.

- Routage et SD-WAN

- Recherche de route (Route lookup)

- Pour les nouvelles sessions (trafic d'origine et trafic de réponse).
 - Pour les sessions « obsolètes » (dirty sessions).
 - Session qui doit être réévaluée par le noyau après avoir été affectée par un changement de routage, de politique de pare-feu ou d'interface.
 - Le FortiGate effectue des recherches d'itinéraires pour le trafic d'origine et le trafic de réponse. Pendant la recherche d'itinéraire, FortiGate vérifie également les itinéraires de stratégie.

- Meilleure route

- Par défaut, FortiGate ignore les règles SD-WAN si la meilleure route vers la destination n'est pas un membre SD-WAN.
 - Si le trafic ne correspond à aucune des règles SD-WAN, FortiGate achemine le trafic en utilisant le processus normal.
 - Si aucun membre SD-WAN n'a pas de route valide vers la destination.

• Routage et SD-WAN (suite)

– Implicit SD-WAN rule

- Si le trafic ne correspond à aucune des règles SD-WAN, FortiGate équilibre la charge (méthode source IP) sur toutes les interfaces membre.

– Configurer toutes les routes !

- L'objectif du SD-WAN est de choisir le meilleur membre vers lequel transférer le trafic, en fonction des critères de la règle SD-WAN,
- Dès lors, le routage doit être configuré de sorte que vos sites SD-WAN connaissent toutes les routes possibles vers toutes les destinations possibles qui sont destinées à être traitées par le SD-WAN.
 - Sinon, le SD-WAN peut ne pas choisir le meilleur membre, non pas parce qu'il ne répond pas aux exigences de l'application, mais parce que FortiGate n'a pas de route pour la destination et le membre.

• Configuration du routage

– Configuration d'une route par défaut utilisant l'interface SD-WAN

- Même si une seule route est configurée via l'interface SD-WAN, FortiGate installe des routes individuelles pour les interfaces membres dans la table de routage.

La configuration d'une route par défaut utilisant l'interface SD-WAN ne nécessite pas d'adresse de passerelle.

Network > Static Routes

Edit Static Route

Destination	Subnet	Named Address	Internet Service
	0.0.0.0/0		
Interface	SD-WAN		
Administrative Distance	1		
Comments			
Status	Enabled Disabled		

```
# get router info routing-table all
...omitted output...
```

```
S* 0.0.0.0/0 [1/0] via 10.200.2.254, port2
    [1/0] via 10.200.1.254, port1
C 10.200.2.0/24 is directly connected, port2
C 10.200.1.0/24 is directly connected, port1
```

- Configuration du routage (suite)
 - Configuration d'une route via une interface membre SD-WAN
 - Il est possible de configurer des routes statiques par membre
 - Pour un contrôle plus fin du trafic.
 - Dans ce cas, vous devez spécifier une passerelle si le type d'interface l'exige.

Network > Static Routes

Edit Static Route

Destination	Subnet Internet Service
	8.8.8.8/255.255.255.255
Gateway Address	10.200.1.199
Interface	port1
Administrative Distance	10
Comments	Write a comment... 0/255
Status	Enabled Disabled

- Vérifier le routage du trafic SD-WAN
 - Les logs permettent de vérifier par quelle interface membre le trafic est envoyé

Log & Report > Forward Traffic

Relative Date/Time	Source	Destination	Destination Interface	Application Name	Result	Policy ID	SD-WAN Rule Name
29 seconds ago	10.0.1.10	10.0.2.10	T_MPLS	FTP	✓ Accept (60 B / 40 B)	1 (To-Hub-Overlay)	Critical-to-HQ
2 minutes ago	10.0.1.200	96.45.45.45	port2	tcp/853	✓ Accept (9.57 kB / 14.7 kB)	3 (DIA)	
2 minutes ago	10.0.1.200	96.45.45.45	port2	tcp/853	✓ Accept (9.42 kB / 14.52 kB)	3 (DIA)	
2 minutes ago	10.0.1.10	8.8.8.8 (dns.google)	port1	PING	✓ Accept (49.98 kB / 0 B)	3 (DIA)	
4 minutes ago	10.0.1.10	8.8.8.8 (dns.google)	port1	PING	✓ Accept (39.98 kB / 0 B)	3 (DIA)	
4 minutes ago	10.0.1.200	96.45.45.45	port2	tcp/853	✓ Accept (8.76 kB / 12.94 kB)	3 (DIA)	

- Le sniffer intégré permet aussi de vérifier par quelle interface le trafic est envoyé

```
# diagnose sniffer packet any 'tcp[13]&2==2 and port 443' 4
5.455914 port1 out 192.168.1.254.59785 -> 192.168.1.11.443: syn 457459
5.455930 port2 out 192.168.1.11.443 -> 192.168.1.254.59785: syn 163440 ack 457460
5.455979 port2 out 192.168.1.32.49573 -> 192.168.1.25.443 : syn 927943
5.456043 port1 out 192.168.1.21.54711 -> 192.168.1.114.443: syn 930863
```

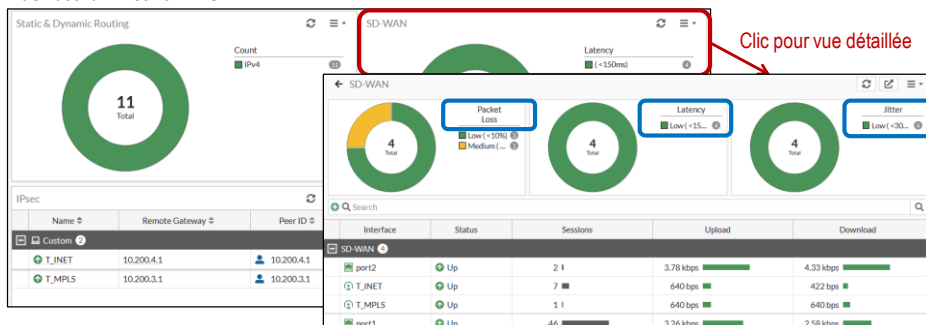

SD-WAN Monitoring

- **SD-WAN Monitoring**
 - Vérifier le bon fonctionnement du routage
 - Le routage SD-WAN est dynamique (en fonction de la qualité des liens).
 - Il est donc utile de vérifier régulièrement l'état des liaisons, le comportement du routage et la répartition du trafic de vos dispositifs SD-WAN.
 - La distribution du trafic correspond-elle aux attentes?
 - Seul le trafic critique est acheminé par les liens les plus coûteux?
 - Outils de monitoring
 - La table de routage, la table de session, le sniffer intégré, le dashboard SD-WA.

SD-WAN Monitoring

- **Dashboard—SD-WAN Widget**

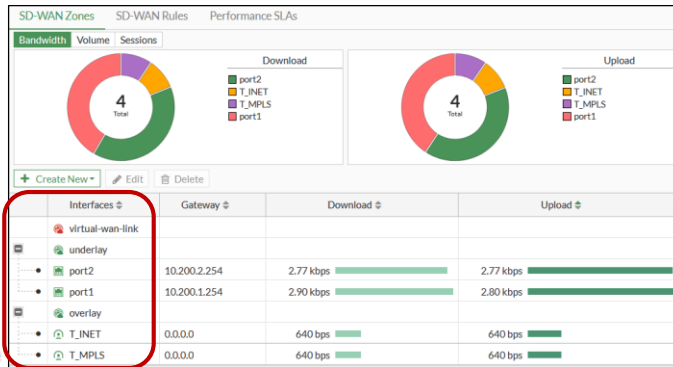
Dashboard > Network > SD-WAN



- Interfaces et zones SD-WAN

- Affiche une vue synthétique de la configuration des zones et des membres du SD-WAN

Network > SD-WAN > SD-WAN Zones

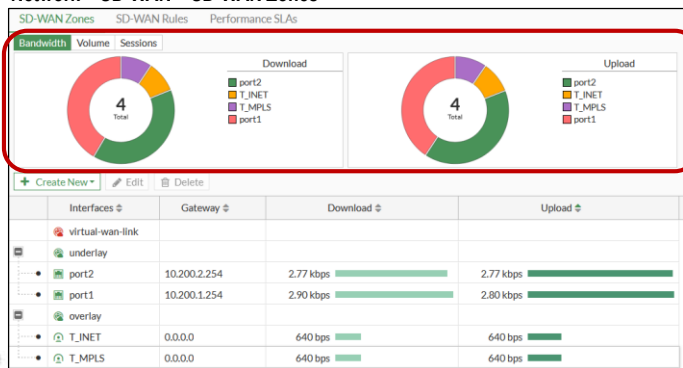


375

- Distribution du trafic

- Affiche la distribution du trafic entre membres du SD-WAN en se basant sur la bande passante, le volume ou les sessions

Network > SD-WAN > SD-WAN Zones



376

Résumé des règles SD-WAN

- Permet de visualiser rapidement les principaux paramètres de configuration d'une règle et la dernière fois que la règle a été utilisée pour diriger le trafic.

Network > SD-WAN > SD-WAN rules

ID	Name	Source	Destination	Criteria	Members	Hit Count	Last Used	Performance SLA
IPy4 3								
1	Critical-to-HQ	LOCAL_SUBNET	HQ-Subnet	Latency	T_INET T_MPLS	7	11 hours ago	VPN_PING
2	Critical-DIA	LOCAL_SUBNET	GoToMeeting Microsoft.Office.365.Portals Salesforce		port1 port2	0	16 hours ago	
3	Non-Critical-DIA	LOCAL_SUBNET	Facebook Social.Media GeneralInterest		port2 port1	0	12 hours ago	
Implicit 1								
	sd-wan	all	all	Source IP	any			

Membre en cours d'utilisation

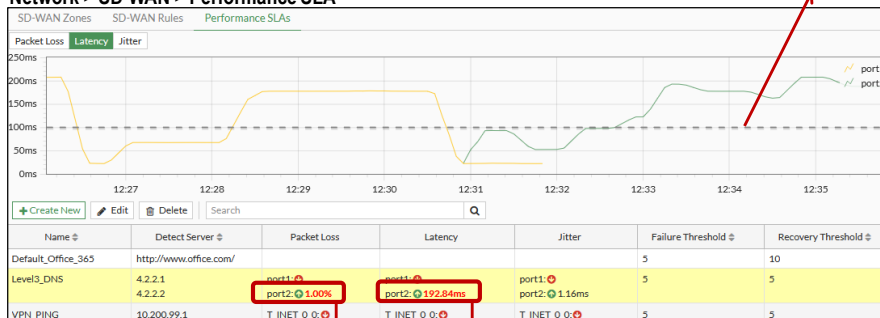
« Drag and drop » pour réordonnancer

377

État et performance d'un member SD-WAN

- Permet de visualiser rapidement les principaux paramètres de configuration d'une règle et la dernière fois que la règle a été utilisée pour diriger le trafic.

Network > SD-WAN > Performance SLA



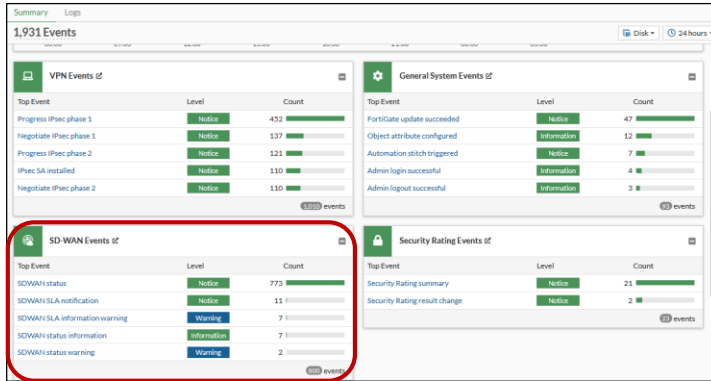
Seuil SLA target

En rouge : critère SLA non satisfait. Flèche verte = lien up
Informations uniquement sur les 10 dernières minutes.

378

- **System Event Logs**
 - Fournit un aperçu des événements.

Log & Report > System Events > SD-WAN Events



Clic pour voir les détails (diapositives suivantes)

379

- **System Event Logs > SD-WAN Events**

Log & Report > System Events

Relative Da...	Level	Message	Log Description
2 hours ago	Notice	Service will be redirected in sequence order.	SDWAN status
2 hours ago	Notice	Member link is unreachable or miss threshold. Stop forwarding traffic.	SDWAN status
2 hours ago	Notice	Service will be redirected in sequence order.	SDWAN status
2 hours ago	Notice	Member link is unreachable or miss threshold. Stop forwarding traffic.	SDWAN status
2 hours ago	Notice	Service prioritized by performance metric will be redirected in sequ...	SDWAN status
2 hours ago	Notice	Member link is unreachable or miss threshold. Stop forwarding traffic.	SDWAN status
2 hours ago	Notice	Number of pass member changed.	SDWAN status
2 hours ago	Notice	Member status changed. Member out-of-sla.	SDWAN status
2 hours ago	Warning	SD-WAN health-check member changed state.	SDWAN SLA information warning
2 hours ago	Warning	SD-WAN health-check member changed state.	SDWAN SLA information warning
2 hours ago	Notice	Number of pass member changed.	SDWAN status
2 hours ago	Notice	Member status changed. Member out-of-sla.	SDWAN status
2 hours ago	Notice	Member status changed. Member out-of-sla.	SDWAN status
2 hours ago	Notice	SD-WAN Health Check member(s) pass.	SDWAN status

Un port a été supprimé de la liste des membres préférés

État d'un port est passé de vivant à mort. Clic pour avoir des détails

Log Details	
General	
Source	Interface
Interface	port2
Data	
Message	SD-WAN health-check member changed state.
Security	
Level	Warning
Other	
Log event original timestamp	1694598723897875400
Timestamp	0700
Log ID	0113622931
Type	event
Sub Type	sdwan
Event Type	Health Check
Health Check	Level3_DH45
Probe Protocol	ping
Old Value	alive
New Value	dead

380

Chapitre 10

ZTNA

Zero Trust Network Access

Introduction ZTNA

- **Objectifs**
 - Comprendre le principe du Zero Trust
 - Comprendre les avantages de l'utilisation de Zero Trust Network Access (ZTNA)
 - Comprendre les principes fondamentaux de ZTNA
 - Comprendre comment établir l'identité d'un dispositif et la confiance
 - Comprendre l'authentification basée sur un certificat SSL
 - Configurer l'accès ZTNA sur FortiOS
 - Décrire les types de configuration ZTNA

- Zero trust (ZT), Zero Trust Architecture (ZTA), Zero Trust Access (ZTA)
 - Le modèle zéro confiance
 - **Modèle stratégique de cybersécurité qui part du principe qu'il n'existe aucune zone de confiance : il faut toujours vérifier**
 - Aucun utilisateur ni terminal n'est considéré comme étant de confiance (trusted) tant que son identification et son accréditation n'ont pas été minutieusement vérifiées.
 - **Zero Trust est basé sur un ensemble de technologies existantes telles que**
 - le contrôle d'accès,
 - l'authentification (multifacteur - MFA),
 - la segmentation,
 - la vérification continue des utilisateurs et des appareils,
 - la surveillance du réseau,
 - le principe du moindre privilège,
 - ...
 - Aucune confiance implicite et aucun privilège n'est accordé par défaut
 - Même si l'utilisateur se connecte depuis l'intérieur de l'entreprise avec un PC de l'entreprise.

- Zero trust (suite)
 - Aucune transaction n'est autorisée sans confiance
 - Aucun utilisateur ni terminal n'est autorisé à accéder à une ressource (fichier, application, ...) tant qu'il n'est pas considéré comme étant de confiance.
 - Peu importe sa localisation (réseau interne de l'entreprise, télétravail, ...) et celle de la ressource (LAN, DMZ, cloud, ...)
 - Peu importe s'il a déjà eu un accès auparavant.
 - La confiance est obtenue après vérification d'un ensemble de paramètres
 - Les paramètres peuvent être basés sur l'identité (authentification de l'utilisateur et/ou du terminal) et le contexte (posture check : présence d'un antivirus, localisation, ...).
 - L'accès accordé après vérification est limité (Least privilege)
 - L'accès peut être donné à une seule ressource et pendant un temps limité.
 - La confiance n'est pas conservée
 - Des vérifications sont effectuées continuellement, et pas seulement une fois.
 - L'accès peut être révoqué en cours de session si l'état de sécurité change.

• Le NIST définit 7 principes sur lesquels repose une architecture ZTA

1. Données, services et équipements sont des ressources

- L'accès et les actions sur une ressource doivent être systématiquement contrôlés et supervisés.

2. Toutes les communications devraient être sécurisées

- Les communications doivent être sécurisées (certificat, chiffrement), indépendamment de l'emplacement des ressources.

3. Chaque tentative d'accès à une ressource devrait être vérifiée et évaluée

- Il faut définir des habilitations et contrôler les accès sur base de ces habilitations.
 - RBAC : Role-Based Access Control.
- Les utilisateurs doivent être authentifiés et disposer uniquement des droits nécessaires à leurs fonctions, ni plus ni moins (principe du moindre privilège).

4. L'accès à une ressource devrait être soumis à une politique d'accès dynamique

• Dynamique

- Le niveau de sécurité nécessaire pour accéder à chaque ressource doit pouvoir s'adapter en fonction du contexte dans lequel se trouve l'utilisateur.

• Le contexte peut être fonction de :

- L'identité du client, du service ou de la ressource demandée.
- L'état du client demandant l'accès (versions installées, certificat, indices de compromission, ...)
- Les attributs comportementaux (première fois que la connexion est demandée depuis un pays étranger, ...)
- Les attributs d'environnement (localisation réseau, date de la requête, ...)

5. Un système de surveillance de l'intégrité et du niveau de sécurité en temps réel devrait être implémenté

- Idéalement, l'intégralité des composants du réseau doit être surveillée afin de détecter rapidement tout comportement suspect ou anormal.
- **CDM**
 - Continuous Diagnostics and Mitigation. Un système de diagnostic et d'atténuation des risques en continu doit être mis en place pour surveiller l'état des appareils et des applications et appliquer les correctifs nécessaires.
- **SOC**
 - Le Security Operations Center est une équipe de professionnels de la sécurité informatique qui surveille l'ensemble de l'infrastructure informatique d'une entreprise, 24h/24 et 7j/7, afin de détecter les événements de cybersécurité en temps réel et y faire face aussi rapidement et efficacement que possible.
- **SIEM**
 - Le Security Information Event Management collecte les données des journaux d'événements à partir de sources diverses, identifie les activités qui s'écartent de la norme grâce à une analyse en temps réel et applique les mesures appropriées.

6. Les mécanismes d'authentification et d'autorisation devraient être dynamiques et strictement appliqués avant qu'un accès soit autorisé

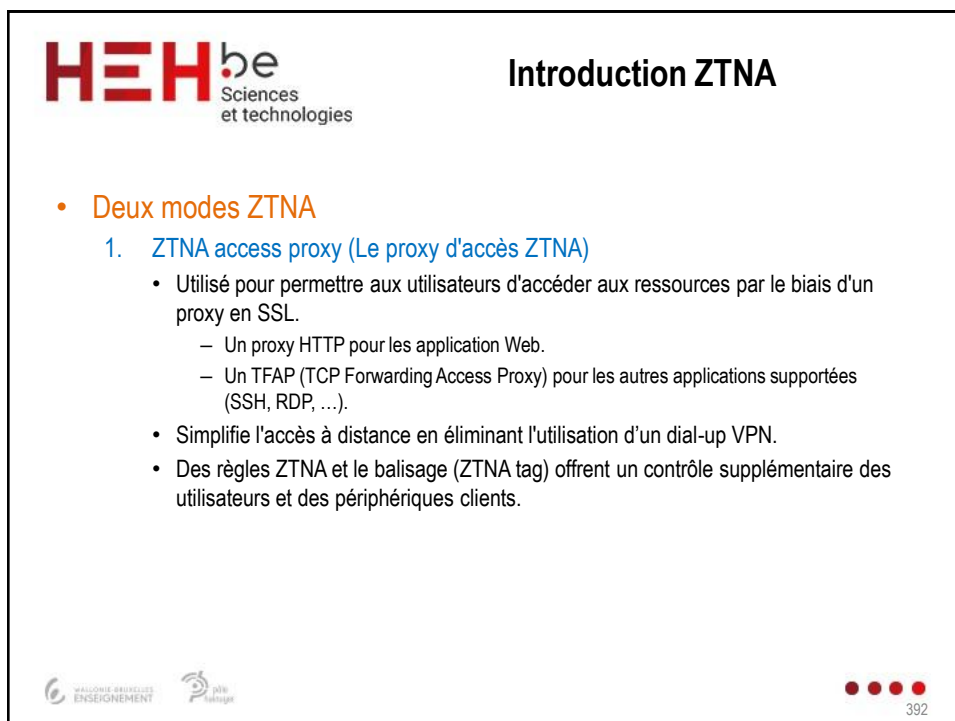
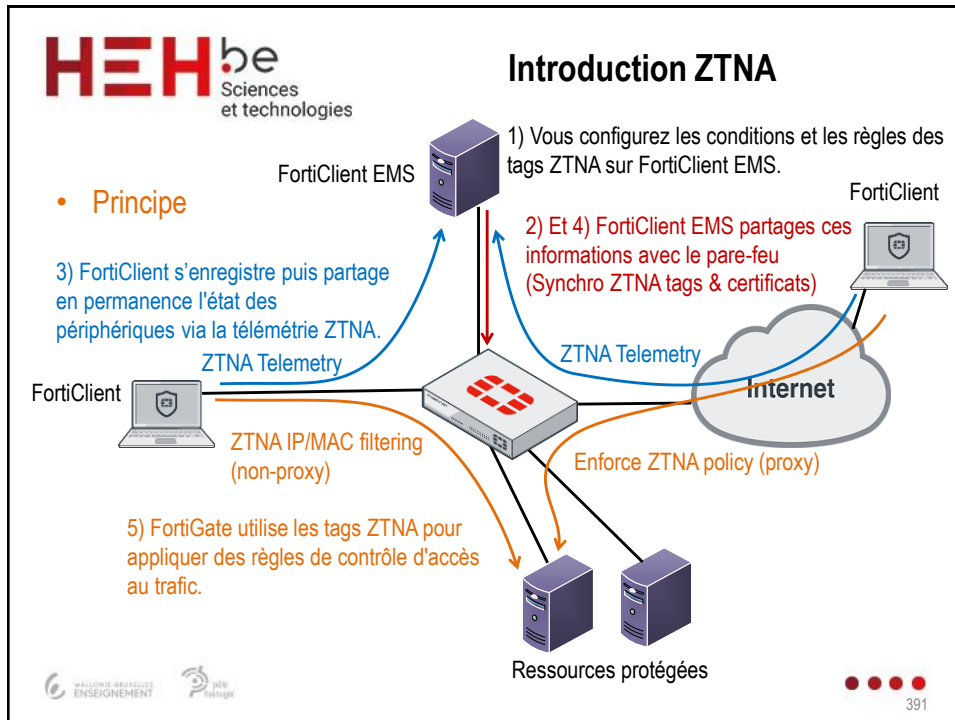
- L'entreprise devrait disposer d'un système de gestion des identités, des habilitations et des accès et d'un système de gestion des actifs.
 - ICAM : Identity, Credential, and Access Management.
 - IAM : Identity and Access Management.
- L'entreprise devrait mettre en place une surveillance continue avec réauthentification et réautorisation éventuelles tout au long des transactions.

7. L'entreprise devrait assurer une supervision constante de la sécurité

- L'entreprise doit collecter le maximum d'informations possibles sur le niveau de sécurité des actifs, l'infrastructure réseau et les communications en cours.
- La traçabilité et l'exploitation continue des informations collectées doivent servir à l'amélioration constante de la sécurité du SI.

- ZTNA : Zero Trust Network Access
 - ZTNA est une fonctionnalité de Zero Trust Access (ZTA) qui se concentre sur le contrôle d'accès aux applications
 - ZTNA de Fortinet n'accorde l'accès **par session** à une application qu'après vérification de différents paramètres.
 - Périphérique, utilisateur, contexte.
 - Le contrôle s'effectue à chaque nouvelle session.
 - Car entre cette session et la précédente, le PC s'est peut-être fait infecter ou voler.
 - Le **processus** de contrôle s'effectue **indépendamment** de l'emplacement du client et de la ressource.
 - Indépendamment dans le sens où des contrôles sont effectués peu importe la localisation, mais ces contrôles peuvent être différents selon l'environnement.
 - Par exemple, un accès peut nécessiter une authentification 2FA depuis l'extérieur mais pas depuis l'intérieur de l'entreprise.

- ZTNA : Zero Trust Network Access (suite)
 - Fortinet ZTNA contrôle les accès en :
 - Vérifiant l'identité des périphériques client (Via des certificats).
 - Authentifiant l'identité de l'utilisateur (MFA supporté).
 - Vérifiant l'autorisation de l'utilisateur (Habilitations, RBAC).
 - Vérifiant la posture en fonction du contexte.
 - Réalisant des contrôles basés sur des attributs et contextes définis dans des tags zéro confiance (Zero-trust tags).
 - Par exemple, ZTNA peut vérifier : la localisation, présence d'un antivirus, d'un certificat, d'une connexion à FortiClient EMS, la présence d'un fichier spécifique, d'un OS spécifique, d'une connexion à un domaine AD, etc.



Introduction ZTNA

2. ZTNA IP/MAC filtering (ZTNA secure access)

- Ce contrôle d'accès est typiquement utilisé lorsque les terminaux sont physiquement situés dans le réseau de l'entreprise.
- Utilise les règles et les tags ZTNA pour mettre en œuvre un accès zéro confiance basé sur les rôles.
 - Ce contrôle d'accès combine les adresses IP/MAC (règles de pare-feu) avec des tags ZTNA pour l'identification et le contrôle de la posture de sécurité.
 - Ce mode ne nécessite pas l'utilisation du proxy d'accès

Les équipements et leurs rôles

- **FortiClient**
 - **Solution de sécurité pour les périphériques clients**
 - FortiClient permet à chaque appareil - local ou distant, fixe ou mobile - de s'intégrer à FortiClient EMS.
 - Plusieurs plates-formes supportées :
 - Windows, Mac OS, Linux, iOS, les appareils mobiles Android et Chromebook.
 - **FortiClient peut être utilisé soit avec FortiClient EMS uniquement, soit dans la Security Fabric.**

ZTNA Edition
✓ Zero Trust Agent
✓ Central Management via EMS
✓ Central Logging & Reporting
✓ Dynamic Security Fabric Connector
✓ Vulnerability Agent & Remediation
✓ SSL VPN with MFA
✓ IPSEC VPN with MFA
✓ FortiGuard Web & Video Filtering
✓ ZTNA Application Access control

EPP/APT Edition
All the Features of ZTNA Edition plus:
✓ SSL Inspection
✓ Inline AV & Anti-Malware
✓ Intrusion Prevention (IPS)
✓ FortiGuard Web & Video Filtering
✓ DNS Security
✓ USB Device Control

- **FortiClient (suite)**
 - Fournit des informations au FortiClient EMS lorsqu'il s'y enregistre :
 - Informations sur le client (réseau, système d'exploitation, version, etc.).
 - Informations sur l'utilisateur connecté.
 - Informations sur l'état de la sécurité (dans ou en dehors de la Security Fabric, antivirus à jour et activé, vulnérabilités détectées, etc.).
 - Demande et obtient un certificat de périphérique client
 - Demande et obtient un certificat de périphérique client auprès de l'autorité de certification EMS ZTNA lors de sa première tentative de connexion.
 - Vous ne pouvez pas utiliser les fonctionnalités de FortiClient tant que celui-ci n'est pas connecté à FortiClient EMS et qu'il n'a pas de licence.
 - Le client utilisera ce certificat pour s'identifier auprès d'un FortiGate.
 - Est configuré via le profil de sécurité que l'administrateur a configuré dans FortiClient EMS.

- **FortiClient EMS**
 - Solution de gestion centralisée de FortiClients
 - Permet de configurer de manière centralisée des profils de sécurité avec lesquels les FortiClients seront approvisionnés.
 - Vous pouvez y créer, modifier et supprimer des règles d'étiquetage zéro confiance.
 - Permet l'administration des connexions des terminaux FortiClient
 - Acceptation, déconnexion et blocage des terminaux.
 - Il apporte une visibilité sur l'ensemble des FortiClients du réseau
 - L'état, le système (versions obsolètes?), les règles, les exceptions, la sécurité,...
 - Il comprend des fonctions d'automatisation pour la gestion des périphériques et le dépannage.
 - Dans une architecture ZTNA, vous ne pouvez modifier les configurations d'un FortiClient qu'à partir du FortiClient EMS.

- FortiClient EMS (suite)
 - Émet et signe le certificat du FortiClient
 - Avec l'UID du FortiClient, le numéro de série du certificat et le numéro de série de l'EMS.
 - FortiClient EMS synchronise ensuite le certificat Client avec le FortiGate.
 - FortiClient EMS partage son certificat EMS ZTNA CA avec le FortiGate.
 - Afin que les FortiGates puissent l'utiliser pour authentifier les certificats clients.

- FortiClient EMS (suite)
 - Utilise des règles Zero Trust pour étiqueter les clients (tag) en fonction des informations dont il dispose sur chaque client.
 1. EMS envoie des règles zéro confiance aux périphériques client.
 2. Le FortiClient vérifie les clients à l'aide des règles zéro confiance fournies et envoie les résultats à EMS.
 3. EMS regroupe dynamiquement les clients à l'aide du tag configuré pour chaque règle.
 4. EMS synchronise les balises ZTNA avec les FortiGates.
 - Met à jour les informations relatives aux clients lorsque celles-ci changent
 - Synchronise ces mises à jour avec les FortiGates.

EMS > Zero-trust Tags > zero-trust Tagging Monitor

Endpoint with Tag					Refresh
Remote-Endpoints (1)					
Endpoint	User	OS	IP	Tagged on	
Remote-Client	 Administrator	Microsoft Windows Ser...	10.0.2.20	2021-08-25 02:43:06	

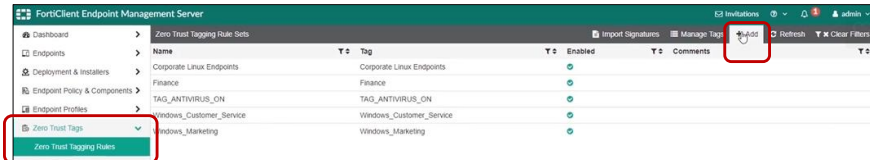
- Les équipements et leur rôle (suite)
 - FortiGate
 - Maintient une connexion continue avec FortiClient EMS
 - Afin de synchroniser les informations sur les clients (l'UID du FortiClient, le SN du certificat client, le SN du FortiClient EMS, les détails du réseau (adresses IP et MAC), etc.).
- Vérification des sessions actives ZTNA
 - Changements de posture des terminaux clients
 - Ils déclenchent la revérification des sessions actives.
 - Si le terminal n'est plus conforme aux règles ZTNA, la session est interrompue.
 - Les tags ZTNA sont mis à jour par le FortiClient EMS
 - FortiGate surveille ces mises à jour. En cas de changement, les sessions ZTNA actives doivent à nouveau correspondre à la politique ZTNA.
 - Changements des règles ZTNA
 - Les modifications apportées aux règles ZTNA déclenchent également une nouvelle vérification de l'appareil client par rapport à la politique.

- ZTNA avec ou sans client (client and clientless ZTNA)
 - Client-initiated, endpoint-initiated
 - Le modèle ZTNA initié par le client utilise un agent sur les clients (Par exemple, FortiClient).
 - Avantages
 - Fonctionne que vous accédez à des ressources dans le cloud ou sur site.
 - Offre une meilleure visibilité et un meilleur contrôle des appareils.
 - Service-initiated, clientless
 - Le modèle ZTNA initié par le service ou "sans client" utilise une architecture de reverse proxy.
 - Pas d'agent sur les clients mais un plug-in de navigateur pour créer un tunnel sécurisé et effectuer l'évaluation de l'appareil et la vérification de la posture.
 - Il ne prend généralement en charge que les applications basées sur HTTP/HTTPS.
 - Plutôt que de résider localement, le logiciel doit être téléchargé à chaque connexion, ce qui ralentit et dégrade l'expérience de l'utilisateur.
 - N'offre pas le même niveau de contrôle ou de visibilité qu'un agent
 - Or un élément important de ZTNA consiste justement à évaluer la posture de l'appareil et son état de vulnérabilité.

Configuration ZTNA

- Zero-Trust tagging rules
 - Configuration des règles de balisage Zéro confiance sur FortiClient EMS

Zero-trust Tags > Zero-trust Tagging Rules > + Add



Configuration ZTNA

- Zero-Trust tagging rules (suite)
 - Configuration des règles de balisage zéro confiance sur FortiClient EMS

Zero-trust Tags > Zero-trust Tagging Rules

Zero Trust Tagging Rule Set

Name: HQ-safe

Tag Endpoint As: HQ-safeRange

Enabled: ☒

Comments: Optional

Rules:

Type	Value
Windows (2)	
Antivirus Software	1 AV Software is installed and running
OS Version	2 Windows 7 3 Windows 10
Rule Logic	(1 and 3) or 2

1) Choisissez un tag existant ou entrer un nouveau tag.

EMS utilise ce tag pour regrouper dynamiquement les clients qui satisfont à la règle.

2) Cliquez sur Add Rule pour créer la règle (voir diapositive suivante).

3) Affichage des règles créées

Par défaut, un terminal doit satisfaire à toutes les règles configurées. « Rule Logic » permet de modifier ce comportement par défaut.

Configuration ZTNA

- Zero-Trust tagging rules (suite)

Le choix de l'OS détermine les types de règles disponibles.

Le type de règle choisi détermine les options possibles

- AD Group
- AD Group
- Antivirus Software
- Certificate
- EMS Management
- File
- Logged in Domain
- Registry Key
- Running Process
- OS Version
- Sandbox Detection
- User Identity
- Vulnerable Devices
- Windows Security

Configuration ZTNA

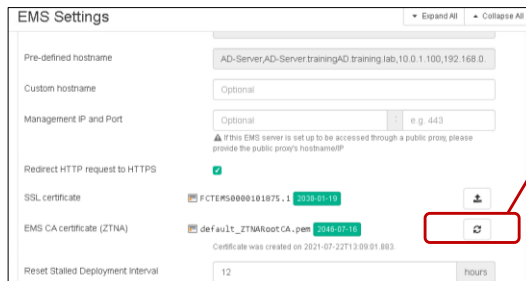
- Zero Trust tag monitor
 - Menu de l'EMS affichant toutes les règles zero trust.

Configuration ZTNA

Gestion des certificats sur le FortiClient EMS

– Default_ZTNARootCA

- FortiClient EMS dispose d'un certificat racine par défaut.
 - La CA ZTNA utilise ce certificat racine pour signer les CSR des terminaux FortiClient.
- Vous pouvez révoquer tous les certificats ou le certificat individuel d'un FortiClient.



Le bouton d'actualisation permet de révoquer et mettre à jour l'autorité de certification racine.

Cela oblige à mettre à jour les FortiGate et FortiClient en générant de nouveaux certificats pour chaque client.

Configuration ZTNA

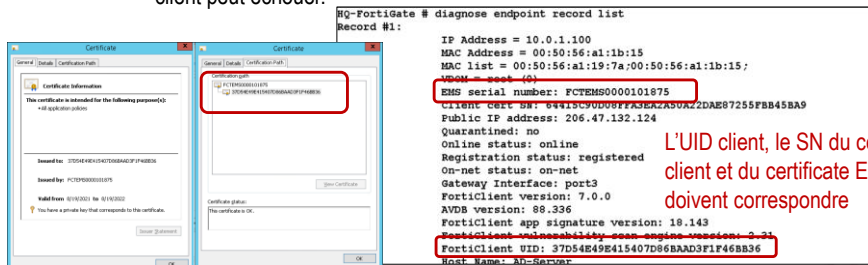
Gestion des certificats sur le FortiClient EMS (suite)

– Certificats

- Sous Windows, les certificats sont installés directement dans le magasin de certificats.
- Sur d'autres systèmes d'exploitation, consultez la documentation du fournisseur.

– FortiGate

- Les informations du certificat dans le magasin du client doivent correspondre aux informations du FortiClient EMS et du FortiGate sinon l'authentification du certificat client peut échouer.



L'UID client, le SN du certificat client et du certificat EMS doivent correspondre

- **Authentification par certificat**

- **Obtention du certificat client**

- Lorsqu'il s'enregistre auprès du FortiClient EMS, le FortiClient soumet automatiquement une demande CSR.
- Le FortiClient EMS signe et renvoie le certificat client.
 - Ce certificat est stocké dans le magasin de certificats du système d'exploitation pour les connexions ultérieures.
- Les informations sur les terminaux sont synchronisées avec FortiGate et FortiClient EMS.
- Actuellement, ZTNA prend en charge les navigateurs Microsoft Edge et Google Chrome.

- **Révocation du certificat client**

- Lorsqu'un client se déconnecte ou est désenregistré de FortiClient EMS, son certificat est supprimé du magasin de certificats et révoqué sur FortiClient EMS.

- **Authentification par certificat (suite)**

- **Par défaut, l'authentification du certificat client est activée sur le proxy d'accès**

- Lorsque le FortiGate reçoit la requête HTTPS, le processus WAD demande au client de s'identifier à l'aide de son certificat.
- Si le client répond avec le bon certificat, l'UID du client et le SN du certificat peuvent être extraits :
 - Si l'UID du client et le SN du certificat correspondent à l'enregistrement du FortiGate, le client est autorisé à poursuivre le traitement de la règle de proxy ZTNA.
 - Si l'UID du client et le certificat SN ne correspondent pas à l'enregistrement du FortiGate, le client est empêché de poursuivre le traitement de la règle de proxy ZTNA.
- Si le client annule et répond avec un certificat client vide,
 - Le client est autorisé à poursuivre si l'option *empty-cert-action* est configurée sur *accept*. Sinon, FortiGate bloque le client et l'empêche de poursuivre.

```
config firewall access-proxy
edit <name>
    set client-cert enable
    set empty-cert-action block
```

Configuration ZTNA

- ZTNA HTTPS access proxy (Le proxy d'accès ZTNA)

- FortiGate fonctionne comme un *reverse proxy* pour un serveur HTTP(S)

3) Vous pouvez imposer une authentification supplémentaire (locale, distante, ..)

LDAP/RADIUS/local

FortiClient EMS

FortiClient

Port 1
IP : 100.64.1.250

Access Proxy VIP
100.64.1.250:9443

Internet

2) FortiGate vérifie le certificat et les tags ZTNA par rapport aux enregistrements des clients ZTNA synchronisés à partir du FortiClient EMS et bloque ou autorise la connexion.

1) Lorsqu'un Client ZTNA veut se connecter à une page web, FortiGate intercepte la communication (proxy) et demande le certificat du client.

Serveur Web
IP : 10.0.1.250

Configuration ZTNA

- Configuration ZTNA HTTPS access proxy

- Configuration à réaliser sur le FortiGate

- **Connecteur Security Fabric FortiClient EMS**

- Le FortiGate maintient une connexion continue avec le serveur EMS pour synchroniser les informations sur les terminaux et les balises ZTNA.

- **Serveur ZTNA**

- Il définit l'adresse VIP du proxy d'accès et les serveurs réels auxquels les clients peuvent se connecter.

- **Règles ZTNA**

- Permet de définir des tags ou des groupes de tags ZTNA pour appliquer l'accès basé sur le rôle.
- Vous pouvez également configurer des profils de sécurité pour protéger ce trafic.

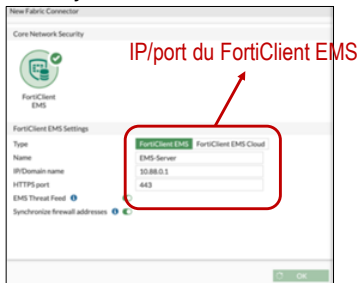
- **[Optionnel] Authentification**

- ZTNA prend en charge les méthodes HTTP et SAML.

Configuration ZTNA

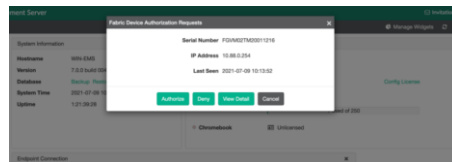
- Configuration ZTNA HTTPS access proxy (suite)
 - Configurer la connexion entre FortiGate et FortiClient EMS
 - FortiGate utilise un connecteur Fabric pour se connecter au FortiClient EMS.

Security Fabric > Fabric Connectors



- Le FortiGate doit être autorisé sur le FortiClient EMS.

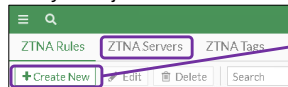
FortiClient EMS > Administration > Fabric Devices



Configuration ZTNA

- Configuration ZTNA HTTPS Access Proxy (suite)
 - Configurer un serveur ZTNA (proxy d'accès)
 - Définir l'adresse VIP du proxy d'accès et le serveur réel auquel les clients peuvent se connecter.

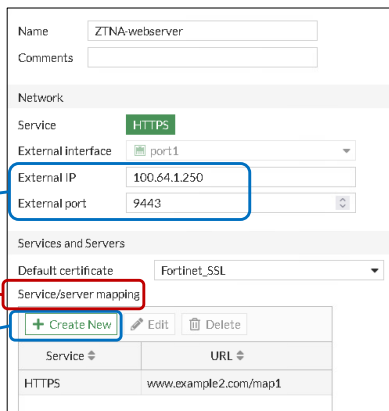
Policy & Objects > ZTNA > ZTNA Servers



Access proxy VIP (les clients envoient leurs requêtes vers cette adresse).

Définition des correspondances (mappages) entre des hôtes virtuels et les serveurs réels.

Voir diapositive suivante



Configuration ZTNA

- Configuration ZTNA HTTPS Access Proxy (suite)

Adresse et port réel du serveur Web

IP	10.0.1.250
Port	443
Status	Active Standby Disable

Service	HTTPS
Virtual Host	Any Host Specify
Match by	Substring Wildcard
Host	www.example2.com
Use certificate	Fortinet_CA_SSL
Match path by	Substring Wildcard Regular Expression
Path	/map1

IP	Port	Status
10.0.1.250	443	Active

Configuration ZTNA

- Configuration ZTNA HTTPS Access Proxy (suite)

— Configurer les règles ZTNA

- Permet de définir des balises et/ou des groupes de balises ZTNA afin d'appliquer le contrôle d'accès (basé sur le rôle).

Policy & Objects > ZTNA > ZTNA Rules

ZTNA Rules	ZTNA Servers	ZTNA Tags
+ Create New	Edit	Delete

Règle ZTNA autorisant les clients à accéder au serveur si ZTNA tag est satisfait

Vous pouvez aussi configurer des profils de sécurité pour protéger ce trafic.

Name	ZTNA-Allow-All
Source	all
ZTNA Tag	Remote-Endpoints
ZTNA Server	ZTNA-webserver
Action	ACCEPT DENY

Security Profiles
AntiVirus
Web Filter
Video Filter
Application Control
IPS
File Filter
SSL Inspection

Name	ZTNA-Deny-Malicious
Source	all
ZTNA Tag	Malicious-File-Detected
ZTNA Server	ZTNA-webserver
Action	ACCEPT DENY

Log Violation Traffic

Comments Write a comment... 0/1023

Enable this policy

Exemple de règle ZTNA refusant l'accès si un malware a été détecté sur le client

Configuration ZTNA

- Configuration ZTNA HTTPS Access Proxy (suite)
 - Configurer l'authentification

Les membres du groupe ZTNAaccess_group devront s'authentifier.

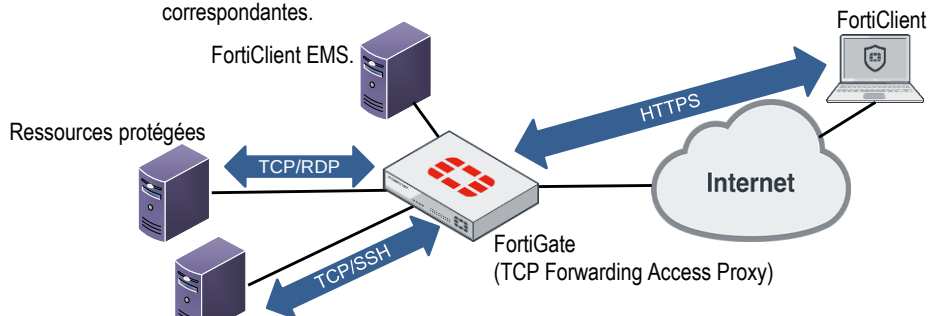
Authentification supportées : LDAP, RADIUS, Local

Policy & Objects > ZTNA > ZTNA Rules

Name	ZTNA-Allow-All
Source	all
	ZTNAaccess_group
ZTNA Tag	Remote-Endpoints
ZTNA Server	ZTNA-webserver
Action	☒ ACCEPT ☐ DENY
Security Profiles	
AntiVirus	☐
Web Filter	☐
Video Filter	☐
Application Control	☐
IPS	☐
File Filter	☐
SSL Inspection	☒ no-inspection
Logging Options	
Log Allowed Traffic	☐
Security Events	☒ All Sessions

Configuration ZTNA

- ZTNA TCP Forwarding Access Proxy (TFAP)
 - RDP, SSH, SMB
 - ZTNA prend en charge les applications basées sur HTTP/HTTPS.
 - TFAP permet de transmettre le trafic RDP, SSH, SMB vers les ressources correspondantes.



Configuration ZTNA

• Configuration

- Choisir TCP forwarding, sinon les étapes sont les mêmes que pour l'accès proxy (serveur, règles, authentification)

Policy & Objects > ZTNA > ZTNA Rules

ZTNA Rules ZTNA Servers ZTNA Tags

+ Create New Edit Delete Search

Edit ZTNA Server

Type IPv4

Name Web

Comments

Network

External Interface wan1

External IP 192.168.160.198

External port 8443

SAML

Services and Servers

Default certificate Fortinet_Factory

Service/server mapping

+ Create New Edit Delete

Service URL # Real Servers

TCP Forwarding /tcp 1

Edit Service/Server Mapping

Type IPv4

Service HTTP HTTPS TCP Forwarding

Virtual Host Any Host Specify

Servers

+ Create New Edit Delete

Address Ports

Web_Server 443

417

Configuration ZTNA

• ZTNA SSH Access Proxy

- Même rôle que TFAP mais spécifiquement prévu pour le trafic SSH
 - Permet d'appliquer les contrôles ZTNA au trafic SSH.
 - Permet l'application de l'inspection approfondie du trafic SSH (SSL/SSH inspection).
 - Permet la validation de la clé d'hôte SSH du serveur (facultatif).
 - Permet l'utilisation d'une authentification utilisateur à usage unique
 - Pour ne pas devoir s'authentifier au proxy d'accès SSH ZTNA et puis au serveur SSH.

Configuration ZTNA

- **ZTNA IP/MAC-Based Access Control**
 - Utilisé pour accéder à un serveur Web interne lorsque les terminaux sont physiquement situés sur le réseau de l'entreprise (On-net).

Policy & Objects > Firewall Policy

Name	Block-Malicious
Incoming Interface	port3
Outgoing Interface	port1
Source	all
Destination	all
Schedule	always
Service	ALL
Action	ACCEPT DENY

Log Violation Traffic

Comments Write a comment... 0/1023

Enable this policy

- Ce mode ne nécessite pas l'utilisation d'un proxy d'accès.
- Permet d'utiliser les balises ZTNA pour le contrôle d'accès au niveau des règles de FW.

Select Entries

Search

ZTNA TAG (51)

FCITEMS - IP (10)

ZTNA IP	all_registered_clients
ZTNA IP	EDR-Classification
ZTNA IP	Endpoint_Compliance
ZTNA IP	Important
ZTNA IP	Infected
ZTNA IP	noav
ZTNA IP	...

419

ZTNA vs IPsec vs SSL

- **Comparaison ZTNA vs VPN**
 - **Granularité**
 - **Un VPN donne généralement un plus large accès aux ressources**
 - Par exemple, l'accès à un réseau entier.
 - **Le ZTNA traite chaque utilisateur et appareil individuellement**
 - Seules les ressources auxquelles l'utilisateur et l'appareil sont autorisés à accéder sont mises véritablement à disposition.
 - **Visibilité**
 - **Le VPN n'a pas conscience du trafic et de son utilisation**
 - Cela rend plus difficile la visibilité de l'activité des utilisateurs et de l'utilisation des applications.
 - **ZTNA est micro-segmenté**
 - Il peut offrir une visibilité accrue sur l'activité des applications.
 - Cette possibilité facilite grandement la surveillance de l'état des applications, la planification des capacités, la gestion et l'audit des licences.

420

- Comparaison ZTNA vs VPN (suite)

- Sécurité

- Une architecture Zero Trust réduit considérablement la surface d'attaque
 - Car les ports et les applications sont invisibles à moins d'être authentifiés et autorisés.
 - Car il impose une vérification permanente des utilisateurs et des appareils.
 - Car il fournit un accès minimal (Least privilege) aux utilisateurs et aux appareils en fonction de leur rôle dans l'entreprise.
 - Car il n'y a pas de risque de laisser un VPN accidentellement ouvert.
 - Déplacement latéral
 - Une architecture Zero Trust entrave considérablement les possibilités de déplacement latéral d'un pirate sur le réseau (micro-segmentation).
 - État de sécurité de l'appareil
 - Un VPN d'accès à distance n'a aucune connaissance de l'état de fonctionnement d'un périphérique client.
 - ZTNA intègre la conformité et l'état de sécurité des appareils dans les politiques d'accès.

» Cette approche réduit considérablement le risque de vol ou de fuite de données.

- Comparaison ZTNA vs VPN (suite)

- Expérience utilisateur

- Les clients VPN d'accès à distance sont connus pour offrir une expérience utilisateur médiocre
 - Ajout de latence, problèmes en matière de connectivité, à quel VPN se connecter, ...
 - Avec ZTNA, l'utilisateur n'a plus besoin de savoir à quel VPN se connecter ni où se trouvent les ressources
 - L'utilisateur clique simplement sur l'application pour obtenir une connexion sécurisée, que l'application soit sur site, dans un cloud public ou un cloud privé.
 - ZTNA établit automatiquement des connexions sécurisées à la demande, la plupart des utilisateurs ne remarqueront même pas la présence de la solution ZTNA.

- Mise en conformité

- Avec ZTNA, chaque demande d'accès est évaluée et peut être enregistrée
 - Il est donc plus facile de constituer la documentation relative à la conformité.
 - Les audits sont simplifiés, car il existe une chaîne de preuves visibles pour toutes les demandes d'accès.

- **Comparaison ZTNA vs VPN (suite)**

- **Flexibilité et agilité**

- **Les VPN n'offrent pas la même granularité que les solutions ZTNA**

- L'installation et la configuration d'un logiciel client VPN sur les terminaux de tous les utilisateurs et la configuration de multiples tunnels VPN peuvent s'avérer complexes : nœuds multiples, règles d'accès au pare-feu, gestion des adresses IP, des flux de trafic et du routage.

- **ZTNA est plus agile dans des environnements qui changent rapidement, avec des utilisateurs, des applications et des appareils qui vont et viennent**

- Il est beaucoup plus facile d'ajouter ou de supprimer des règles de sécurité et les autorisations des utilisateurs en fonction de leurs besoins immédiats.

- **Déploiement ZTNA**

- ZTNA ne nécessite pas d'être déployé en une fois dans l'ensemble de l'infrastructure mais peut être déployé pour des groupes d'utilisateurs ou des applications spécifiques.
 - ZTNA utilise les méthodes d'authentification existantes et les méthodes d'accès aux applications natives, ce qui se traduit par une expérience utilisateur transparente.

	VPN IPsec	VPN SSL	ZTNA
Type de tunnel	Tunnel	Tunnel	Par session
Configuré entre :	• Forticlient-Fortigate. • Browser-Fortigate • FortiGate-GW VPN tiers • FortiGate-client VPN tiers	• Forticlient-Fortigate. • Browser-Fortigate • FortiGate-GW VPN tiers • FortiGate-client VPN tiers	• Browser-Fortigate • Forticlient-Fortigate (TCP Forwarding Access)
Connexion via	Client IPsec	Page web sur le Fortigate FortiClient FortiGate (client SSL)	Noms d'hôte HTTPS ou IP/Port FortiClient (TCP forwarding access)
Interopérabilité	• Standard interopérable avec plusieurs fournisseurs.	• Peut être spécifique au fournisseur.	• Peut être spécifique au fournisseur.
Utilisation courante	• Site à site, site à agence. • Data center.	• Télétravailleurs, Utilisateurs mobile (Internet cafés, bibliothèques, ...) • Flexible ; Mode tunnel ou par session	• Télétravailleurs • Utilisateurs locaux • Uniquement par session

ZTNA vs IPsec vs SSL

	VPN IPsec	VPN SSL	ZTNA
Implémentation	• Plus flexible. ◦ Topologies en étoile et maillée possibles. ◦ Vers client ou autre passerelle VPN. ◦ Chiffrement plus rapide car réalisé par la passerelle BPN.	• Configuration plus simple que IPsec • Ne nécessite pas d'installation (Web only) • Uniquement d'un client SSL vers un serveur SSL • Aucun paramétrage requis par l'utilisateur.	• Configuration plus simple que IPsec • Ne nécessite pas d'installation • Seulement de client à FortiGate • Aucun paramétrage requis par l'utilisateur. • Support technique est moins sollicité
Surface d'attaque	• Protection traditionnelle du périmètre : ◦ Protection contre les menaces externes uniquement ◦ Ne couvre pas les menaces à l'intérieur du réseau	• Protection traditionnelle du périmètre : ◦ Protection contre les menaces externes uniquement ◦ Ne couvre pas les menaces à l'intérieur du réseau	• Philosophie Zero Trust ◦ Personne à l'intérieur ou à l'extérieur du réseau ne doit être digne de confiance sans vérifications. ◦ Basée sur l'authentification systématique de l'identité.

ZTNA vs IPsec vs SSL

• Limites du ZTNA

– BYOD

- Le Zero Trust dans un lieu de travail qui s'appuie fortement sur le BYOD peut nécessiter beaucoup de travail, surtout en amont.

– Nombre élevé d'applications

- Un grand nombre d'applications devant être surveillées et sécurisées selon les normes Zero Trust peut rendre difficile la mise en œuvre de l'architecture ZTA.

– Dépendance aux fournisseurs

- La mise en œuvre du ZTNA peut entraîner une dépendance accrue vis-à-vis des fournisseurs de solutions de sécurité spécifiques.
- Cela peut limiter la flexibilité et la portabilité des infrastructures, et peut également entraîner des problèmes de compatibilité avec d'autres systèmes ou solutions.

- **Limites du ZTNA**

- Latence

- Le ZTNA peut potentiellement entraîner une augmentation de la latence et une réduction des performances réseau.
 - Cela est dû aux exigences de chiffrement et de déchiffrement des données, ainsi qu'à la nécessité de vérifier l'authentification de chaque utilisateur avant d'autoriser l'accès aux ressources.

- Coût :

- L'adoption du ZTNA peut entraîner des coûts supplémentaires, notamment pour l'achat et la configuration de solutions logicielles ou matérielles spécifiques.
 - De plus, la gestion et la maintenance continues de l'infrastructure ZTNA peuvent nécessiter des ressources supplémentaires.

Bibliographie

Ouvrages

O. SANTOS, J. STUPPI, *CCNA Security 210-260 Official Cert Guide*, Cisco Press, septembre 2015.

Sources électroniques

ANSSI, *Recommandations de sécurité relatives à TLS*,
https://www.ssi.gouv.fr/uploads/2016/09/guide_tls_v1.1.pdf, 2016.

ANSSI, *Note technique. Recommandations de sécurité relatives à IPsec pour la protection des flux réseau*, https://www.ssi.gouv.fr/uploads/2012/09/NT_IPsec.pdf, 2015.

BOUSABER C., IKE v2, <https://www.randco.fr/blog/2013/ike-v2/>, 2013.

ETUTORIALS.ORG, *RSA Encrypted Nonces Overview*,
<http://etutorials.org/Networking/Cisco+Certified+Security+Professional+Certification/Part+II+Virtual+Private+Networks+VPNs/Chapter+11+Cisco+IOS+IPSec+Certificate+Authority+Support/RSA+Encrypted+Nonces+Overview/>,

FRIEDL S., *An Illustrated Guide to IPsec*, <http://www.unixwiz.net/techtips/iguide-ipsec.html>, 2005.

FORTINET, INC., *FortiOS-AdministrationGuide Version 7.4.5*,
<https://docs.fortinet.com/document/fortigate/7.4.5/administration-guide/383477>; mars 2025.

FORTINET NSE TRAINING INSTITUTE, *NSE4 -FortiGate Security and Infrastructure (FortiOS 7.4)*, <https://www.fortinet.com/training/security-academy-program>, 2025.

MILLER L., *Zero trust access for dummies*,
<https://www.fortinet.com/content/dam/fortinet/assets/ebook/zero-trust-access-for-dummies.pdf>, 2022